



AccuKnox Inc.

**Service and Organization Controls (SOC) 2 Type II
Report
Security, Availability, and Confidentiality**



Independent Report on the AccuKnox System's description and the Design's Suitability and Operating Effectiveness of its Controls to meet the Criteria for the Security, Availability, Processing Integrity, and Confidentiality Principles.

This report is valid for the period from July 1, 2024, to December 31, 2024.

THIS REPORT IS CONFIDENTIAL

This report is intended solely for the use of AccuKnox, and the authorized parties with AccuKnox signed a non-disclosure agreement.

By:



Infoguard Cyber Security, Inc.

333 W. San Carlos St. Suite 920
San Jose, CA 95113

www.InfoguardSecurity.com

Table of Contents

Section I. Independent Auditor's Report for the Security, Availability, Processing Integrity, and Confidentiality Criteria	5
1. Validity of the Report	5
2. Scope	5
3. Applicability of Report.....	6
4. Service Organization's Responsibilities	6
5. Service Auditor's Responsibilities	7
6. Service Auditor's Independence and Quality Control.....	7
7. Inherent Limitations	7
8. Description of Tests of Controls	8
9. Opinion.....	8
10. Restricted Use	8
11. General Terms of Engagement.....	9
Section II. AccuKnox Management Assertion	11
Section III. Description of AccuKnox Service & System	14
1. Company Background	14
2. Control Environment.....	14
3. The Principal Service Commitments and System Requirements	15
4. Service Description.....	15
5. System Description (used to provide services)	16
6. AccuKnox Related Security Controls	22
7. Complementary User Entity Controls (CUEC)	48
8. Complementary Subservice Organization Controls (CSOCs).....	49
9. Criteria Not Application to the System	49
10. Significant Changes During the Review Period	49
Section IV. Information Provided by Independent Service Auditor and Test Results.....	51
1. Control Environmental Elements	51
2. Description of Test Procedures performed.....	51
3. Trust Services Principles, Criteria, and Controls	52
4. Test Results of the Trust Services Principles, Criteria, and AccuKnox-Related Controls	54
Section V. Notes	130

Disclaimer

AccuKnox ("Client") has engaged InfoGuard Cyber Security ("InfoGuard") to report on the description of AccuKnox solutions ("the description") and the Suitability of Design and Operating Effectiveness of Controls to meet the Criteria for the Security and Availability principles set forth in TSP section 100, Trust Services Principles, Criteria, and Illustrations for Security, Availability, Processing Integrity, Confidentiality, and Privacy (AICPA, Technical Practice Aids, issued March 2016, "applicable trust services criteria"), throughout the period January 1, 2024, to June 30, 2024, in accordance with the International Standard on Assurance Engagements 3000 (Revised): "Assurance Engagements other than Audits or Reviews of Historical Financial Information" (ISAE 3000 (Revised)). On the basis of this engagement, we provided the Client with the following Service Organization Control (SOC) Report ("Report").

Access to the Report has been granted to AccuKnox after acknowledgment and acceptance of the following terms and conditions:

- (1) InfoGuard does not provide any recommendations regarding the use of the abovementioned System.
- (2) The Report was prepared on the basis of the engagement between our Client and us. Our responsibility for the Report is exclusively determined by the terms and conditions of this engagement letter and is asserted solely towards our Client. We do not accept any responsibility for the Report towards any third party. In particular, we do not assume any responsibility as to whether our Report is suitable for any third-party's purposes. The aforementioned conditions shall, however, not apply to losses, damages, or costs arising from the willful or fraudulent behavior of InfoGuard.
- (3) Anything deviating from these terms and conditions shall only apply if you and InfoGuard have agreed on it in writing. If you wish to enter into such a written agreement, please contact InfoGuard.com.
- (4) We have not carried out any work or made any inquiries since the date of the Report. The Report does not incorporate the effects, if any, of events and circumstances which may have occurred or information that may have come to light subsequent to that date.
- (5) This report is confidential.

Section I

Independent Service Auditor's Report for Security, Availability, Processing Integrity, and Confidentiality Criteria



Section I. Independent Auditor's Report for the Security, Availability, Processing Integrity, and Confidentiality Criteria

AccuKnox Inc.
333 Ravenswood Ave.
Suite AG 138, SRI
Menlo Park, CA 94025

1. Validity of the Report

This report is valid for the period from July 1, 2024, to December 31, 2024.

2. Scope

We have examined the description of the system of AccuKnox (the "Service Organization" or "AccuKnox") related to in-scope service and offerings for AccuKnox Platform ("AccuKnox Platform") throughout the period January 1, 2024, to June 30, 2024 (the "Description") based on the criteria for a description of a service organization's system set forth in DC Section 200, *2018 Description Criteria for a Description of a Service Organization's System in a SOC 2® Report* ("description criteria"), and the suitability of the design and operating effectiveness of controls stated in the Description throughout the period January 1, 2024, to June 30, 2024 to provide reasonable assurance that AccuKnox's service commitments and system requirements were achieved based on the trust services criteria relevant to security, availability, processing integrity, and confidentiality ("applicable trust services criteria") set forth in TSP Section 100, *2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy*.

As indicated in the Description, AccuKnox uses Google Cloud Platform (GCP) as the subservice organization to provide platform and infrastructure services to host the production environment supporting AccuKnox Platform. The Description includes only control objectives and the related controls of AccuKnox and excludes the control objectives and related controls of GCP. The description indicates that complementary subservice organization controls that are suitably designed and operating effectively are necessary, along with controls at AccuKnox, to achieve AccuKnox's service commitments and system requirements based on the applicable trust services criteria. The description presents AccuKnox's controls, the applicable trust services criteria, and the types of complementary subservice organization controls assumed in the design of AccuKnox's controls. The description does not disclose the actual controls at the subservice organization.

The description indicates that complementary user entity controls that are suitably designed and operating effectively are necessary, along with controls at AccuKnox, to achieve AccuKnox's service commitments and system requirements based on the applicable trust services criteria. The description presents AccuKnox's controls, the applicable trust services criteria, and the complementary user entity controls assumed in the design of AccuKnox's controls.

3. Applicability of Report

This report has been prepared to provide information on internal controls of AccuKnox that may be relevant to customers pursuing the security, availability, processing integrity, and confidentiality trust principles. AccuKnox has considered the service-specific characteristics and commitments to determine the applicability of the SOC 2 Trust Principles for the in-scope services. Based on the guidance from AICPA, the following are the applicability considerations:

Security	Addresses risks related to potential abuse, theft, misuse, and improper access to system components	Applies to the underlying physical and virtual infrastructure of the services
Availability	Addresses risks related to system accessibility for processing, monitoring, and maintenance	Applies to the services whose accessibility is advertised or committed by contract
Processing Integrity	Addresses risks related to completeness, accuracy, and timeliness of system/application processing of transactions	Applies to the services that operate transaction processing interfaces
Confidentiality	Addresses risks related to unauthorized access or disclosure of specific information designated as “confidential” within contractual arrangements	Applies to the customer data elements that are designated as “confidential” based on the company’s data classification policy
Privacy	Addresses risks related to the protection and management of personal information	Privacy of end-users and any privacy-related data associated with applications or services developed on the platform is the customer’s responsibility, as described in AccuKnox Trust Center. Not applicable since personal information of customer administrators is collected and handled within the AccuKnox Customer Portal, which is outside the scope of the system boundaries

4. Service Organization’s Responsibilities

AccuKnox is responsible for its service commitments and system requirements and for designing, implementing, and operating effective controls within the system to provide reasonable assurance that AccuKnox’s service commitments and system requirements were achieved. AccuKnox has provided the accompanying assertion titled “AccuKnox Management Assertion” (the “assertion”) about the Description and the suitability of design and operating effectiveness of controls stated therein. AccuKnox is also responsible for preparing the Description and assertion, including the completeness, accuracy, and method of presentation of the Description and assertion; providing the services covered by the Description; selecting the applicable trust services criteria and stating the related controls in the Description; and identifying the risks that threaten the achievement of the Service Organization’s service commitments and system requirements.

AccuKnox is responsible for:

- Preparing the description of the service organization’s system and the assertion, including the completeness, accuracy, and method of presentation of both the description and assertion;
- Providing the services covered by the description of the service organization’s system;

- Selecting the trust services principles addressed by the engagement and stating the applicable trust services criteria and related controls in the description of the service organization’s system;
- Identifying the risks that would prevent the applicable trust services criteria from being met;
- Identifying any applicable trust services criteria related to the principles being reported on that have been omitted from the description and explaining the reason for the omission; and
- Designing, implementing, and documenting the controls to meet the applicable trust services criteria.

5. Service Auditor’s Responsibilities

Our responsibility is to express an opinion on the Description and on the suitability of the design and operating effectiveness of the controls stated in the Description based on our examination. Our examination was conducted in accordance with attestation standards established by the American Institute of Certified Public Accountants. Those standards require that we plan and perform our examination to obtain reasonable assurance about whether, in all material respects, the Description is presented in accordance with the description criteria, and the controls stated therein were suitably designed and operating effectively to provide reasonable assurance that (a) the Service Organization’s service commitments and system requirements were achieved based on the applicable trust services criteria. We believe that the evidence we obtained is sufficient and appropriate to provide a reasonable basis for our opinion.

An examination of the description of a service organization’s system and the suitability of the design and operating effectiveness of those controls involves the following:

- Obtaining an understanding of the system and the service organization’s service commitments and system requirements.
- Assessing the risks that the Description is not presented in accordance with the description criteria and that controls were not suitably designed or did not operate effectively.
- Performing procedures to obtain evidence about whether the Description is presented in accordance with the description criteria.
- Performing procedures to obtain evidence about whether controls stated in the Description were suitably designed to provide reasonable assurance that the service organization achieved its service commitments and system requirements based on the applicable trust services criteria.
- Testing the operating effectiveness of those controls stated in the Description to provide reasonable assurance that the service organization achieved its service commitments and system requirements based on the applicable trust services criteria.
- Evaluating the overall presentation of the Description.

Our examination also included performing such other procedures as we considered necessary in the circumstances.

6. Service Auditor’s Independence and Quality Control

We have complied with the independence and other ethical requirements of the Code of Professional Conduct established by the AICPA. We applied the statements on quality control standards established by the AICPA and, accordingly, maintained a comprehensive system of quality control.

7. Inherent Limitations

The Description is prepared to meet the common needs of a broad range of report users and may not, therefore, include every aspect of the system that individual users may consider important to meet their informational

needs. There are inherent limitations in the effectiveness of any system of internal control, including the possibility of human error and the circumvention of controls.

Because of their nature, controls may not always operate effectively to provide reasonable assurance that the Service Organization’s service commitments and system requirements are achieved based on the applicable trust services criteria. Also, the projection to the future of any conclusions about the suitability of the design or operating effectiveness of the controls is subject to the risk that may become inadequate because of changes in conditions or that the degree of compliance with the policies or procedures may deteriorate.

8. Description of Tests of Controls

The specific controls we tested, the nature, timing, and results of our tests are listed in section IV of this Report.

9. Opinion

In our opinion, in all material respects, based on the description criteria identified in AccuKnox’s assertion and the applicable trust services criteria:

In our opinion, in all material respects,

- a. The Description presents AccuKnox’s system related to in-scope services and offerings for AccuKnox Platform that was designed and implemented throughout the period January 1, 2024, to June 30, 2024, in accordance with the description criteria.
- b. The controls stated in the Description were suitably designed throughout the period January 1, 2024, to June 30, 2024, to provide reasonable assurance that AccuKnox’s service commitments and systems requirements would be achieved based on the applicable trust services criteria if the controls operated effectively throughout that period and if the subservice organization and user entities applied the complementary controls assumed in the design of AccuKnox’s controls throughout that period.
- c. The controls stated in the Description operated effectively throughout the period January 1, 2024, to June 30, 2024, to provide reasonable assurance that AccuKnox’s service commitments and system requirements were achieved based on the applicable trust services criteria if complementary subservice organization controls and complementary user entity controls assumed in the design of AccuKnox’s controls operated effectively throughout that period.

10. Restricted Use

This report, including the description of tests of controls and results thereof in section III, is intended solely for the information and use of AccuKnox and user entities of AccuKnox’s system during some or all of the period January 1, 2024, to June 30, 2024, and prospective user entities, independent auditors and practitioners providing services to such user entities, and regulators (collectively referred to as “specified parties”) who have sufficient knowledge and understanding of the following:

- The nature of the service provided by the service organization;
- How the service organization’s system interacts with user entities, subservice organizations, and other parties;
- Internal control and its limitations;
- User entity responsibilities, complementary user entity controls, and how they interact with related controls at the service organization to meet the applicable trust services criteria;
- The applicable trust services criteria;
- The risks that may threaten meeting the applicable trust services criteria and how controls address those risks.

This report is not intended to be, and should not be, used by anyone other than these specified parties. If a report recipient is not a specified party as defined above and has obtained this report or has access to it, the use of this report is the non-specified user’s sole responsibility and at the non-specified user’s sole and exclusive risk. Non-specified users may not rely on this report and do not acquire any rights against InfoGuard as a result of such access. Further, InfoGuard does not assume any duties or obligations to any non-specified user who obtains this report and/or has access to it.

11. General Terms of Engagement

We issue this report on the basis of the engagement agreed with AccuKnox.

San Jose, California, June 30, 2024



Jonathan Gruchy

InfoGuard Cyber Security



Section II

AccuKnox Management Assertion

Section II. AccuKnox Management Assertion

We have prepared the accompanying description of the product and service of AccuKnox (the “Service Organization” or “AccuKnox”) throughout the period January 1, 2024, to June 30, 2024 (the “period”) related to the in-scope offering for AccuKnox Platform (“AccuKnox Platform”) in Section III titled “AccuKnox Platform Description” (the “Description”). The Description is based on the criteria for a description of a service organization's system in DC section 200, 2018 Description Criteria for a Description of a Service Organization's System in a SOC 2® Report (“Description Criteria”). The Description is intended to provide report users with information about the AccuKnox Platform that may be useful when assessing the risks arising from interactions with AccuKnox's system, particularly information about system controls that AccuKnox has designed, implemented, and operated to provide reasonable assurance that its service commitments and system requirements were achieved based on the trust services criteria relevant to security, availability, processing integrity, confidentiality, and privacy (applicable trust services criteria) set forth in TSP section 100, 2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy (AICPA, Trust Services Criteria).

We confirm, to the best of our knowledge and belief, that

- a. The Description fairly presents the system throughout the period January 1, 2024, to June 30, 2024, based on the following description criteria:
 - i. The Description contains the following information:
 - (1) The types of services provided.
 - (2) The components of the system used to provide the services, which are as follows:
 - (a) **Infrastructure.** The physical structures, IT, and other hardware (for example, facilities, computers, equipment, mobile devices, and other telecommunications networks).
 - (b) **Software.** The application programs and IT system software that supports application programs (operating systems, middleware, and utilities).
 - (c) **People.** The personnel involved in the governance, operation, and use of a system (developers, operators, entity users, vendor personnel, and managers).
 - (d) **Procedures.** Automated and manual procedures.
 - (e) **Data.** Transaction Streams, files, databases, tables, and output used or processed by the system.
 - (3) The boundaries or aspects of the system covered by the description.
 - (4) For information provided to, or received from, subservice organizations and other parties:
 - (a) How the information is provided or received and the role of the subservice organization and other parties.
 - (b) The procedures the service organization performs to determine that such information and its processing, maintenance, and storage are subject to appropriate controls.
 - (5) The applicable trust services criteria and the related controls designed to meet those criteria, including, as applicable, the following:
 - (a) Complementary user entity controls assumed in the design of the service organization's system.
 - (b) When the inclusive method is used to present a subservice organization, controls at the subservice organization.
 - (6) If the service organization presents the subservice organization using the carve-out method:
 - (a) The nature of the services provided by the subservice organization.
 - (b) Each of the applicable trust services criteria that are intended to be met by controls at the subservice organization, alone or in combination with controls at the service organization, and the types of controls expected to be implemented at carved-out subservice organizations to meet those criteria.

- (7) Any applicable trust services criteria that are not addressed by control and the reasons relevant details of changes to the service organization's system during the period covered by the description.
- ii. The description does not omit or distort information relevant to the service organization's system while acknowledging that the description is prepared to meet the common needs of a broad range of users and may not, therefore, include every aspect of the system that each individual user may consider important to his or her own particular needs.
- b. The controls stated in the description were suitably designed to meet the applicable trust services criteria throughout the period January 1, 2024, to June 30, 2024, if user entities applied the complementary user entity controls assumed in the design of AccuKnox's controls throughout the period January 1, 2024, to June 30, 2024.
- c. The controls stated in the description operated effectively throughout the period January 1, 2024, to June 30, 2024, to meet the applicable trust services criteria if user entities applied the complementary user entity controls assumed in the design of AccuKnox's controls, and those controls operated effectively throughout the period January 1, 2024, to June 30, 2024.

June 25, 2024

Nat Natraj

Nat Natraj

CEO,

AccuKnox Inc.



Section III

AccuKnox Platform System Description

**throughout the period
January 1, 2024, to June 30, 2024**

Section III. Description of AccuKnox Service & System

Throughout January 1, 2024, to June 30, 2024

1. Company Background

AccuKnox Technologies, Inc., located in Silicon Valley, was founded in 2020 to provide Identity-driven Security for Data, Kubernetes, and Native VM workloads for Private and Public Clouds. AccuKnox provides Zero Trust Run-time Kubernetes Security Solution and provides run-time protection for Kubernetes and other cloud workloads using Kernel Native Primitives such as AppArmor, SELinux, and eBPF.

2. Control Environment

2.1. Standards of Business Conduct

AccuKnox's organizational structure and governance provide the framework within which its activities for achieving entity-wide objectives are planned, executed, controlled, and monitored. Corporate governance at AccuKnox starts with an independent Board of Directors that establishes, maintains, and monitors standards and policies for ethics, business practices, and compliance that span across the company.

Corporate governance at AccuKnox serves several purposes:

- To establish and preserve management accountability to AccuKnox's owners by appropriately distributing rights and responsibilities among AccuKnox Board members, managers, and shareholders
- To provide a structure through which management and the Board set and attain objectives and monitor performance
- To strengthen and safeguard a culture of business integrity and responsible business practices
- To encourage efficient use of resources and to require accountability for the stewardship of these resources

2.2. Integrity and Ethical Values

AccuKnox Standards of Business Conduct (SBC) reflect a commitment to ethical business practices and regulatory compliance. They summarize the principles and policies that guide AccuKnox's business activities and provide information about AccuKnox's Business Conduct and Compliance Program. SBC was developed in full consideration of the AccuKnox codes of conduct policy.

Annual SBC training is mandatory for all AccuKnox employees and contingent staff. The SBC training includes information about AccuKnox corporate policies for conducting business while conforming to applicable laws and regulations. It reinforces the need for employees to work with integrity and to comply with the laws of the countries in which AccuKnox operates. It also guides employees and contingent staff on the processes and channels available to report possible violations or to ask questions.

2.3. Accountability

All contingent staff are accountable for understanding and adhering to the requirements contained in the Security Policy and any applicable supporting procedures. Individuals not employed by AccuKnox but allowed to access, manage, or process information assets are also accountable for understanding and adhering to the guidance contained in the Security Policy and standards.

2.4. Commitment to Competence

AccuKnox management defines competence as the knowledge and skills necessary to accomplish tasks that define employees' roles and responsibilities. Management's commitment to competence includes management's consideration of the competence levels for particular jobs and how those levels translate into the requisite skills and knowledge.

Specific control activities that AccuKnox has implemented in this area are described below:

- Management has considered the competency levels for particular jobs and translated required skills and knowledge levels into written position requirements.
- Ongoing training is provided to maintain the skill level of personnel in certain positions

3. The Principal Service Commitments and System Requirements

AccuKnox designs its product and services to meet its objectives for its AccuKnox services. Those objectives are based on the service commitments that AccuKnox makes to user entities, the laws, and regulations that govern the provision of the AccuKnox services, and the compliance requirements that AccuKnox has established for the services.

Security commitments to user entities are documented and communicated in Service Level Agreements (SLAs) and other customer agreements, as well as in the description of the service offering provided online. Security commitments are standardized and include, but are not limited to, the following:

- Security principles within the fundamental designs of AccuKnox that are designed to permit system users to access the information they need based on their role in the system while restricting them from accessing information not needed for their role
- Use of encryption technologies to protect customer data both at rest and in transit

AccuKnox establishes operational requirements that support the achievement of security commitments, relevant laws and regulations, and other system requirements. Such requirements are communicated in AccuKnox's system policies and procedures, system design documentation, and contracts with customers. Information security policies define an organization-wide approach to how systems and data are protected. These include policies around how the service is designed and developed, how the system is operated, how the internal business systems and networks are managed, and how employees are hired and trained. In addition to these policies, standard operating procedures have been documented on how to carry out the specific manual and automated processes required in the operation and development of AccuKnox.

4. Service Description

AccuKnox is Zero Trust Run-time Kubernetes Security Solution. It provides run-time protection for clients' Kubernetes and other cloud workloads using Kernel Native Primitives such as AppArmor, SELinux, and eBPF.

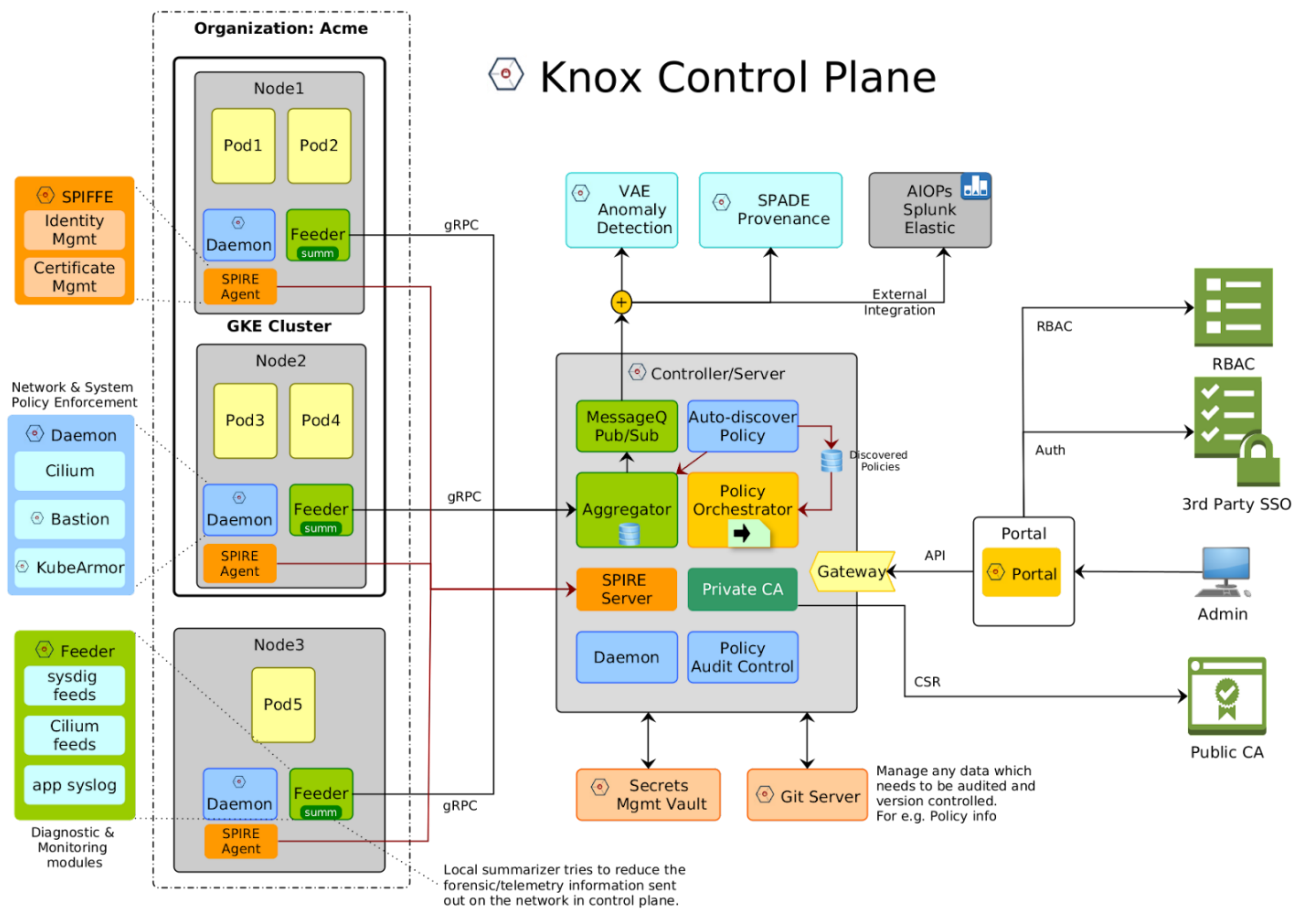
Product Solution Features:

- Identity-driven Security for Data, Kubernetes, and Native VM workloads for Private and Public Clouds
- Automatic generation of policies for client's workload in seconds
- Identity as a perimeter of security it uses SPIFFE id for network policies
- Anomaly detection to protect against any malicious behavior
- Support for SIEM / SOAR Integrations

5. System Description (used to provide services)

As outlined in TSP section 100 Trust Services Criteria, a system is designed, implemented, and operated to achieve AccuKnox's specific objectives for delivery of services in accordance with AccuKnox management-specific requirements. The purpose of the system description is to delineate the boundaries of the system, which includes the services outlined above and the five components described below:

- Infrastructure,
- Software,
- People,
- Procedures, and
- Data

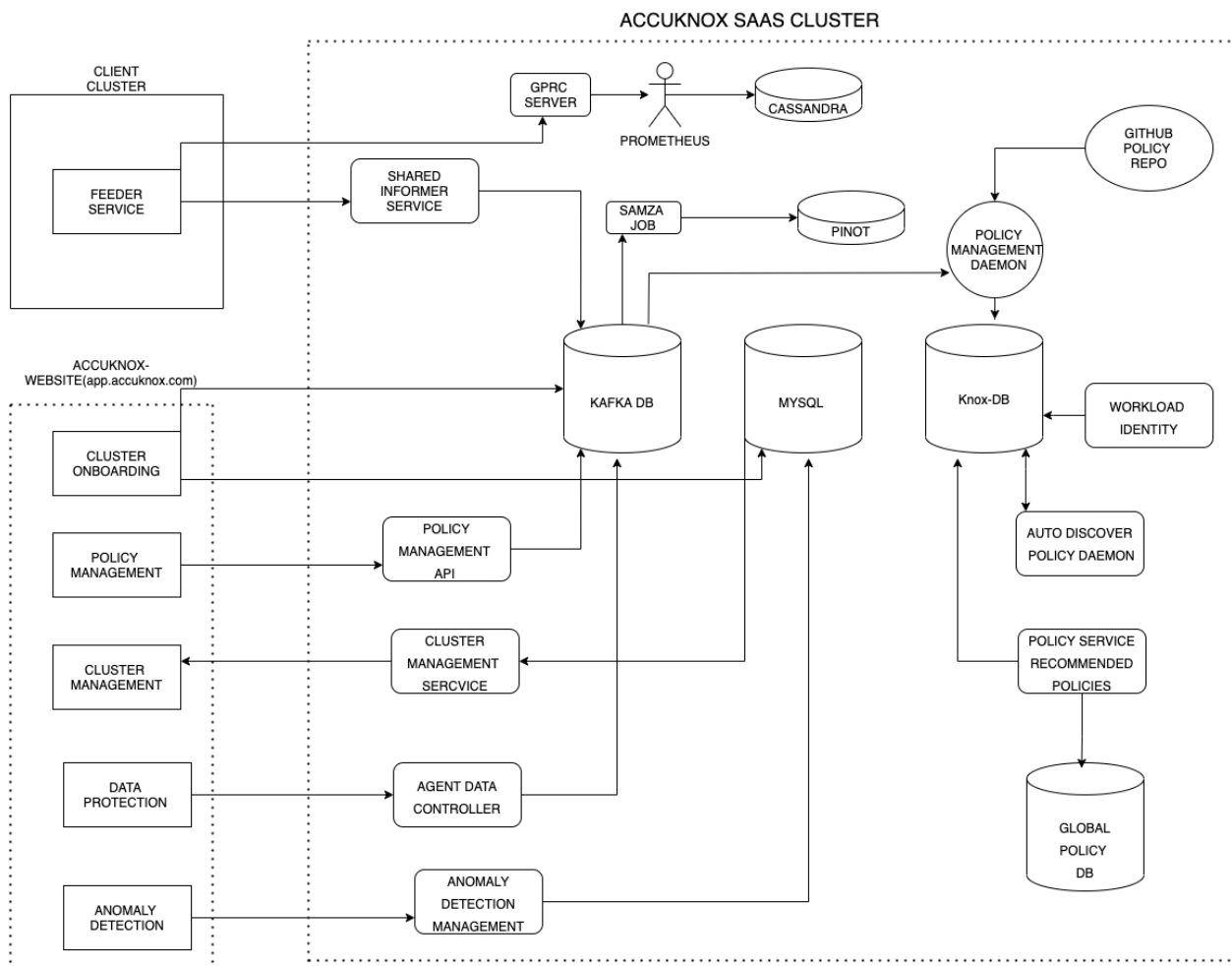


AccuKnox SaaS Platform

The following figure depicts the internal architecture of the AccuKnox SaaS platform. Key components are feeder service, shared informer service, anomaly detection, data protection and policy, and cluster managers, which are used to visualize and protect the customer workload.

The workflow includes:

- **Feeder service** - Collects all the client cluster details after onboarding and feeding the data to share informer service through HTTPS Protocol
- **Shared-Informer-Service** - Receive the Data from the feeder service and share the data to Kafka DB through GRPC and RBAC
- **Policy Management Daemon** - Sends the client Data to KnoxDB, including GitHub policy repository data, and managing the overall policy
- **Cluster Management Service** - It pulls the data from Mysql DB and shares (how many clusters onboarded) the status to UI
- **Data Protection service** - It manipulates the data from DB and pushes it to the agent data controller
- **Agent data controller** - It receives data from agents through HTTP and forwards it to different Kafka topics. It can easily be scaled up horizontally by spinning up more Pods
- **Anomaly detection** - Train the client container via machinery algorithm and to find any anomaly detection (abnormal behavior) in the container



5.1. Infrastructure and Environment

AccuKnox utilizes secure third-party Cloud Service Providers like GCP, AWS, etc. This data center continues to provide SaaS to customers for their production servers and systems. GCP had a SOC 2 Type II. The scope of this audit does not include the controls of GCP.

5.1.1. AccuKnox Development Infrastructure

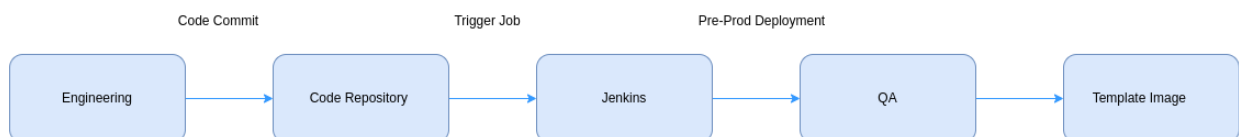
AccuKnox software is developed and maintained by the AccuKnox software team. This team is comprised of experienced software developers with deep knowledge of the systems in use within AccuKnox. The source code is retained in the AccuKnox GitHub code repository, and access is limited to users on the AccuKnox team.

The AccuKnox DevOps team deploys the release candidates that have passed QA and UAT verifications to GCP, which are of interest to the customer. Specifically, the front-end deployment will be delivered through the GCP Kubernetes Services. The backend components will be delivered through GCP infrastructure services.

Changes to the AccuKnox software are managed through a documented change control process. This process enables a second AccuKnox developer to review each change and to bring in additional reviewers as needed. Approval by a non-author who is qualified to review the code is required for any code to be considered for a merge to the main branch of the repository. Change records are generated. Development and testing are performed locally on developer machines and in dedicated, separate GCP environments and do not interact in any way with the production customer systems.

AccuKnox application development is primarily accomplished on laptops, and all subsequent integration, Quality Assurance (QA), User Acceptance Testing (UAT), and Production (PROD) deployments run within the GCP. The platform uses multiple GCP services, which are detailed in subsequent sections, to deliver a highly scalable, redundant solution to AccuKnox customers.

The engineering team pushes the code to the repository. The repository is GitHub. Whenever a new Git push happens to the repository, it automatically triggers a job on the Jenkins Server. The Jenkins job builds the release version of the code and saves a template image on a cloud storage bucket as well as Artifactory, which is controlled by the methodscuKnox DevSecOps team.



Development Workflow

Many of the server products that support application and integration services share common requirements and similar tools for server configuration and administration

- Developers work on bugs and features in separate branches. For all major and minor updates, a PR is to be raised to the development branch from where a secure CI/CD pipeline takes over and deploys it to the dev environment. After a strict verification process and if the commit passes the pipeline, it is deployed to the Production environment.
- Once features are tested and implemented locally, they are merged into the staging branch and deployed to the Staging environment for QA testing.
- After testing is complete, feature branches are merged into the development branch.
- On the release date, the development branch is merged into production and then deployed to the Production environment.

5.1.2. Staging Infrastructure

Once the features are implemented and considered fairly stable, they get merged into the staging branch and then automatically deployed to the Staging environment. This is when QA kicks in: testers go to staging servers and verify that the code works as intended.

The staging environment is automatically deployed on every commit or push if there are any changes made.

5.1.3. Customer Deployment Infrastructure

The AccuKnox DevOps team uses the template image on the appropriate cloud platform and provisions a cloud-hosted AccuKnox SaaS platform on the public cloud provider, which is of interest to the customer. Google Cloud Platform is the supported cloud provider.

5.1.4. Production Infrastructure

Once the feature is implemented and tested, it can be deployed to production. If the feature was implemented in a separate branch, it should be merged into the master branch first. The branches should be deleted periodically when they are merged to avoid confusion between team members.

All major deployment releases to production are at a scheduled time, of which the whole team is aware of. AccuKnox will get the time when the application is least active and use that time to roll out updates. Urgent production fixes are deployed at any time.

5.1.5. Operating Systems

AccuKnox is a Linux-based application developed and maintained by AccuKnox, which is hosted in GCP Cloud. The software development group develops, enhances, and maintains AccuKnox to provide service for the company's customers.

- GCP:
 - Hosted in GCP Cloud as IaaS service with below Instance type and configurations:
 - GKE cluster with COS base operating system
 - All services are containerized and running on GKE
 - The Percona MySQL cluster is deployed and running on GKE
 - A Kafka cluster is running on GKE to provide streaming data
 - Uses Istio for service mesh

Primary software and Operating Systems used to provide AccuKnox services includes the following:

Software	Operating System	Purpose
AccuKnox SaaS (k8s)	COS	Hosting the application
AccuKnox UI	On Bucket	Frontend hosting to Handle User Request
Database(Mysql & Kafka)	COS	Master and Slave Database server

5.2. People

AccuKnox utilizes the following functional areas of operations within the scope of this review:

- **Executive management** - responsible for overseeing company-wide activities, establishing and accomplishing goals, providing strategic planning of operations, and overseeing objectives
- **Engineering** - provides all aspects of technical assistance relating to the AccuKnox service, including development, testing, quality assurance, technical documentation, and security.
- **Sales** - provide sales and sales support to prospective AccuKnox customers.
- **Account Management** - provides post-sales customer support, which provides problem resolution and customer training.
- **Marketing** - responsible for product definition, demand generation, positioning, branding, and creating opportunities for the Sales team.
- **Finance & Administration**—provides financial, administrative (including contract review), and management services, including human resources-related functions and employment administration.
- **Support team** - serves customers by providing product and services information that includes resolving product and service issues
- **IT** - The group provides the internal IT operations including Helpdesk, IT infrastructure, IT networking, IT system administration
- **Information Security** - The Information Security team works to make AccuKnox product a secure and compliant platform by building common security governance, technologies, tools, processes, and best practices. The Information Security team is involved in the review of deployments and enhancements of AccuKnox services to facilitate security considerations at every level of the Secure Development Lifecycle (SDLC). They also perform security reviews.

This team consists of personnel responsible for:

- Secure Development Lifecycle
- Security incident response
- Driving security functionality within service development work

5.3. Process and Procedures

AccuKnox Information Security has developed and communicated to the stakeholders procedures through which service activities are initiated, authorized, performed, and delivered in order to cover the following key security lifecycle areas:

- Data classification (data at rest, in motion, and output)
- Assessment of the business impact resulting from proposed security approaches
- Selection, documentation, and implementation of security controls
- Performance of annual management self-assessments to assess security controls
- Authorization, changes to, and termination of information system access
- Monitoring security controls
- Management of access and roles
- Maintenance and support of the security system and necessary backup and offline storage
- Incident response
- Change Management
- Management Monitoring
- Business Continuity and Disaster Recovery
- Security & Monitoring
- Intrusion Detection

Changes to these procedures are performed annually and authorized by senior management and Information Security.

5.4. Data

Data (also referred to as information asset) is classified, as described in the Data Classification Policy, based on how it is used or may be used within the Service environment and includes the following.

- The principal types and methods of data created, collected, processed, retained, disclosed, disposed of, anonymized, transmitted, used, or stored by AccuKnox
- Personally Identifiable Information (PII) that warrants security, data protection, or breach disclosures based on laws or commitments (for example, personally identifiable information, protected health information, and payment card data)
- Customer and third-party entity information (for example, information subject to confidentiality requirements in contracts) that warrants security, data protection, or breach disclosures based on laws or commitments

AccuKnox does not store or manage customer data. However, customer administrator information and customer entity information are managed, processed, and stored by AccuKnox in accordance with the relevant data protection and other regulations, with specific requirements formally established in customer contracts. Customer data is captured, which is utilized by AccuKnox in delivering its technology solutions. Such data includes, but is not limited to, the following:

- Alert notifications and monitoring reports generated from the commercial monitoring applications
- Alert notifications received from automated backup systems
- Vulnerability or security alerts received from various sources, including security subscriptions, scanning tools, IDS alerts, or automated patching systems
- Incident reports documented via the ticketing systems

6. AccuKnox Related Security Controls

AccuKnox Information Security organization, a dedicated security department, has been established to design, implement, and operate security controls to meet and comply with the trust service criteria and ensure that the system is protected against unauthorized access (both physical and logical).

The following is the description of the AccuKnox security controls in place for compliance with the applicable Trust Service Criteria and Related Controls:

6.1. Security Organization - Information Security Program

AccuKnox has established an Information Security Program that provides documented management direction and support for implementing information security within the AccuKnox environment. The design and implementation of applicable controls are defined based on the type of AccuKnox service and its architecture.

The objective of the Information Security Program is to maintain the Confidentiality, Integrity, and Availability of information while complying with applicable legislative, regulatory, and contractual requirements.

The Information Security Program consists of the following components:

1. Policy, Standards, and Procedures
2. Risk Assessment
3. Security Awareness Training
4. Security Implementation
5. Review and Compliance
6. Management Reporting

The Information Security Program is based on the International Organization of Standards (ISO) Codes of Practice for Information Security Management ISO / IEC 27001:2013 standard. Its accompanying policies and processes provide a framework to assess risks to the AccuKnox environment, develop mitigating strategies, and implement security controls.

Related Security Document:

Sec-101 AccuKnox Information Security Management Plan

6.2. Security Management

AccuKnox has dedicated information security personnel as Chief Information Security Officer (CISO) and security consultants as needed, responsible for the management of information security throughout the organization which holds a position on the Security Steering Committee and maintain security credentials and is required to annually sign and acknowledge the review of the information security policies. He is responsible for developing, maintaining, and enforcing AccuKnox's information security policies. The information security policy is reviewed annually by the security officer, CIO, and vice president of operations, and it is approved by the Security Steering Committee.

As the information security team maintains security, it monitors known incidents and patches as well as results from recent vulnerability assessments and addresses necessary changes to the policies and procedures. Such changes can include a reclassification of data, a reassessment of risk, changes in incident response plans, and a verification of responsibilities for authorizing and monitoring accesses. Changes are reviewed and communicated during weekly IT maintenance meetings or through system alerts.

During annual security training and awareness programs, management ensures communication of the latest security policies as well as written job descriptions for security management.

Additionally, management is responsible for ensuring that business associate agreements are current for third parties and for updating the annual IT risk assessment.

Related Security Document:

Sec-101 · AccuKnox Information Security Management Plan

6.3. AccuKnox Information Security Steering Committee

AccuKnox has established the Information Security Steering Committee that is accountable and reports to AccuKnox Executive Management (*Sec-104 AccuKnox Information Security Steering Committee*). Membership consists of representatives from all departments within AccuKnox. The mission of the AccuKnox Information Security Steering Committee is to communicate changes to policies which guide information privacy, security, and confidentiality programs across the company. Likewise, the Committee serves to approve and enforce specific actions that have a potential impact on information privacy, security, and confidentiality beyond one functional area. In addition, the AccuKnox Information Security Steering Committee serves as the advisory and consultative body for all functions within AccuKnox on information privacy, security, and confidentiality.

This Committee is chaired by the AccuKnox Chief Information Security Officer, who establishes and communicates the agenda and meeting minutes to all participants. Agenda items include, but are not limited to, the following:

- Status of independent third-party audits;
- The status of the AccuKnox Security Awareness Training program;
- Data Protection;
- Vendor Oversight program updates;
- Status of Product Penetration Tests;
- Security hotfix and defect tracking submitted by Engineering; and
- Security incident status.

Related Security Document:

Sec-104 · AccuKnox Information Security Steering Committee Organization Chart & Charter

6.4. Roles and Responsibilities

Information security roles and responsibilities have been defined across the different AccuKnox functions. The Information Security team facilitates the implementation of security controls and provides security guidance to the teams. The Information Security team also coordinates with representatives from Corporate, External, Legal, and Human Resources (personnel security) on additional information security-related activities impacting the services.

Related Security Document:

Sec-101 · AccuKnox Information Security Management Plan

6.5. Information System Review

AccuKnox performs a periodic Information Security Management Program (ISMP) review, and results are reviewed with the management. This activity involves monitoring the ongoing effectiveness and improvement of the ISMP control environment by reviewing security issues, audit results, and monitoring status, and by planning and tracking necessary corrective actions.

Related Security Document:

Sec-101 · AccuKnox Information Security Management Plan

6.6. Compliance Requirements

AccuKnox maintains reasonable and appropriate technical and organizational measures, internal controls, and information security routines intended to help protect customer data against accidental loss, destruction, alteration; unauthorized disclosure or access; or unlawful destruction.

AccuKnox compliance requirements are monitored and reviewed regularly with the Information Security group and Information Security Steering Committee, and other internal organizations, as applicable. Members of the Information Security update relevant SOPs, Security policies, and service descriptions in order to remain in line with compliance requirements.

The Security Policy requires a periodic review of the performance of policies and procedures governing information security. The Information Security team coordinates audits that evaluate systems and the control owners for compliance with security policies, standards, and other requirements. Audit activities are planned and agreed upon in advance by stakeholders, including approval for necessary access required to perform such audits.

Related Security Document:

Sec-220. AccuKnox Regulatory Compliance Policy

6.7. Risk Management

AccuKnox regularly reviews the risks that may threaten the achievement of its service commitments and system requirements related to security based on the applicable trust services criteria set forth in TSP section 100, 2017 Trust Services Principles and Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy (AICPA, Trust Services Criteria).

AccuKnox performs risk assessments to identify, quantify, and prioritize risks against criteria published in the AccuKnox Risk Management Policy. Once the risks are identified and qualified, a formal risk assessment is recorded in AccuKnox's Governance Risk and Compliance (GRC) solution as the central repository for risk information. Each risk is then mitigated to an acceptable level. Risks may be accepted, for example, if the cost of mitigation controls exceeds the actual costs of mitigation, which may not be deemed as cost-effective for the organization.

AccuKnox Risk Management Policy (*Sec-105 Information Security Risk Management Policy, Standard, and Process*) defines risk management methodologies, activities, and organizational requirements to achieve the policy objectives. AccuKnox's risk management model comprises six process steps:

- Risk Planning
- Risk Identification
- Risk Analysis
- Risk Response
- Risk Monitoring

Changes in security threats and risks are reviewed by AccuKnox Information Security and Security Steering Committee, and updates to existing control activities and information security policies are performed as necessary.

Security risks related to external parties (such as customers, contractors, and vendors) are identified and addressed within the AccuKnox environment based on AccuKnox's corporate procurement process. Designated responsibilities are defined to coordinate with relevant corporate groups (e.g., Procurement) in reviewing risks associated with external parties and establishing relevant agreements.

Related Security Document:

Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process

6.8. Security Awareness Training

Information security awareness training is provided to AccuKnox employees and contractors on an ongoing basis to educate them on applicable policies, standards, and information security practices. Awareness training on security, availability, and confidentiality of information is provided to employees at the time of joining as part of induction. In addition, all staff participates in mandatory security, compliance, and privacy training periodically in order to design, build, and operate secure cloud services.

Employees receive information security training and awareness through different programs such as new employee orientation, computer-based training, and periodic communication (e.g., compliance program updates). These include training and awareness pertaining to the platform in the security, availability, confidentiality, and integrity domains. In addition, job-specific training is provided to personnel, where appropriate. The key objectives of the information security training and awareness program are listed below:

- **Objective 1:** The learner will be able to articulate the need to protect the confidentiality, integrity, and availability of the production environment.
- **Objective 2:** The learner will be able to apply basic security practices to safeguard the production environment and customer information.
- **Objective 3:** The learner will understand the criticality of security, compliance, and privacy in relation to customer expectations.
- **Objective 4:** The learner will have a basic understanding of the responsibility to meet compliance and privacy commitments.
- **Objective 5:** The learner will know where to find additional information on security, privacy, business continuity/disaster recovery, and compliance.

All Engineering staff are required to complete a computer-based training module when they join the team. Staff is required to retake this training at least once per fiscal year.

In addition, the annual Standards of Code of Conduct (SCC) training is mandatory for all AccuKnox employees. The SCC training includes an anti-corruption section that focuses on AccuKnox's anti-corruption policies and highlights policies that reinforce the need for employees to work with integrity and to comply with the anti-corruption laws of the countries in which AccuKnox operates. All active employees are required to complete this course.

Related Security Document:

Sec-203. AccuKnox Information Security Awareness Training Policy

6.9. Security Policy, Standards, and Processes

AccuKnox Security Governance documents (Policies, Standards, and Processes) outline the objectives related to information security, define risk management requirements, and information security roles and responsibilities. The Security documents contain rules and requirements that are met by AccuKnox staff in the delivery and operations of the product and services. The Security documents are derived from the ISO 27001:2013 standard and are augmented to address relevant regulatory and industry requirements for the AccuKnox Services environment.

The security documents are reviewed and updated, as necessary, at least annually, or more frequently, in case of a significant security event or upon significant changes to the service or business model, legal requirements, organization, or platform.

Each management-endorsed version of the security document and all subsequent updates are distributed to all relevant stakeholders from the AccuKnox intranet site.

Security policies are formally documented and communicated to AccuKnox employees via the corporate Intranet. Instances of employee non-compliance with the security policy are escalated to the HR department and the Information Security Steering Committee.

The following security policies and related standards and processes are in place for AccuKnox:

Security-100 Information Security Program Management	
Sec-101	· AccuKnox Information Security Management Plan
Sec-102	· AccuKnox Information Security Document Management (Policy, Standards, Process, Artifacts)
Sec-103	· AccuKnox Security Risk Exception Policy & Process
Sec-104	· AccuKnox Information Security Steering Committee Organization Chart & Charter
Sec-105	· AccuKnox Security Risk Assessment/Management Policy & Process
Sec-106	· AccuKnox Third Party / Vendor Security and Risk Management Policy & Process
Security-110 Asset Management (Information, SW, HW)	
Sec-110	· AccuKnox Asset Management Policy & Process
Sec-111	· AccuKnox Information Classification and Handling Policy
Sec-113	· AccuKnox Media Handling and Security Policy
Sec-114	· AccuKnox Data Disposal and Sanitization Policy
Sec-115	· AccuKnox Data Retention Policy
Security-120 Identification & Authentication Management	
Sec-120	· AccuKnox Identification and Authentication Management Policy & Process
Sec-120	· AccuKnox Account Management Process
Sec-122	· AccuKnox Password Management Policy
Security-130 Access & Authorization Management	
Sec-130	· AccuKnox Access Control Policy and Process
Sec-130	· AccuKnox Application Access Control Policy & Process
Sec-130	· AccuKnox Remote Access Policy
Sec-130	· AccuKnox Access Review Policy & Process
Sec-130	· AccuKnox 3rd Party Access Control Policy
Security-150 Network & Communications Security Management	
Sec-150	· AccuKnox Network Security Policy
Sec-151	· AccuKnox Network Segmentation Policy
Sec-153	· AccuKnox Firewall Management Policy
Sec-154	· AccuKnox Wireless Security
Sec-155	· AccuKnox Mobile Device Policy
Sec-156	· AccuKnox Secure Email Policy and Process

Security-160 Operational Security Management	
Sec-160	. AccuKnox System Security Assurance and Hardening Policy
Sec-162	. AccuKnox Security Information and Events Monitoring Policy
Sec-165	. AccuKnox Data Backup Policy & Process
Sec-166	. AccuKnox Change Management Policy & Process
Sec-167	. AccuKnox Security Log & Event Management Policy
Sec-168	. AccuKnox Vulnerability Management Policy
Sec-169	. AccuKnox Patch Management Policy & Process
Security-170 Application Security Management	
Sec-170	. AccuKnox Application Security Policy
Sec-171	. AccuKnox Encryption & Key Management Standard
Sec-172	. AccuKnox Secure Software Development Life Cycle SDLC
Sec-177	. AccuKnox Application Security Standard
Security-180 Physical & Environmental Security Management	
Sec-180	. AccuKnox Physical Security Policy
Security-190 Information Security Incident Management	
Sec-190	. AccuKnox Incident Response Policy and Process
Sec-191	. AccuKnox Incident Response Plan
Security-200 Human Resources Security Management	
Sec-200	. AccuKnox Acceptable Use Policy
Sec-200	. AccuKnox Clear Desk & Clear Screen Policy
Sec-200	. AccuKnox Social Networking / Media Policy
Sec-201	. AccuKnox Human Resources Security Management Policy
Sec-201	. AccuKnox Employee & Contractor Onboarding, Change and Termination Policy & Process
Sec-201	. AccuKnox Background Screening Policy & Standard
Sec-201	. AccuKnox Disciplinary Policy
Sec-203	. AccuKnox Security Awareness Training & Education Policy
Sec-204	. AccuKnox Teleworking Policy
Sec-207	. AccuKnox Access Badge Assignment Procedure
Security-210 Business Continuity Management	
Sec-210	. AccuKnox Business Contingency Policy
Sec-211	. AccuKnox Business Continuity and Disaster Recovery Policy
Sec-212	. AccuKnox Business Continuity Plan
Security-220 Compliance Management	
Sec-220	. AccuKnox Regulatory Compliance Policy
Sec-221	. AccuKnox Internal Audit Policy & Process

6.10. Human Resources Policies and Practices

AccuKnox has established formal human resources policies, practices related to employee hiring, orientation, training, evaluation, counseling, promotion, compensation, and disciplinary activities.

Specific control activities that AccuKnox has implemented in this area are described below:

- New employee hiring procedures, including the use of new hire checklists, are in place to guide the hiring process and include verification that candidates possess the required qualifications to perform the duties as outlined in the job description.
- Evaluations are performed for each employee on an annual basis.
- Employees are required to complete security awareness training on an annual basis to understand their obligations and responsibilities to comply with the corporate and business unit security policies.
- Documented policies and procedures are in place that addresses remedial actions for lack of compliance with policies and procedures.
- A termination checklist is completed as a component of the employee termination process.
- The following mandatory documents must be acknowledged and signed by the selected candidates: “Code of Business Conduct” or “Acceptable Use Policy” (Sec-200 AccuKnox Acceptable Use Policy) explaining AccuKnox's policies and a non-disclosure agreement (NDA) prohibiting any disclosure of information which is classified as internal, confidential, or strictly confidential. Access to AccuKnox systems, protected areas, etc., is not granted unless the NDA has been signed by the employee.
- Formal organizational charts and detailed reporting structures for each functional group within AccuKnox are defined, maintained on a regular basis, and can be accessed by all employees via AccuKnox Portal.
- Notice of instances of non-compliance with AccuKnox Security Policy is issued to the employee by an employee’s manager (or member of the management team) with a Human Resources representative present. Depending on the sensitivity of the issue, an investigation is initiated, and disciplinary sanctions are agreed upon (e.g., verbal warning, written warning, suspension, termination).

Related Security Document:

Sec-201. AccuKnox Human Resources Security Management Policy

6.11. Personnel

AccuKnox performs employee background screening as determined by the hiring manager based on access to sensitive data, including access to personally identifiable information or to back-end computing assets and per customer requirements, as applicable. AccuKnox also employs a formal performance review process to ensure employees adequately meet the responsibilities of their position, including adherence to company policies, information security policies, and workplace rules. Hiring managers may, at their discretion, initiate corrective actions, including termination, if any aspect of an employee's performance and conduct is not satisfactory.

AccuKnox Information Security works with AccuKnox Human Resources and vendor companies to perform the required background check on each new or transferred personnel before they are granted access to AccuKnox Services production assets containing customer data.

Corporate policies are communicated to employees and relevant external parties during the onboarding process and as part of the annual security training and awareness education program. Non-disclosure Agreements (NDAs) are signed by employees and relevant external parties upon engagement with AccuKnox. Disciplinary actions are defined for persons who violate AccuKnox's Security Policy or commit a security breach. Employees are also required to comply with relevant laws, regulations, and provisions regarding information security remain valid if the area of responsibility changes or the employment relationship is terminated. Security Policy and non-disclosure requirements are reviewed periodically to validate the appropriate protection of information.

Related Security Document:

Sec-201. AccuKnox Human Resources Security Management Policy

6.12. System and User Account Management

AccuKnox has implemented role-based security to limit and control access within the IAM. Employees are granted logical and physical access to in-scope systems based on documented approvals by appropriate management personnel.

AccuKnox uses a specific corporate Identification and Access Management (IAM) system for centralized authentication and authorization to restrict access to the systems and services within the AccuKnox environment. Each user account is unique and is identifiable to an individual user.

Domain-account management requests are routed to the designated asset owner according to established account provisioning and de-provisioning processes for approval. Typically, access is controlled through the addition of individual user accounts to established domain security groups within the IAM. Based on the configuration of a security group, any access request may either require an explicit approval from the assigned security group owner or maybe auto approved for members of designated teams within AccuKnox's organizational structure. Requests requiring explicit approval are automatically forwarded to the security group owner for approval in the system.

Employee status data from AccuKnox HR is used to facilitate the provisioning and removal of user accounts in AccuKnox-managed IAM domains. Automated feeds from AccuKnox HR systems provide this information, and account management processes prevent the creation of an account for individuals that do not have valid HR records. These feeds also initiate the removal of the user accounts for terminated users from the IAM.

Automated mechanisms have been implemented to manage the appropriateness of access granted to information systems. Manual periodic reviews of individual accounts and security group memberships on assets are performed by authorized individuals, as appropriate, to evaluate whether access is still required. Remediation action is taken, as necessary, based on the review.

The human resources department provides IT personnel with an employee termination report. IT reconciles the termination report with current access privileges to determine if access has been appropriately removed or disabled. Dormant accounts are disabled after 45 days of inactivity.

Administrative access to IAM, Unix, servers, and databases is restricted to authorized employees.

Unique user credentials are required to authenticate all users to the systems, as well as to the facility services.

Related Security Document:

Sec-120. AccuKnox Account Management Process

Deactivation of Accounts

AccuKnox's Identity Management is periodically reviewed by AccuKnox Security to identify user accounts of terminated employees. Jira tickets are created to deactivate accounts that are found in Google Identity Management with no corresponding user.

AccuKnox has also developed a policy and implemented a process for account deactivation with employee termination or role changes.

Related Security Document:

Sec-201 AccuKnox Human Resources Policy

6.13. Access Control

The Security Policy establishes the access control requirements for requesting and provisioning user access for accounts and services. The policy requires that access be denied by default, follow the least privilege principle, and be granted only upon business need.

a) Access to AccuKnox Infrastructure

Access to AccuKnox components in the production environment is controlled through a designated set of access points and restricted to the corresponding service Production Support and Engineering teams. Users are authenticated to access points using AccuKnox IAM and MFA or domain credentials, depending on where the production assets are located.

Passwords used to access AccuKnox network devices are restricted to authorized individuals and system processes based on job responsibilities and are changed on a periodic basis.

Production assets that are not domain-joined or require local user accounts for authentication require unique identifiers tied to an individual user that require appropriate approvals prior to being granted access. Non-domain-joined user accounts that are not required due to termination of user or change in user's role and responsibilities are removed manually within a stipulated period of termination/role change. In addition, access through persistent local accounts on servers is not considered within user access review as they are configured to raise security alerts upon creation and are created on isolated VMs, which tend to have a short life span.

b) Access to the Customer's Production Infrastructure

Viewer and system administration-level access to the customer production servers is restricted to AccuKnox agents. The installed AccuKnox agents will have access to create/modify resources if approved by the customer admin team.

Below are the scenarios for accessing customer pieces of information:

- Admin installs the AccuKnox agents with viewer/admin privileges
- AccuKnox agents collect pieces of information like the number of pods, nodes, and containers and send it back to the AccuKnox control plane via an encrypted channel

c) Access to Customer Systems by AccuKnox Personnel

By default, user accounts are not created, and the default administrator account is disabled on customer systems. However, access to the customer systems may be required for exceptional situations, such as troubleshooting issues and handling incidents. To resolve these types of issues, temporary access procedures have been established to provide temporary access for AccuKnox personnel (DevSecOps) to customer data and applications with the appropriate approvals. These temporary access events (i.e., request, approval, and revocation of access) are logged and tracked using an internal ticketing system per documented procedures.

AccuKnox does not have access to the customer data except via a collaboration session through the customer's admin.

.

Related Security Document:

Sec-130. AccuKnox Access Control Policy and Process

6.14. Asset Management

Data Classification and Confidentiality Policy

AccuKnox assets are classified in accordance with AccuKnox Data Classification guidelines. The classification process is owned by the AccuKnox Information Security team. There are four categories for classification based on their impact on the business: Secret, Confidential, Internal Use, and Public. Steps are taken to protect assets commensurate with the respective asset's classification and its data sovereignty. A review of asset inventory, ownership, and classification is performed at least semi-annually.

AccuKnox inventory of cloud-based resources is monitored and maintained by the AccuKnox Security team. On a quarterly basis, the AccuKnox Security team checks for completeness and accuracy of the inventory to ensure that it appropriately represents the AccuKnox production environment.

AccuKnox has created and implemented processes to control the delivery and removal of information assets through a centralized ticketing system.

Related Security Document:

Sec-110. AccuKnox Asset Management Policy & Process

Sec-111. AccuKnox Information Classification and Handling Policy

6.15. Data Encryption (Cryptographic Controls)

Data at rest and in transit are secured using data encryption.

Cryptographic controls and approved algorithms are used for information protection within the AccuKnox platform and implemented based on AccuKnox Cryptographic Policy and AccuKnox Cryptographic Standards. Cryptographic keys are managed throughout their lifecycle (e.g., ownership, generation, storage, distribution, periodic rotation, and revocation) in accordance with established key management procedures.

Encryption for data at Rest. Sensitive data elements, including customer information, are stored in AccuKnox databases encrypted by 256-bit AES (Advanced Encryption Standard). Additional specified data elements are encrypted upon customer selection using 256-bit AES (Advanced Encryption Standard).

Encryption for data in Transit. HTTPS (HTTP over TLS) is based on a minimum of 128-bit encryption and is used for secure communications between web browsers and web servers.

Related Security Document:

Sec-171. AccuKnox Encryption and Key Management Standard.

6.16. Data Segregation

Directory Services assigns each tenant a unique identifier as part of the IAM. The mapping between the customer and the IAM location is represented within the partition table and is hidden from each customer. Each customer is segregated and partitioned within IAM based on this unique identifier to ensure appropriate customer data segregation.

Related Security Document:

Sec-151. AccuKnox Network Segmentation Policy

6.17. Customer Data Deletion

Customer data is retained in the AccuKnox system in a limited function account for 90 days after expiration or termination of the customer's subscription so that the customer may extract the data. After the 90 day retention period ends, the customer's account is disabled, and the customer's data is deleted. In accordance with applicable retention policies and legal/regulatory requirements as described in the Customer Registration section of the subscription, customer data is securely disposed of upon customer instruction. Customer accounts in non-payment or violation of terms, etc., are subject to involuntary terminations and account disablement.

Related Security Document:

Sec-114. AccuKnox Data Disposal and Sanitization Policy

6.18. Data Backup

Processes have been implemented for the backup of critical AccuKnox components and data. Backups are managed by the AccuKnox team and scheduled on a regular frequency established by the respective component teams. The team monitors backup processes for failures and resolves them per documented procedures to meet required backup frequency and retention. AccuKnox team that supports the services and the backup process conducts integrity checks through standard restoration activities. Further, production data is encrypted on backup media.

AccuKnox source code, configuration, and internal data are stored on GitHub. Customers or AccuKnox CloudOps can create Snapshots periodically and restore from them if desired.

Related Security Document:

Sec-165. AccuKnox Data Backup Policy & Process

6.19. Data Redundancy and Replication

AccuKnox uses MySQL databases with Multi-AZ and secure login.

In a Multi-AZ deployment, the DR strategy automatically provisions and maintains a synchronous standby replica in a different Availability Zone. In case of any failure outage of the DB instance, it automatically switches to a standby replica in another Availability Zone if clients have enabled Multi-AZ.

Updates made to the source DB instance are asynchronously copied to the Read Replica. Clients can reduce the load on their source DB instances by routing read queries from their applications to the Read Replica. Using Read Replicas, they can elastically scale out beyond the capacity constraints of a single DB Instance for read-heavy database workloads.

6.20. Separation of Environments

AccuKnox has implemented segregated environments for development, testing, and production as a means to support the segregation of duties and prevent unauthorized changes to production. AccuKnox maintains logical and physical separation between the DEV (development), STAGE (pre-production), and PROD (production) environments.

Virtual services run on different clusters in separate network segments. STAGE and PROD environments reside in separate network segments. Access to STAGE and PROD is restricted to authorized personnel from the service Operations and Production Support teams.

Deployment of software to production must meet testing and operational readiness criteria at each pre-production and production stage and be approved prior to release. Production deployments use approved software builds and images.

In addition, production data is not used or copied to non-production environments. Test scripts and synthetic data are created for use in the development and stage environments.

6.21. Segregation of Duties

Segregation of duties is established on critical functions within the AccuKnox environment to minimize the risk of unauthorized changes to production systems. Responsibilities for requesting, approving, and implementing changes to the AccuKnox environment are segregated among designated teams.

Related Security Document:

Sec-130. AccuKnox Access Control Policy and Process

6.22. Change Management

The formalized Change Management process has been established to plan, schedule, approve, apply, distribute, and track changes to the production environment through designated responsibilities with the objective of minimizing risk and customer impact. It further controls the integrity and reliability of the environment while maintaining the pace of change required for business purposes.

Proposed changes are evaluated to determine if they present a security risk and what mitigating actions, including employee and user entity notifications, must be performed. The IT management team meets weekly to review and schedule changes to the IT environment.

Emergency changes follow the formalized change management process but at an accelerated timeline. Prior to initiating an emergency change, necessary approvals are obtained and documented.

Changes to infrastructure and software are developed and tested in a separate development or test environment before implementation. Additionally, developers do not have the ability to migrate changes into production environments.

Related Security Document:

Sec-166. AccuKnox Change Management Policy & Process

6.23. Software and Configuration Changes

Software and configuration changes within AccuKnox, including major releases, minor releases, and hotfixes, are managed through a formal change and release management procedure and tracked using a centralized ticketing system. Changes are requested, approved, tracked, and implemented throughout the release lifecycle, which includes product and engineering planning, release management, deployment, and post-deployment support phases. Change requests are documented, assessed for their risks, and evaluated/approved for acceptance by the designated AccuKnox personnel. Software releases are discussed, planned, and approved through daily coordinated meetings with appropriate representatives from the service and component teams.

Changes that are made to the source code are controlled through an internal source code repository. Refer to the Secure Development section for the controls enforced on the source code.

Formal security and quality assurance testing are performed prior to the software release through each pre-production environment (i.e., development and stage) based on defined acceptance criteria. The results of the quality assurance testing are reviewed and approved by the appropriate representatives prior to moving the release to production. Changes are reviewed for their adherence to established change and release management procedures prior to closure. Once deployed, changes are monitored for success; failed implementations are immediately rolled back, and the change is not considered as completed until it is implemented and validated to operate as intended.

Related Security Document:

Sec-166. AccuKnox Change Management Policy & Process

6.24. Hardware Changes/Built-out

Hardware changes are managed through formal change and release management procedures and a centralized ticketing system. Hardware changes are evaluated against the release entrance criteria that are established by the AccuKnox IT team, which forms the acceptance criteria for the build-out of hardware within the AccuKnox environment. Similar to software changes, the infrastructure changes are discussed and planned through daily coordinated meetings with representatives from service and component teams.

The AccuKnox team coordinates the scheduling of the release and deployment of the change into the production environment. The AccuKnox IT team performs the build-out of hardware devices and post-build-out validation in coordination with the AccuKnox IT team to verify its adherence to the hardware build requirements for new clusters. AccuKnox Operations Managers perform a final review and sign-off of new deployments, and the AccuKnox IT team closes the ticket.

Related Security Document:

Sec-166. AccuKnox Change Management Policy & Process

6.25. Network Changes

AccuKnox IT teams have implemented a formal change management process and a centralized ticketing tool to document network changes and their approvals. Network changes include configuration changes, emergency changes, Access Control Lists (ACLs) changes, patches, and new deployments.

ACL changes that are identified and categorized as standard changes are considered pre-approved and may be implemented on peer review. Non-standard changes are reviewed for their characteristics and risks and approved by representatives from the Security and Networking teams during the daily coordinated meeting. Reviews and approvals are also tracked in a centralized ticketing system. Changes are performed through approved change implementers that are part of a designated security group. Post-implementation reviews are performed by qualified individuals other than the implementer who evaluate the change success criteria.

Related Security Document:

Sec-166. AccuKnox Change Management Policy & Process

6.26. Vulnerability Management

The Information Security team carries out frequent internal and external scans to identify vulnerabilities and assess the effectiveness of the patch management process. Services are scanned for known vulnerabilities; new services are added to the next timed quarterly scan, based on their date of inclusion, and follow a quarterly scanning schedule thereafter. These scans are used to ensure compliance with baseline configuration templates, validate that relevant patches are installed, and identify vulnerabilities. The scanning reports are reviewed by appropriate personnel, and remediation activities for identified vulnerabilities are triggered in a timely manner following a risk-based approach.

Related Security Document:

Sec-168. AccuKnox Vulnerability Management Policy

6.27. Patch Management

Updates are identified through regular internal and external security vulnerability scans (*Sec-168 AccuKnox Vulnerability Policy*) as well as internal notification alerts recognized by AccuKnox Security teams.

External notifications (e.g., Ubuntu Security Notices (USN) for Linux patches) or the regularly scheduled system scans identify any required patches to the infrastructure or platform. The IT team evaluates patch releases and determines applicability and impact on AccuKnox services environment and customers. The applicable security patches are applied during a scheduled release to the AccuKnox environment based on the severity of the vulnerability.

Processes are in place to evaluate patches and their applicability to the AccuKnox environment. Once patches have been reviewed and their criticality level determined, the service team determines the release cadence for implementing patches without service disruption. (*Sec-169 AccuKnox Patch Management Policy and Process*)

Applicable patches are automatically applied to Guest PaaS VMs unless the customer has configured the VM for manual upgrades. In this case, the customer is responsible for applying patches.

Teams follow a change process to modify the underlying OS within the platform. All changes are reviewed and tested, at a minimum, for their quality, performance, impact on other systems, recovery objectives, and security features before they are moved into production using a defined release process. Test windows have been established for reviewing and testing new features and changes to existing features and patches.

Patches are released through the periodic OS release cycle in accordance with change and release management procedures. Emergency out-of-band security patches (e.g., Software Security Incident Response Process patches) are expedited for more immediate release.

Related Security Document:

Sec-169. AccuKnox Patch Management Policy & Process

6.28. Logging and Monitoring

The security administration team uses a variety of security utilities to monitor, identify, and detect possible security threats and incidents. These utilities include but are not limited to firewall notifications, intrusion detection system (IDS) or intrusion prevention system (IPS) alerts, vulnerability assessment reports, and operating system event logs. These alerts and notifications are reviewed daily by the security administration team using a security incident and event monitoring (SIEM) product. Additionally, the security administration team has developed and will review the following SIEM reports:

- Failed object-level access
- Daily IDS or IPS attacks
- Critical IDS or IPS alerts
- Devices not reporting in the past 24 hours
- Failed login detail
- Firewall configuration changes
- Windows policy changes
- Windows system shutdowns and restarts
- The issue is tracked with the ELK Stack.
- Daily Attack is reported from the Cyberoam.
- Critical ISP down alerts are configured and reported from Cyberoam.
- Security group changes alert notifications are reported from CloudWatch.
- Logging to the console without MFA
- Disabling the credentials unused for 90 days or greater

Security events requiring further investigation are tracked using a help desk ticket and monitored until resolved. AccuKnox has established an Audit Log Management policy, which restricts the log and monitors access to only authorized staff with a business need to access such systems.

Related Security Document:

Sec-169. AccuKnox Patch Management Policy & Process

6.29. System Monitoring

- The Monitoring tool within the AccuKnox platform provides automated centralized logging and alerting capabilities for monitoring system use and detection of potentially unauthorized activity. The Monitoring tool capabilities include Data Collection, Data Aggregation, Data Analysis, and Information Access.
- The Alert and Incident Management System provides alerts on a real-time basis by automatically generating emails and incident tickets based on the log information captured.
- AccuKnox Security Monitoring provides logging and alerting capabilities upon detection of breaches or attempts to breach AccuKnox platform trust boundaries. Critical security event logs generated are configured to alert. AccuKnox monitors key security parameters to identify potentially malicious activity on AccuKnox nodes.
- AccuKnox Endpoint Protection (EP) guards against malware and helps improve the security of the AccuKnox SaaS Guest customers, AccuKnox infrastructure tenants, and AccuKnox internal applications. EP can be configured to enable antimalware protection for the AccuKnox infrastructure customer and AccuKnox PaaS Guest VMs. AccuKnox's antimalware endpoint solutions are designed to run quietly in the background without requiring human intervention. If malware is detected, the endpoint protection agent automatically takes action to remove the detected threat.
- AccuKnox is using Nagios core as system monitoring, which will monitor the CPU memory and disk usage of all the hosts
- CloudWatch alarms are configured to monitor the critical resources, including the RDS, Load Balancer, and other systems.

- As incident management, AccuKnox is using OPSGENIE, which will call the on-call resource immediately when the issue happens in the system.
- An external service called Uptime Robot is also used to raise alerts whenever the host/application is experiencing availability issues.

Related Security Document:

Sec-167. AccuKnox Security Log & Event Management Policy

6.30. Network Monitoring

For monitoring the Network for the instances, AccuKnox leverages several tools like Istio, Kiali, and Uptime Robot that have been integrated with the servers. The tools continuously monitor the servers and send notifications if any abnormalities are found.

Related Security Document:

Sec-150. AccuKnox Network Security Policy

6.31. Securing Edge Sites

All drives that are used for edge production servers are encrypted, including the operating system. The drives have Always-On encryption and stay encrypted even during OS patching and updates. In addition, all unused IO ports on edge production servers are disabled by OS-level configuration that is defined in the baseline security configuration. Continuous configuration validation checks are enabled to detect drift in the OS-level configurations.

Related Security Document:

Sec-160. AccuKnox System Security Assurance and Hardening Policy

6.32. Incident Management

AccuKnox has implemented an incident management framework that includes defined processes, roles, communications, responsibilities, and procedures for detection, escalation, and response to incidents internally and to customers. All AccuKnox employees, contractors, and third-party users of information systems and services are required to report any observed or suspected security weaknesses in systems or services, i.e., security events.

Related Security Document:

Sec-190. AccuKnox Incident Response Policy and Process

Sec-191. AccuKnox Incident Response Plan

6.32.1. Security Incident - Internal Monitoring and Communication

AccuKnox has established incident response procedures and centralized tracking tools, which consist of different channels for reporting production system incidents and weaknesses. Automated mechanisms include system monitoring processes for alerting AccuKnox service On-Call IT teams per defined and configured event, threshold, or metric triggers.

Additionally, Information Security conducts yearly tests of the Incident Management SOPs and response capabilities. Reports related to information security events are provided to AccuKnox management on a regular basis. Problem statements for systemic issues are submitted to the Information Security Steering Committee for an executive leadership review.

Related Security Document:

Sec-190. AccuKnox Incident Response Policy and Process

Sec-191. AccuKnox Incident Response Plan

6.32.2. Incident Handling

AccuKnox teams use the established incident classification, escalation, and notification process for assessing an incident's criticality and severity and accordingly escalating to the appropriate groups for timely action. AccuKnox Information Security team, with assistance from the AccuKnox IT team, documents, tracks, and coordinates response to incidents. Where required, security incidents are escalated to the legal or executive management team following established forensic procedures to support potential legal action after an information security incident.

Related Security Document:

Sec-190. AccuKnox Incident Response Policy and Process

Sec-191. AccuKnox Incident Response Plan

6.32.3. Incident Post-Mortem

Post-mortem activities are conducted for customer-impacting incidents or incidents with high severity ratings (i.e., levels 0 and 1). The post-mortems are reviewed by the AccuKnox Information Security Management team during weekly and monthly review meetings with AccuKnox senior management. Incident and security post-mortem trends are reviewed and evaluated on a periodic basis, and, where necessary, the AccuKnox platform or security program may be updated to incorporate improvements identified as a result of incidents.

Related Security Document:

Sec-190. AccuKnox Incident Response Policy and Process

Sec-191. AccuKnox Incident Response Plan

6.33. Business Continuity / Disaster Recovery

AccuKnox Business Continuance Planning is the ongoing process of planning, developing, implementing, and testing processes and procedures to ensure the efficient and effective resumption of the most critical functions of AccuKnox in the event of a disaster.

Primary AccuKnox service is hosted in GCP and built on technology infrastructure that is designed to be fault-tolerant and redundant.

The technology infrastructure is composed of a highly redundant configuration of firewall, router, and load balancer appliances. It is also equipped with multiple instances of applications, files, and database servers, all configured in a fault-tolerant fashion.

Related Security Document:

Sec-211. AccuKnox Business Continuity and Disaster Recovery Policy

Sec-212. AccuKnox Business Continuity Plan

6.34. Network Problem Management

The Networking team comprises Problem Management, Network Escalations, and Network Security teams to identify and address security alerts and incidents. The Networking team is responsible for identifying and analyzing potential problems and issues in the AccuKnox Online Services networking environment.

Related Security Document:

Sec-150. AccuKnox Network Security Policy

6.35. Physical and Environmental Security

AccuKnox systems are hosted in the cloud by a third-party vendor, Google Cloud Services, and Google. Physical security is provided and maintained by the hosting company (data center, backup, storage, as well as sensitive system components within the facility). AccuKnox office security is provided by building security and office locks.

Related Security Document:

Sec-180. AccuKnox Physical Security Policy

6.35.1. Facility and Environmental Security

The backup power supply is provided in the data centers by the cloud service providers in case of primary power failure. The backup power generators are maintained on a regular basis to ensure the correct functionality. Proof of their maintenance is documented in a report provided by the cloud service providers.

In order to protect the data centers against damage from fire, they are equipped with appropriate fire emergency systems, including smoke and heat sensors, as well as fire extinguishers. The fire emergency systems are tested and maintained on a regular basis to ensure their proper functionality. Proof of their maintenance is documented in a report provided by the cloud service providers.

The climate control of the data centers is constantly monitored and controlled via redundant air conditioning systems operating within a predefined temperature scale. The air conditioning systems are tested and maintained on a regular basis, which is documented by cloud service providers.

Related Security Document:

Sec-180. AccuKnox Physical Security Policy

6.35.2. Surveillance

Data centers are equipped with motion detectors, and the area surrounding the data center is monitored by surveillance cameras. Unauthorized access to this area is monitored by motion sensors, which the on-duty security guard enables at night and on weekends. All movements trigger an alarm that is monitored by the on-duty security staff. Motion sensors are maintained on a regular basis. Maintenance is documented by the cloud service providers' reports.

The surrounding areas of the data center and facility buildings are monitored by security guards on a 24x7x365 basis using surveillance cameras. Surveillance cameras are maintained on a regular basis. Maintenance is documented by the cloud service providers' reports.

Related Security Document:

Sec-180. AccuKnox Physical Security Policy

6.36. Communications

6.36.1. Internal Communication

AccuKnox maintains communication with employees using corporate intranet sites, email, training, etc. The communications include but are not limited to communication of AccuKnox policies and procedures, corporate events, new initiatives, and awareness of the Information Security Management Plan. Changes and updates to AccuKnox policies and procedures and all subsequent updates are distributed to all relevant stakeholders from the AccuKnox Security intranet site.

Related Security Document:

Sec-200. AccuKnox Acceptable Use Policy

6.36.2. Service Level Agreements

AccuKnox details commitments made regarding the delivery or performance of services. These details are published in the Service Level Agreements (SLAs) available for each in-scope service.

6.36.3. Customer Communication

Communication between key AccuKnox components where customer data is transmitted and involved is secured using SSL. SSL certificates are self-signed, except for those certificates that are used for connections from outside the AccuKnox network.

Prior to provisioning AccuKnox services, customers are required to review and agree with the acceptable use of data and AccuKnox service, as well as security and privacy requirements, which are defined in AccuKnox Services Terms, AccuKnox Subscription Agreement, AccuKnox Platform Privacy Statement, and Technical Overview of the Security Features in AccuKnox Platform.

Subsequent communication with customers is primarily achieved through the following options:

- 1. Service Dashboard**

AccuKnox maintains and notifies customers of potential changes and events that may impact the security, availability, or confidentiality of the services through an online Service Dashboard. The online Service Dashboard is updated in real-time.

- 2. Legal**

Any changes/updates to the Service Agreement, Terms, End User License Agreement (EULA), Acceptable Use Policy (AUP), Privacy Statement, or SLAs are posted on the AccuKnox website. The information presented in AccuKnox Trust Center is current as of the “last updated” date at the top of each section but is subject to change without notice. Customers are encouraged to review AccuKnox Trust Center periodically to be informed of new security, privacy, and compliance developments.

- 3. Contact Information**

Customers can communicate with AccuKnox support in various ways. The contact section presents forum access and direct contact for support.

- 4. Customer Secrets**

Customer secrets, including certificates, private keys, and RDP passwords, are communicated via the Representational State Transfer (REST) protocol or AccuKnox Portal over a secured channel using SSL. Customer secrets are stored in an encrypted form in the AccuKnox system. Further, private root keys belonging to AccuKnox services are protected from unauthorized access.

Related Security Document:

Sec-201. AccuKnox Employee & Contractor Onboarding, Change and Termination Policy & Process

6.37. Systems Security

This section describes the end-to-end security architecture model for AccuKnox solutions. AccuKnox Operations has standardized operating system installations based on a predefined security policy (*Sec-160 AccuKnox system Security Assurance Policy*). Servers are configured with just the applications and services required to run the server as designed. Services not required are disabled, and binary files not required for operation are removed, which reduces the total number of vulnerabilities a system may have.

AccuKnox Operations standardized installation process also ensures that servers of the same type are configured in the same manner, utilizing a process that initiates an upgrade to system binaries across all systems. Based on the system type, the configuration will remain the same. If one server type needs to receive a patch for a vulnerable binary file, that patch is pushed to all systems of that particular server type. If that

binary exists on all systems, it is patched across all systems. Patches are then included in the build process so that future systems built comply with security standards (*Sec-169 AccuKnox Patch Management Policy and Process*). AccuKnox uses this configuration process to “harden” the operating system prior to implementing additional controls, as detailed below.

Servers. Authentication using a unique login/password pair is required when AccuKnox users attempt to access corporate profile information, initiate a transaction, or retrieve information saved from a previous session. HTTPS (HTTP over TLS) is based on a minimum of 128-bit encryption and is used for secure communications between web browsers and servers.

Monitoring Servers. AccuKnox uses Nagios to monitor the availability of AccuKnox Deception Center (ADC) services, and alerts are sent to Slack and Email.

Routers. As a SaaS provider, all routings are provided by cloud service providers.

Firewalls. Firewalls separate the AccuKnox corporate network from AccuKnox development systems. Therefore, unauthorized users cannot access AccuKnox data from AccuKnox corporate network infrastructure. Access is limited to specific roles or functions within AccuKnox Operations. Additionally, access is managed on an “exception” basis whereby personnel needs clearance to be authorized as external connections. Access is time-limited, after which re-authentication is required. (*Sec-130 AccuKnox Access Control Policy and Processes*)

Intrusion Detection System. AccuKnox uses network and host-based intrusion detection. This technology provides logging and alert capabilities to assist in the detection of malicious acts and misuse. An engineer from AccuKnox IT Operations reviews such alerts for potential security incidents on occurrence. Any potential incidents are subsequently addressed and resolved, then reviewed by AccuKnox IT Operations management.

Related Security Document:

Sec-150. AccuKnox Network Security Policy

Sec-160. AccuKnox System Security Assurance and Hardening Policy

6.38. Baseline Security Configuration

Technical standards and baselines have been established and communicated for OS deployments. Automated mechanisms and periodic scanning have been deployed to detect and troubleshoot exceptions and/or deviations from the baseline in the production environment. Where applicable, mechanisms are in place for services to re-image production servers with the latest baseline configuration, at least on a monthly frequency. Further, OS and component teams review and update configuration settings and baseline configurations at least annually.

Related Security Document:

Sec-160. AccuKnox System Security Assurance and Hardening Policy

6.39. Network Configuration

The Networking team has implemented procedural and technical standards for the deployment of network devices. These standards include baseline configurations for network devices, network architecture, and approved protocols and ports. The Networking team regularly monitors network devices for compliance with technical standards and potentially malicious activities.

Related Security Document:

Sec-150. AccuKnox Network Security Policy

Sec-151. AccuKnox Network Segmentation Policy

Sec-153. AccuKnox Firewall Management Policy

Sec-154. AccuKnox Wireless Security

6.40. Processing Integrity

AccuKnox monitors the transactions invoked by the customer and relays them appropriately to the suitable Resource Provider endpoint. AccuKnox Portal utilizes AccuKnox configuration files for determining the types of events that are to be recorded when processing a transaction. Additionally, monitoring rules have been defined to process the events that have been recorded and generate alerts per the severity of an event, and forward the same to the required stakeholders in the process so that they can take appropriate action. AccuKnox management reviews portal performance monthly during AccuKnox Review to evaluate the performance of AccuKnox services against compliance with customer SLA requirements.

Requests made through Service Management API or AccuKnox Portal are segregated based on the subscription IDs, and service requests are provisioned based on the parameters defined as per the customer's request. The service requested and the request type allows AccuKnox to provision customer services appropriately. AccuKnox performs input validation to restrict any non-permissible requests to the API, which includes checking for the validity of subscription IDs and the user, Denial of Service (DoS) attack mitigation, protection against XML bombs, namespace validation, and header information.

6.41. Secure Systems Development

6.41.1. Overview

AccuKnox's software development practices, across each of the component teams, are aligned with the AccuKnox Secure Development Lifecycle (SDLC) methodology. The SDLC introduces security and privacy control specifications during the feature/component design and throughout the development process, which are reviewed through designated security roles.

The Security team creates the SDL baseline for AccuKnox services to follow. The SDLC baseline includes tasks to be performed which identify tools or processes that ensure teams are developing their services in a secure manner. As part of onboarding onto the SDLC process, the Security team works with the service teams to determine any additional SDLC steps to be performed specific to the service. Additionally, teams are required to perform threat modeling exercises that are reviewed and approved by the Security team. Each team has an SDLC Owner who is responsible for ensuring appropriate completion of the SDLC tasks. The SDLC Owner reviews the SDLC tasks and gives the overall sign-off for completion of the SDLC process.

The methodologies vary slightly depending on product maturity and the type of development (e.g., new applications vs. incremental features). Sec-170 AccuKnox Application Security Policy and Sec-172 AccuKnox Software Development Life Cycle.

In all cases, the methodologies define:

- Specific phases, activities, and deliverables.
- Phase entry and exit criteria include reviewing feature completeness, quality trends, test case execution, test case automation, and security reviews.
- Formal exit reviews for each phase, with final approval by AccuKnox Products Development leadership or their delegates.

AccuKnox's development process is based on Agile development methodology, which is centered on small, empowered, cross-functional teams called "feature teams" or "scrum teams." Since requirements are hard to capture in documents, Agile concentrates on having running software in development that can be iterated quickly. Feature teams are responsible for planning and delivering sets of related features. Members typically include members from Development, Quality Assurance, Product Management, and Documentation. In some cases, the team may also include members from Cloud Operations and the User Experience teams.

Features may be developed and reviewed with selected customers for evaluation and feedback. Changes are developed and delivered according to the Sec-166 AccuKnox Change Management Policy via one of the following approaches:

- **Feature-Based Development:** New features and enhancements are developed independently utilizing Agile with Scrum for execution.
- **Incubation:** For new product innovation, AccuKnox uses an Incubation development model, which allows for rapid, iterative design and development cycles as requirements are refined.
- **Sustaining:** Production defects are reviewed and resolved under a tightly controlled change management process. Critical defects are fixed quickly via hotfixes or data fixes. Other important fixes are addressed via regularly scheduled service packs.

AccuKnox releases innovation on a frequent basis to customers. Each release contains:

- Feature-Based Development features and/or
- Incubation features and/or
- Minor Enhancements and/or
- Defect Fixes

To ensure customers know what each release contains, the release notice includes a bill of materials "BOM" that highlights which solutions have New Features, Minor Enhancements, or Fixed Defects.

Related Security Document:

Sec-170. AccuKnox Application Security Policy

Sec-171. AccuKnox Encryption & Key Management Standard

Sec-172. AccuKnox Secure Software Development Life Cycle SDLC

Sec-177. AccuKnox Application Security Standard

6.41.2. Sustaining

After the product deploys or ships, defects found by customers are fixed, and these problems are analyzed to improve the next release. Production quality metrics are tracked continuously to determine areas for improvement. AccuKnox formally tracks all production system changes in JIRA for full change management.

A dedicated cross-functional team is responsible for the change management of the product. The team includes Engineering, Quality Assurance (QA), Documentation, and Support. All changes to production follow a defined review and approval process.

- Changes are deployed in Hot Fixes, Data Fixes, or scheduled Service Packs (SP).
- Urgent issues that cannot wait for the next SP are deployed through Hot Fixes (HF). All HFs go through a review, build qualification, and targeted test plan.
- All SP go through the full QA cycle and have the same exit criteria as a full release.
- All change requests (features, enhancements, and defect fixes) are tracked in JIRA, and all code changes are managed in a version control system.

Related Security Document:

Sec-172. AccuKnox Secure Software Development Life Cycle SDLC

6.41.3. Quality Assurance

AccuKnox uses the following quality control processes and tools to ensure release and service packs are built to the highest quality:

- Technical Reviews (during design and implementation)
- Automated Testing & Manual Testing (including ad hoc testing)

- Performance and Stress Testing
- Use of industry-leading development tools

Related Security Document:

Sec-172. AccuKnox Secure Software Development Life Cycle SDLC

6.41.4. Technical Reviews

Prior to implementation, design reviews by either a principal Engineer or Architect are required. During implementation, a code review, performed by two reviewers, is required. Reviews ensure that code is designed and implemented to a high standard. Code check-in cannot happen (system-enforced) until both reviewers approve the code.

Related Security Document:

Sec-172. AccuKnox Secure Software Development Life Cycle SDLC

6.41.5. Testing

AccuKnox leverages an automation test suite (both unit- and UI-level) that provides consistent, repeatable testing, decreased test time, and complete testing rather than relying purely on manual testing. Automation also allows AccuKnox to manage and maintain the release quality throughout the development lifecycle. The automation suite is run for every build during the full development lifecycle. AccuKnox requires that every new feature includes 100% acceptance test automation.

In addition to the automation suite, AccuKnox executes a comprehensive test suite of manual test cases. Each week, AccuKnox also performs regular ad-hoc “group” testing.

The code is scanned using static code scanning tools to identify potential security and code flaws.

AccuKnox establishes a non-negotiable pass rate for all releases for both automation and manual testing.

Related Security Document:

Sec-172. AccuKnox Secure Software Development Life Cycle SDLC

6.41.6. Performance / Stress Testing

Performance testing, validation, and monitoring are an integral part of AccuKnox's development and production models.

During feature development, the design of every feature is reviewed for performance impacts. Automated unit tests are written to ensure critical performance measures are met as part of the feature development exit review. A number of automated tests validate basic performance metrics and measure key performance statistics such as CPU, request execution duration, query frequency, and other representative metrics to catch performance-impacting code changes as soon as possible after they are introduced. This test suite is constantly revised and expanded as AccuKnox changes the code base, whether that is to build new functionality or to fix defects. These test suites are run continuously throughout the development process, providing a level of basic performance coverage across the application suite.

Based on reviews with principal engineers and architects, additional performance testing may be required to ensure that new changes will not adversely affect performance. In these cases, AccuKnox executes performance testing in a lab environment to simulate the production environment. The performance lab consists of a representative model of the production environment. AccuKnox uses two different types of testing in this environment – stress testing and stability testing:

- Stress testing is a test suite designed to simulate production-like transactions under load. Targeted functional tests for each of the features are written to create this production-like load, as well as creating test sets to simulate different usage patterns and loads on the system. Performance is measured through this run and compares these measurements from release to release to ensure that there is not any degradation.
- Stability testing (or longevity testing) is a long-running test suite used to ensure that there are no issues that appear from extended usage of the system. The technical review panel for each product reviews and approves the results of these performance tests. A release can only move forward if it proves that it does not introduce regression in response times or system metrics.

After product release, AccuKnox has a number of metrics that are constantly monitored to ensure system performance of the production system from system level (memory, disk I/O, database connections, etc.) to the application level (page response times, business transitions, etc.). Trend-based monitoring is used to track production system metrics and ensure that there is sufficient capacity for ongoing growth.

Related Security Document:

Sec-172. AccuKnox Secure Software Development Life Cycle SDLC

6.41.7. Source Code Control

AccuKnox source code is stored within AccuKnox's internal source code repository tools that function as the versioning system for the source code. The tools track the identity of the person who checks source code out and what changes are made. Permission to make changes to the source code is provided by granting write access to the source code branches, which limits the access to confined project boundaries per job responsibilities. In addition, source code builds are scanned for malware prior to production release.

Access requests by AccuKnox employees (FTE) and non-FTEs to the source code repository require approval from the relevant project sponsor. Upon expiry, FTEs and non-FTEs need to submit an access request to the project sponsor for renewal.

Related Security Document:

Sec-172. AccuKnox Secure Software Development Life Cycle SDLC

6.41.8. AccuKnox SDLC Adherence

Regardless of the methodology being followed, all releases are fully documented with document change control handled by source code control systems such as Git hosted on Bitbucket Cloud or other document management systems such as the Confluence Wiki. This includes requirements, design, and test approach documents for all features. All test cases and results are documented and tracked.

All Product Lifecycle Management Exit criteria, including GA approval documents, are tracked in a document management system (AccuKnox program management tool). All source code and important project documentation are kept in the version

control systems Git on Bitbucket.

Prior to production implementation, all changes to applications, including emergency changes, require complete documentation based on established procedures and checklists with signoff approval from Engineering Development management before Operations will apply the changes.

Related Security Document:

Sec-172. AccuKnox Secure Software Development Life Cycle SDLC

6.42. Capacity Planning

AccuKnox has implemented the capacity planning process, which is used to identify and quantify adjustments to the growing demand for resources. The goal of the capacity process is to plan ahead while using optimal efficiency.

AccuKnox capacity planning is done monthly. Hardware, storage, and application usage are collected from AccuKnox centralized monitoring, and growth is calculated (where applicable). Based on those numbers, future capacity requirements are estimated, and follow-up tickets are filed.

Cloud Operations senior management meets periodically or as needed to discuss capacity findings and approves significant capacity changes.

The main items reviewed during the monthly meeting are:

- Network usage
- Customer usage for applicable applications
- Data files sizes for major applications
- CPU/memory/disk usage for Search applications

Related Security Document:

Sec-172. AccuKnox Secure Software Development Life Cycle SDLC

6.43. Customer Problem Management

AccuKnox has established formal policies and procedures for customer and system-related problems to support 24x7 resolution of production system-related problems, customer-related issues, and calls. (*Sec-190 AccuKnox Incident Response Policy and Process, Sec 191 AccuKnox Incident Response Plan*)

Customer-related issues are handled by AccuKnox Customer Support, who provide dependable and timely resolution of all customer service requests based on contractual commitments. Within AccuKnox Customer Support, issue resolution is enhanced through the use of proactive notification to customers concerning problems, service interruptions, patches, updates, and Service Pack availability. Furthermore, a knowledge base is available to all AccuKnox employees for categorizing and cataloging issues and solutions to speed problem resolution.

System-related problems are handled by the AccuKnox Production Operations team, which supports AccuKnox Service Level Program, which provides a systems accessibility warranty to AccuKnox customers.

Ticketing systems with prioritization and appropriate escalation are used to track and monitor that issues and problems are resolved in a timely manner. Severity Levels and escalation procedures are established to support contractual commitments and internal guidelines.

Related Security Document:

Sec-172. AccuKnox Secure Software Development Life Cycle SDLC

6.44. Secure Data Deletion

Prior to a customer deception center deactivation and resource reclamation, the customer must negotiate all data extraction with the contracts & support teams.

When a customer's site is marked to be reclaimed, AccuKnox Cloud Operations will trigger a process that goes in and marks all customer data for deletion. The data is then purged from the system, and the client ID number is dissociated with the schema and is returned to the available client pool to be reused for a new customer.

All customer configurations should be purged from cloud operations and backup systems within 48 hours of full contract termination and deception center shutdown. Backup data will be completely purged from the system 48 hours from the date the site has been fully purged from the production environment.

Related Security Document:

Sec-113. AccuKnox Media Handling and Security Policy

Sec-114. AccuKnox Data Disposal and Sanitization Policy

6.45. Vendor Oversight Program

AccuKnox has deployed a Vendor Oversight Program, which ensures that AccuKnox and its vendors stay current with existing contractual obligations, security, privacy and data protection legislation, certification compliance requirements, and industry best practices. Sec-106 AccuKnox Third Party/Vendor Security Risk Management Policy.

Third parties undergo a review process through Procurement, and an approved vendor list has been established. Purchase orders to engage a third party require an AccuKnox vendor Master Agreement (MA) to be established or a review to be performed by Legal. In addition to MA, a signed NDA is also required. Vendors requiring access to source code need to be approved by the President and Legal and sign a Source Code Licensing Agreement.

a) Vendors / Sub-processors

AccuKnox InfoSec is responsible for determining the vendor, sub-processor risk to AccuKnox solutions. Risk is evaluated upon the initial service contract and routinely reevaluated. An initial risk assessment is performed for each vendor, sub-processor to evaluate risk per the service provided, the type of data processed or handled, the cloud security controls, and criticality of the service to the confidentiality, integrity, and availability of the system. Continuous monitoring of vendor risk is achieved through monitoring of vendor Third Party and AccuKnox audit findings and as required. The frequency of vendor risk re-evaluations is prescribed in AccuKnox Vendor and Sub-Processor Risk Assessment Policy.

b) Third-Party Sub-Processor Data Centers

To augment AccuKnox's risk assessment process, AccuKnox obtains security certificates such as Service Organization Controls (SOC2), Payment Card Industry Data Security Standard (PCI-DSS), or equivalent when available from the third-party sub-processor data centers and reviewed for compliance with industry and AccuKnox Third-Party Risk Management Policy. If the aforementioned report is not available, compensating procedures are performed based on AccuKnox's vendor management criteria (e.g., site visits, compliance

reviews as part of the vendor risk management process). If exceptions are noted, management evaluates the associated risk to AccuKnox's control environment.

Related Security Document:

Sec-106. AccuKnox Third Party/Vendor Security Risk Management Policy & Process

7. Complementary User Entity Controls (CUEC)

This section describes controls that AccuKnox assumed, in the design of the system, would be implemented by user entities, and which, if necessary to achieve Trust Services Principles stated in the accompanying description, are identified in the description along with the specific Trust Services principle(s) that cannot be achieved solely by controls implemented by AccuKnox.

The Data and Account Management controls in this section are necessary to achieve the Security and Processing Integrity principles; the Logical Security controls in this section are necessary to achieve the Security principle, and the Backup and Recovery controls in this section are necessary to achieve the Availability principle.

The list of user entity controls presented below does not represent a comprehensive set of all controls that should be employed by customers. Other controls may be required to achieve the customer's security or business requirements in regard to AccuKnox solutions.

Control Area	Customer Responsibility
Service Contract Management	It is the Customer's responsibility to read and be familiar with all terms and conditions of AccuKnox Global Terms and Conditions and AccuKnox Operating Policies regarding the use of AccuKnox solutions. It is the Customer's responsibility to be aware of the various deployment options available within the AccuKnox solution. Customers are responsible for communicating and maintaining accurate organizational contact information with AccuKnox. It is the Customer's responsibility to determine whether optional features selectable within the Solution align with their internal business and security requirements.
Secure Data Deletion	Customers are responsible for exporting their data for the local archive from AccuKnox Cloud Services prior to the expiration of the agreement term.
Backup & Recovery	Customers are responsible for ascertaining data retention and data lifecycles within AccuKnox solutions that are appropriate for their needs.
Logical Security	As applicable, customers are responsible for maintaining their digital certificates as they apply to the use of AccuKnox solution and adhere to the certificates' intended use. Customers are responsible for the proper configuration of the user organization's browser to interact with AccuKnox solutions. Customers are responsible for ensuring that authorized users are appointed as organizational administrators for granting the user access to AccuKnox solutions and optional features. Customers are responsible for configuring their AccuKnox solutions user accounts and shared secrets such that passwords or Personal Identification Numbers (PINs) are sufficiently strong and properly managed. Customers are responsible for ensuring that their AccuKnox solutions passwords and PINs are kept confidential. Customers are responsible for notifying AccuKnox of possible security breaches or incidents to open a ticket via the web portal.

8. Complementary Subservice Organization Controls (CSOCs)

Certain control objectives in this report can only be achieved if CSOCs that were assumed in the design of AccuKnox Platform controls are suitably designed and operating effectively at the subservice organizations.

AccuKnox uses the subservice organizations and their respective CSOCs that should be in operation are described in the table below. These subservice organizations are not subject to examination by Infoguard. The CSOCs presented below should not be regarded as a comprehensive list of all the controls that should be implemented by the subservice organizations.

Subservice Organization	Complementary Subservice Organization Controls
GCP	GCP is responsible for providing a Platform as a Service (PaaS) to host AccuKnox Platform in their cloud environment.
GCP	GCP is responsible for providing Infrastructure as a Service (IaaS) for cloud hosting services where AccuKnox Platform resides.
GCP	GCP is responsible for ensuring network protection for the cloud environment through the use of a proprietary hypervisor firewall and security monitoring applications that are configured and monitored by GCP.
GCP	GCP is responsible for managing logical access to the underlying network, virtualization management, and storage devices for its Infrastructure, where AccuKnox Platform systems reside.
GCP	GCP is responsible for ensuring physical access restriction for the facilities, offline storage and backup data, monitoring network, and other system components such as firewalls, routers, and servers.

9. Criteria Not Application to the System

The following control does not apply to AccuKnox:

- Protecting Customer confidential information.

Rationale: AccuKnox does not have access to nor retains customers' confidential information.

10. Significant Changes During the Review Period

No significant changes have occurred to the services provided to user entities since the organization's last review.

Section IV

Information Provided by Independent Service Auditor and Test Results.

Section IV. Information Provided by Independent Service Auditor and Test Results

Control Activities, Test Procedures, and Results of Testing

This section presents the description of the tests performed by Infoguard to determine whether AccuKnox's controls were operating effectively and the results of those tests of controls.

Our examination was limited to the controls specified by AccuKnox in Sections III and IV of the Report and did not extend to controls in effect at user entities or subservice organizations. It is the responsibility of each user entity and its independent auditor to evaluate this information in conjunction with the evaluation of internal controls at the user entity in order to assess internal control. If their internal controls are not effective at user entities, AccuKnox's controls may not compensate for such deficiencies.

1. Control Environmental Elements

The control environment represents the collective effect of various elements in establishing, enhancing, or measuring the effectiveness of specific controls. Our tests of the control environment included the following procedures:

- Interviews with management, operations, administrative, and other personnel who are responsible for developing, ensuring adherence to, and applying controls;
- Observation of personnel in the performance of their assigned duties;
- Inspection of documents and records pertaining to controls;
- Inquiry about and inspection of compliance monitoring; and
- Inquiry about and inspection of corporate human resources and information security policies.

The control environment was considered in determining the nature, timing, and extent of the testing of the operation of controls relevant to meeting the applicable control objectives.

2. Description of Test Procedures performed

AccuKnox audit procedures for evaluating the suitability of the design were based on the explanations and the procedure descriptions related to the tested processes, as well as the evidence of control effectiveness provided. In detail, AccuKnox used a combination of the audit techniques "inquiry," "observation," and "inspection" for the test of each control activity.

To evaluate the operating effectiveness of controls, Infoguard primarily used the audit technique of "inspection." The combination of audit techniques depended on the design of the controls and the risk assessment of the respective audit areas. If applicable, the items for testing of controls have been selected using random sampling. The audit techniques and testing procedures have been performed as follows:

Type	Description
Inquiry	Inquiry consists of seeking relevant information or representations of knowledgeable persons. Inquiries range from formal written inquiries to interviews and informal oral inquiries.
Observation	Observation consists of looking at a process or procedure being performed by others, for example, the auditor's observation of the performance of control activities. Observation provides audit evidence about the performance of a process or procedure but is limited to the point in time at which the observation takes place and by the fact that the act of being observed may affect how the procedure is performed. Observation is an appropriate way to obtain evidence if there is no documentation of the operation of control, like segregation of duties. Observation is also useful for physical controls.

Inspection	The inspection involves examining records or documents, whether internal or external, in paper form, electronic form, on other media, or a physical examination of evidence. Inspection of records and documents provides audit evidence of varying degrees of reliability, depending on their nature and source, and in the case of internal records and documents, on the effectiveness of the controls over their production. Inspection is often used to determine whether manual controls are being performed. Evidence could include written explanations, checkmarks, or other indications of follow-up recorded on documentation.
------------	---

Sampling and Populations

System-generated populations were obtained whenever possible. Consistent with guidance from the American Institute of Certified Public Accountants (AICPA), Infoguard used professional judgment to consider the tolerable deviation rate, audit risk, characteristics of the population, and other factors to determine the number of items to select in the sample for each test. Infoguard’s sample selections were intended to be representative of the population obtained. Sampling performed by Infoguard is defined in “Tests Performed by Infoguard” as random, judgmental, or haphazard, as appropriate. Full populations were tested only in select instances.

3. Trust Services Principles, Criteria, and Controls

The following Trust Services Principles set forth in TSP section 100, Trust Services Principles and Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy (AICPA, Trust Services Principles, and Criteria, issued 2018) are covered by this report:

a) Security

Requirements: The system is protected against unauthorized access, use, or modification.

The security principle refers to the protection of the system resources through logical and physical access control measures in order to support the achievement of management’s commitments and requirements related to security, availability, processing integrity, and confidentiality. Controls over the security of a system prevent or detect the breakdown and circumvention of segregation of duties, system failure, incorrect processing, theft or other unauthorized removals of data or system resources, misuse of the software, and improper access to, or use of, alteration, destruction, or disclosure of information.

b) Availability

Requirements: The system is available for operation and use as committed or agreed.

The availability principle refers to the accessibility of the system, products, or services as committed by contract, service-level agreement, or other agreements. This principle does not, in itself, set a minimum acceptable performance level for system availability.

c) Processing Integrity

Requirements: System processing is complete, valid, accurate, timely, and authorized.

The processing integrity principle refers to the completeness, validity, accuracy, timeliness, and authorization of system processing. Processing integrity addresses whether the system achieves its aim or the purpose for which it exists and whether it performs its intended function in an unimpaired manner, free from unauthorized or inadvertent manipulation. Processing integrity does not automatically imply that the information received and stored by the system is complete, valid, accurate, current, and authorized. The risk that data contains errors introduced prior to its input in the system often cannot be addressed by system controls, and detecting such errors is not usually the responsibility of the entity. Similarly, users outside the boundary of the system may be responsible for initiating processing. In these instances, the data may become invalid, inaccurate, or otherwise inappropriate, even though the system is processing with integrity.

d) Confidentiality

Requirements: Information designated as confidential is protected as committed or agreed.

The confidentiality principle addresses the system's ability to protect information designated as confidential in accordance with the organization's commitments and requirements through its final disposition and removal from the system.

Information is confidential if the custodian of the information, either by law or regulation, the custodian's own assertion, commitment, or other agreement, is obligated to limit its access, use, and retention and restrict its disclosure to a specified set of persons or organizations (including those that may otherwise have authorized access within the boundaries of the system).

The need for information to be confidential may arise for many different reasons. For example, the information is proprietary information, information intended only for company personnel, personal information, or merely embarrassing information.

4. Test Results of the Trust Services Principles, Criteria, and AccuKnox-Related Controls

Applicable to the Security, Availability, Processing Integrity, and Confidentiality Principle

4.1. CC1.0 – Control Environment

Trust Services Criteria			
CC1.1	The entity demonstrates a commitment to integrity and ethical values.		
CC1.1	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC1.1.1	Setting up the Tone at the Top AccuKnox's board of directors and management, at all levels, demonstrate through their directives, actions, and behavior the importance of integrity and ethical values to support the functioning of the system of internal control. AccuKnox has documented the code of business conduct and ethical standards, which are reviewed, updated, and approved by the board of directors and senior management annually. Related Security Document: Sec-200- AccuKnox Acceptable Use Policy AccuKnox Board of Directors Charter	Inspected AccuKnox's code of business conduct and ethical standards, noting the conduct and standards outline AccuKnox's commitments to integrity and ethical values and that the conduct and standards were updated and approved by the board of directors and senior management within the examination period.	No exceptions noted
CC1.1.2	Establishing Standards of Conduct The expectation of the AccuKnox's board of directors and senior management concerning integrity and ethical values are defined in AccuKnox's standards of conduct and understood at all levels of AccuKnox and by outsourced service providers and business partners. Personnel, including contractors, are required to read and accept the code of business conduct and ethical standards upon their hire and formally reaffirm them annually thereafter. Agreements are established with service providers and business partners that include clearly defined terms, conditions, and responsibilities for service providers and business partners.	For a selection of new hires, including contract hires, inspected the code of business conduct and ethical standards signed and determined that the conduct and the standards were acknowledged by each hire selected. For a selection of current personnel, including contractors, inspected the code of business conduct and ethical standards signed and determined that the conduct and the standards were acknowledged annually by each person selected. For a selection of agreements with the service providers and business partners, inspected the agreements and determined that the agreement outlined AccuKnox's requirements, including terms,	No exceptions noted

CC1.1	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
	Related Security Document: Sec-200- AccuKnox Acceptable Use Policy Sec-201- AccuKnox Employee & Contractor Onboarding, Change and Termination Policy & Process AccuKnox Board of Directors Charter	conditions, and responsibilities for the service providers and business partners.	
CC1.1.3	Evaluating Adherence to Standards of Conduct AccuKnox's policies and processes are in place to evaluate the performance of individuals and teams against AccuKnox's expected standards of conduct. Related Security Document: Sec-201- AccuKnox Human Resources Security Management Policy Sec-200- AccuKnox Acceptable Use Policy	Inspected AccuKnox's code of business conduct and ethical standards, noting the conduct and standards outline AccuKnox's commitments to integrity and ethical values and the requirements for the personnel and contractors to comply and signature. For a selection of current and new hires, including contract hires, inspected the code of business conduct and ethical standards signed and determined that the conduct and the standards were acknowledged by each personnel selected.	No exceptions noted
CC1.1.4	Addressing Deviations in a Timely Manner Deviations from AccuKnox's expected standards of conduct are identified and remedied in a timely and consistent manner. AccuKnox's management monitors personnel compliance with the code of business conduct and ethical standards through monitoring of customer and workforce member complaints. AccuKnox's code of business conduct includes a sanctions policy for personnel who violate the code of business conduct. The sanctions policy is applied to personnel who violate the code of business conduct. Related Security Document: Sec-200- AccuKnox Acceptable Use Policy	Inspected AccuKnox's code of business conduct and determined that it included a sanctions policy for personnel who violate the code of business conduct. For a selection of customer and workforce member complaints logged via the third-party administered hotline, inspected the related documentation and determined that personnel who violated the code of business conduct were sanctioned as per the policy.	No exceptions noted
CC1.1.5	Considering Contractors and Vendor Employees in Demonstrating their Commitment Before a third party is engaged by AccuKnox, the third-party personnel undergo background screening. A background check includes, at a minimum, credit, criminal, drug, and employment checks. Related Security Document: Sec-201- AccuKnox Background Screening Policy & Standard	For a selection of third-party personnel engaged by AccuKnox, inspected the background checks and determined that selected third-party personnel successfully completed background checks, including credit, criminal, drug, and employment checks prior to being engaged by AccuKnox.	No exceptions noted

Trust Services Criteria

CC1.2	The board of directors demonstrates independence from management and exercises oversight of the development and performance of internal control.		
CC1.2	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC1.2.1	BOD Establishing Oversight Responsibilities The board of directors identifies and accepts its oversight responsibilities in relation to established requirements and expectations. AccuKnox's board of directors is appointed to act on behalf of the shareholders. Roles and responsibilities of the board of directors as outlined in the Board of Directors' Charter are segregated from the roles and responsibilities of management. The board of directors understands and acknowledges the Board of Directors' Charter to accept its oversight responsibilities in relation to established requirements and expectations. Related Security Document: AccuKnox Board of Directors Charter	Inspected AccuKnox's Board of Directors Charter and determined that the board of directors is appointed to act on behalf of the shareholders, and the roles and responsibilities are segregated from the roles and responsibilities of management. Inspected AccuKnox's board of directors' acknowledgment of the Board of Directors' Charter to accept its oversight responsibilities in relation to established requirements and expectations.	No exceptions noted
CC1.2.2	BOD Applying Relevant Expertise AccuKnox's board of directors defines, maintains, and periodically evaluates the skills and expertise needed among its members to enable them to ask probing questions of senior management and take commensurate action. The Board of Directors' Charter includes the minimum background and skills required of the board of directors. Related Security Document: AccuKnox Board of Directors Charter	Inspected AccuKnox's Board of Directors' Charter and determined that the minimum background and skills required of the board of directors are documented.	No exceptions noted
CC1.2.3	BOD Operating Independently AccuKnox's board of directors has sufficient members who are independent of management The board of directors consists of a majority of independent members as per the Board of Directors' Charter to maintain independence from management. Related Security Document: AccuKnox Board of Directors Charter	Inspected AccuKnox's Board of Directors Charter and determined that it notes the board of directors should consist of a majority of independent members. Inspected the board of directors structure and determined that the board of directors consisted of a majority of independent members.	No exceptions noted

CC1.2.4	Supplementing Board Expertise AccuKnox's board of directors supplements its expertise relevant to security, availability, processing integrity, confidentiality, and privacy, as needed, through the use of a subcommittee or consultants. AccuKnox has a Security Steering Committee governed by the Security Steering Committee Charter that provides support to the board of directors. The Security Steering Committee Charter includes roles and responsibilities relevant to security and support to the board of directors. Related Security Document: Sec-104- AccuKnox Information Security Steering Committee Organization Chart & Charter AccuKnox Board of Directors Charter	Inspected AccuKnox's Information Security Steering Committee structure and determined that a Security Steering Committee was in place. Inspected the Security Steering Committee Charter and determined that it included roles and responsibilities relevant to security and support to the board of directors	No exceptions noted
---------	---	--	---------------------

Trust Services Criteria			
CC1.3	Management establishes, with board oversight, structures, reporting lines, and appropriate authorities and responsibilities in the pursuit of objectives.		
CC1.3	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC1.3.1	Management Considering All Structures of the Organization AccuKnox's management and the board of directors consider the multiple structures used (including operating units, legal entities, geographic distribution, and outsourced service providers) to support the achievement of objectives. AccuKnox management and the board of directors evaluate its organizational structure, reporting lines, authorities, and responsibilities as part of its business planning process and as part of its ongoing risk assessment and management process and revise these when necessary to support the achievement of objectives. Related Security Document: Sec-101- AccuKnox Information Security Management Plan Sec-104- AccuKnox Information Security Steering Committee Organization Chart & Charter	Inspected AccuKnox's organization chart and the annual business planning documentation and determined that organizational structure, reporting lines, authorities, and responsibilities were identified, reviewed annually, and made available to the organization personnel via the organization's intranet.	No exceptions noted
CC1.3.2	Management Establishing Reporting Lines AccuKnox's management designs and evaluates lines of reporting for each AccuKnox structure to enable execution of authorities and responsibilities and flow of information to manage the activities of AccuKnox. Job descriptions are reviewed by AccuKnox management on an annual basis for needed changes, and where job duty changes are required, necessary changes to these job descriptions are also made to enable execution of authorities and responsibilities and flow of information to manage the activities of AccuKnox. Related Security Document: Sec-201- AccuKnox Human Resources Security Management Policy Sec-201- AccuKnox Employee & Contractor Onboarding, Change and Termination Policy & Process	Inspected the organization chart and determined that organizational structure, reporting lines, authorities, the flow of information, and responsibilities were established. For a sample of positions, inspected written job descriptions to determine whether the job descriptions included responsibilities and flow of information to manage the activities of AccuKnox.	No exceptions noted

CC1.3	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC1.3.3	Management defining, Assigning, and Limiting Authorities and Responsibilities AccuKnox's management and the board of directors delegate authority, define responsibilities and use appropriate processes and technology to assign responsibility and segregate duties as necessary at the various levels of the organization. Roles and responsibilities are defined in written job descriptions and communicated to managers and their supervisors, taking into consideration the segregation of duties as necessary at the various levels of the organization and requirements relevant to security. Personnel is required to sign a copy of their job description to acknowledge their understanding of their responsibilities. Reporting relationships and organizational structures are reviewed periodically by senior management and the board of directors as part of organizational planning and adjusted as needed based on changing commitments and requirements. Related Security Document: Sec-201- AccuKnox Human Resources Security Management Policy Sec-201- AccuKnox Employee & Contractor Onboarding, Change and Termination Policy & Process	Inspected the organizational structure and job descriptions and determined that organizational structure, reporting lines, authorities, and responsibilities were documented, taking into consideration segregation of duties as necessary relevant to security. For a selection of personnel hired or transferred to a new role during the period, obtained the file copy of their job description and determined that the employees had acknowledged their understanding of their responsibilities. Inspected the annual business planning and organization chart documentation and determined that organizational structure, reporting lines, authorities, and responsibilities were revised.	No exceptions noted
CC1.3.4	Management Addressing Specific Requirements When Defining Authorities and Responsibilities AccuKnox's management and the board of directors consider requirements relevant to security, availability, processing integrity, confidentiality, and privacy when defining authorities and responsibilities Roles and responsibilities for external party interaction and activity monitoring are defined in written job descriptions and communicated to personnel. Personnel is required to sign a copy of their job description to acknowledge their understanding of their responsibilities. Related Security Document: Sec-201- AccuKnox Human Resources Security Management Policy Sec-201- AccuKnox Employee & Contractor Onboarding, Change and Termination Policy & Process	For a selection of AccuKnox's personnel hired or transferred to a new role or with roles that required interaction with the external parties during the period, obtained the file copy of their job description and determined that the requirements relevant to security, availability, and confidentiality were considered in their job descriptions and responsibilities.	No exceptions noted

Section IV - Trust Services Criteria, AccuKnox Implementation of Controls, and Test Results

CC1.3	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC1.3.5	Management Considering Interactions with External Parties When Establishing Structures, Reporting Lines, Authorities, and Responsibilities AccuKnox's management and the board of directors consider the need for AccuKnox to interact with and monitor the activities of external parties when establishing structures, reporting lines, authorities, and responsibilities. AccuKnox has developed third-party security and management policy and procedures and considers interactions with external parties when establishing a relationship. Related Security Document: Sec-206- AccuKnox Third Party / Vendor Security Risk Management Policy & Process	For a selection of outsourced service providers, including existing and new providers, inspected the annual service provider risk assessments performed and determined that external service provider performance and risks were assessed, including reporting lines, authorities, and responsibilities.	No exceptions noted

Trust Services Criteria

CC1.4	The entity demonstrates a commitment to attract, develop, and retain competent individuals in alignment with objectives.		
CC1.4	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC1.4.1	Establishing Policies and Practices to reflect expectations of competence necessary to support the achievement of objectives Job requirements are documented in the job descriptions. Candidates' abilities, whether an employee, contractor, or vendor employee, are evaluated as part of the hiring or transfer evaluation process to meet those requirements. Related Security Document: Sec-201- AccuKnox Human Resources Security Management Policy Sec-201- AccuKnox Employee & Contractor Onboarding, Change and Termination Policy & Process	Inspected AccuKnox Human Resources onboarding policy to determine that expectations of competence for the job requirements were included in the policy. For a selection of new hires, whether an employee, contractor vendor employee, or transfers, inspected the personnel file and determined that job requirements and expectations of competence were aligned with the position's objectives and documented.	No exceptions noted
CC1.4.2	Evaluating Competence and Addressing Shortcomings Personnel competence across AccuKnox and in outsourced service providers is measured against established policies and practices as part of the annual evaluation process or when new outsourced service provider relationships are established to support the achievement of	For a selection of personnel, whether an employee, contractor, or vendor employee, inspected the personnel file and determined that annual performance evaluations were performed, including action items for any shortcomings or decision to terminate the employment as well as follow-up on prior year's action items as necessary.	No exceptions noted

CC1.4	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
	AccuKnox's service commitments and system requirements and address shortcomings. Any shortcomings noted during the evaluation are addressed with action items and reevaluated in the following year's evaluation process. Related Security Document: Sec-201- AccuKnox Human Resources Security Management Policy Sec-201- AccuKnox Employee & Contractor Onboarding, Change and Termination Policy & Process		
CC1.4.3	Attracting, Developing, and Retaining Individuals AccuKnox provides the mentoring and training needed to attract, develop, and retain sufficient and competent personnel and outsourced service providers to support the achievement of objectives. The management establishes requisite skillsets for personnel, whether an employee, contractor, or vendor employee, and provides continued training about its commitments and requirements for personnel to support the achievement of objectives monitors compliance with training requirements. Related Security Document: Sec-203- AccuKnox Security Awareness Training & Education Policy	For a selection of personnel, obtained the dates of and attendance sheets for role-specific training and determined that the employee, contractor, or vendor employee selected had signed the attendance sheet for training sessions and updates on the specified dates.	No exceptions noted
CC1.4.4	Planning and Preparing for Succession During its ongoing and periodic business planning, business continuity planning, and budgeting process, AccuKnox's management and the board of directors evaluate the need for additional tools and resources to achieve business objectives, including contingency plans for assignments of responsibility important for internal control. Related Security Document: Sec-101- AccuKnox Information Security Management Plan Sec-210- AccuKnox Business Contingency Policy	Inspected AccuKnox's annual business planning, business continuity planning, and budgeting-related documentation and determined that AccuKnox continually evaluated its need for additional tools and resources as well as contingency plans for assignments of responsibility important for internal control.	No exceptions noted
CC1.4.5	Considering the background of potential and existing personnel, contractors, and vendor employees when determining whether to employ and retain the individuals Prior to employment, personnel, including contractors and vendor employees, are verified against regulatory screening databases, including, at a minimum, credit, criminal, drug, and employment checks. For personnel with responsibility important for internal control, such background checks are re-performed every two years.	For a selection of new hires, including contractors and vendor employees, inspected the background checks and determined that selected personnel successfully completed background checks, including credit, criminal, drug, and employment checks prior to being hired by AccuKnox. For a selection of personnel with responsibility important for internal control, inspected the background checks and determined that selected personnel successfully completed background checks	No exceptions noted

CC1.4	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
	Related Security Document: Sec-201- AccuKnox Background Screening Policy & Standard	including credit, criminal, drug and employment checks every two years.	
CC1.4.6	Considering the Technical Competency of Individuals AccuKnox's management evaluates the technical competency of potential and existing personnel, contractors, and vendor employees when determining whether to employ and retain the individuals Related Security Document: Sec-201- AccuKnox Background Screening Policy & Standard	For a selection of new hires, whether an employee, contractor vendor employee, or transfers: - inspected the personnel file and determined that job requirements and technical competency were documented in the job descriptions. - inspected the personnel file and determined that offer letter and management notes were maintained, evidencing that the selected personnel were evaluated before they assumed the responsibilities of their positions. - inspected the personnel file and determined that annual performance evaluations were performed, including action items for any shortcomings or decisions to terminate the employment	No exceptions noted
CC1.4.7	Providing Training to Maintain Technical Competencies AccuKnox provides training programs, including continuing education, and training, to ensure skill sets and technical competency of existing personnel, contractors, and vendor employees are developed and maintained Related Security Document: Sec-203- AccuKnox Security Awareness Training & Education Policy	Obtained the dates of and attendance sheets for the annual security training, as well as the quarterly security compliance updates for employees, and determined that employees had signed the attendance sheet for training sessions and updates on the specified dates. For a selection of personnel, obtained the dates of and attendance sheets for role-specific training and determined that the employee, contractor, or vendor employee selected had signed the attendance sheet for training sessions and updates on the specified dates.	No exceptions noted

Trust Services Criteria

CC1.5 The entity holds individuals accountable for their internal control responsibilities in the pursuit of objectives.

CC1.5.1	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC1.5.1	Enforcing Accountability Through Structures, Authorities, and Responsibilities AccuKnox's management and the board of directors establish the mechanisms to communicate and hold individuals accountable for the performance of internal control responsibilities across AccuKnox and implement corrective action as necessary. AccuKnox management performs annual performance evaluations to communicate and hold individuals accountable for the performance of internal control responsibilities. The performance evaluation is signed by the manager and employee—corrective actions, including training or sanctions, as necessary. Each AccuKnox department holds periodic meetings to monitor and manage the respective department's progress or lack thereof as it relates to their achievement of the department's responsibilities. Related Security Document: Sec-101· AccuKnox Information Security Management Plan Sec-201· AccuKnox Human Resources Security Management Policy Sec-104· AccuKnox Information Security Steering Committee Organization Chart & Charter	For a selection of personnel, whether an employee, contractor, or vendor employee, inspected the personnel file and determined that annual performance evaluations were performed, including action items for any shortcomings or decision to terminate the employment, and whether evaluations were signed by the manager and the employee. For a selection of weekly department meetings that impacted security criteria, the meeting minutes were inspected, and it was determined that the department's progress was monitored and measured by respective department heads, including escalation or taking of corrective action as necessary.	No exceptions noted
CC1.5.2	Establishing Performance Measures, Incentives, and Rewards AccuKnox's management and the board of directors establish performance measures, incentives, and other rewards appropriate for responsibilities at all levels of AccuKnox, reflecting appropriate dimensions of performance and expected standards of conduct, and considering the achievement of both short-term and longer-term objectives Related Security Document: Sec-101· AccuKnox Information Security Management Plan Sec-201· AccuKnox Human Resources Security Management Policy	For a selection of roles, inspected AccuKnox's documented goals, performance evaluation criteria, and compensation matrix, including incentives and rewards, and determined that a formal process has been implemented for performance measures, incentives, and rewards and that the goals documented for selected roles included both short-term and longer-term goals that aligned with AccuKnox's short-term and longer-term goals.	No exceptions noted

4.2. CC2.0 - Information and Communication

Trust Services Criteria			
CC2.1	The entity obtains or generates and uses relevant, quality <u>information</u> to support the functioning of internal control		
CC2.1	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC2.1.1	Identifying Information Requirements A process is in place to identify the information required and expected to support the functioning of the other components of internal control and the achievement of the entity's objectives. Through an established asset management process, AccuKnox performs asset discovery, including information assets at least annually to identify the information required and expected to support the internal control and the achievement of AccuKnox's service commitments and system requirements. AccuKnox's most valuable and sensitive digital data and mission-critical systems are also identified during the annual risk assessment, including internal and external sources of data. Related Security Document: Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process Sec-110. AccuKnox Asset Management Policy & Process	Inspected AccuKnox's asset management Policy and procedure and annual risk assessment and determined that it identified the information required to support internal controls and the achievement of AccuKnox's service commitments and system requirements, including identification of most valuable data and mission-critical systems, whether those are internal or external to AccuKnox.	No exceptions noted
CC2.1.2	Capturing Internal and External Sources of Data AccuKnox's information system captures internal and external sources of data through asset discovery and management process at least annually, which identifies key information system processes that process relevant data into information to support the internal control and the achievement of AccuKnox's service commitments and system requirements. Related Security Document: Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process Sec-110. AccuKnox Asset Management Policy & Process	Inspected AccuKnox's annual assessment and determined that it identifies the key information system processes that process relevant data into information required to support internal controls and the achievement of AccuKnox's service commitments and system requirements. Inspected AccuKnox's asset inventory to determine whether asset inventory was performed and the source of information, internal and external, was captured	No exceptions noted

CC2.1	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC2.1.3	Processing and Transforming Relevant Data into Information AccuKnox's information system has implemented various processes and procedures relevant to security to produce information that is timely, current, accurate, complete, accessible, protected, verifiable, and retained. Related Security Document: Sec-101- AccuKnox Information Security Management Plan	Inspected AccuKnox's documented policies and procedures as they related to the security of most valuable data and mission-critical systems and determined that those documented AccuKnox's internal controls for producing, timely, current, accurate, complete, accessible, protected, verifiable, and retained information as applicable. Inspected AccuKnox SIEM and verified that it processed and transferred timely, current, accurate security data to information used by the security team to act upon as needed.	No exceptions noted
CC2.1.4	Maintaining Quality Throughout Processing AccuKnox has logical and physical security, change management, incident monitoring, and data classification, integrity, and retention controls, as necessary, with checks and balances woven into each applicable process to ensure the quality of processing. Information is reviewed to assess its relevance in supporting the internal control components. Related Security Document: Sec-101- AccuKnox Information Security Management Plan	Inspected AccuKnox's documented policies and procedures as they related to the security of most valuable data and mission-critical systems and determined that those document AccuKnox's internal controls for producing, timely, current, accurate, complete, accessible, protected, verifiable, and retained information, as applicable.	No exceptions noted

Trust Services Criteria

CC2.2	The entity <u>internally</u> communicates information, including objectives and responsibilities for internal control, necessary to support the functioning of internal control		
CC2.2	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC2.2.1	Communicating Internal Control Information A process is in place to communicate required information to enable all personnel to understand and carry out their internal control responsibilities, including Information necessary for designing, developing, implementing, operating, maintaining, and monitoring controls relevant to the security of the system. Related Security Document: Sec-101- AccuKnox Information Security Management Plan	Inspected AccuKnox's intranet and determined that documented policies and procedures as it relates to the security of the most valuable data and mission-critical systems is available to internal personnel on the intranet.	No exceptions noted

CC2.2	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
	Sec-102- AccuKnox Information Security Document Management (Policy, Standards, Process, Artifacts)		
CC2.2.2	Management Communicating with the Board of Directors Communication exists between management and the board of directors so that both have the information needed to fulfill their roles with respect to the entity's objectives. AccuKnox management and the security steering committee meet quarterly and annually to communicate information needed to fulfill their roles with respect to the achievement of AccuKnox's service commitments and system requirements. Related Security Document: Sec-101- AccuKnox Information Security Management Plan Sec-104- AccuKnox Information Security Steering Committee Organization Chart & Charter	For a selection of quarters and the year, inspected the quarterly security steering committee meeting minutes and determined that those minutes documented communications with the executive management regarding the achievement of AccuKnox's service commitments and system requirements, including security, progress, delays, risks, and challenges as applicable.	No exceptions noted
CC2.2.3	Providing Separate Communication Lines Separate communication channels, such as hotlines, are in place and serve as fail-safe mechanisms to enable anonymous or confidential communication when normal channels are inoperative or ineffective. In addition, for communication of an unforeseen event, incident response policies and procedures are in place that includes an escalation plan based on the nature and severity of the incident to senior management and the board of directors as necessary. Related Security Document: Sec-190- AccuKnox Incident Response Policy and Process Sec-191- AccuKnox Incident Response Plan Sec-104- AccuKnox Information Security Steering Committee Organization Chart & Charter	Inspected AccuKnox communication channel and determined that AccuKnox provided alternatives for phone, email communications. Inspected AccuKnox's documented incident response policies and procedures and determined that it includes an escalation tree and multiple communication plans depending on the nature of the incident, including escalation to the executive management, as necessary.	No exceptions noted
CC2.2.4	Selecting Relevant Method of Communication that Considers the Timing, Audience, and Nature of the Information AccuKnox's security commitments are communicated to external users, as appropriate, and those commitments and the associated system requirements are communicated to internal users to enable them to carry out their responsibilities. The responsibilities of internal users whose roles affect system operation are communicated to those parties via the company intranet, departments meetings, all hands meetings, one-on-one meetings, and email.	Inspected AccuKnox's intranet, customer portal, and websites and determined that documented responsibilities, policies, and procedures as they relate to security commitments and responsibilities were available to internal personnel on the intranet and external personnel on AccuKnox's websites and customer portals as applicable. For a selection of responsibilities, policies, and procedures posted on the intranet, inspected the documents and determined that the history of changes with the date of change was documented.	No exceptions noted

CC2.2	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
	Responsibilities and policies, and procedures posted on AccuKnox's intranet are updated as necessary. Related Security Document: Sec-101- AccuKnox Information Security Management Plan Sec-102- AccuKnox Information Security Document Management (Policy, Standards, Process, Artifacts) Sec-106- AccuKnox Third Party / Vendor Security Risk Management Policy & Process		
CC2.2.5	Communicating Responsibilities AccuKnox personnel with responsibility for designing, developing, implementing, operating, maintaining, or monitoring system controls <u>receive</u> communications about their responsibilities, including changes in their responsibilities, and have the information necessary to carry out those responsibilities via policies and job descriptions and intranet. Related Security Document: Sec-102- AccuKnox Information Security Document Management (Policy, Standards, Process, Artifacts)	Inspected AccuKnox's intranet, customer portal, and websites and determined that documented responsibilities, policies, and procedures as they relate to security commitments and responsibilities are available to internal personnel on the intranet and external personnel on AccuKnox's websites and customer portals as applicable and that those responsibilities, policies, and procedures documented history of changes with the date of the change.	No exceptions noted
CC2.2.6	Communicating Information on Reporting System Failures, Incidents, Concerns, and Other Matters AccuKnox personnel is provided with information on how to report systems failures, incidents, concerns, and other complaints to personnel via helpdesk, security incident policy, procedures, and plan. Related Security Document: Sec-190- AccuKnox Incident Response Policy and Process Sec-191- AccuKnox Incident Response Plan	Inspected AccuKnox's documented incident response policies and procedures and determined that it includes information and paths for reporting system failures and incidents. Inspected AccuKnox's security awareness training and determined instructions were provided for reporting system failures, incidents, and other matters.	No exceptions noted
CC2.2.7	Communicating Objectives and Changes to Objectives to Personnel in a Timely Manner Management provides continued training about its security commitments and requirements for personnel to support the achievement of objectives. Planned changes to objectives are reviewed and communicated to personnel as part of security steering committee meetings, department meetings, emails, and one-on-one meetings. Related Security Document: Sec-203- AccuKnox Security Awareness Training & Education Policy	Obtained the dates of and attendance sheets for the quarterly security steering committee meeting, as well as the quarterly security compliance updates for employees, and determined that objectives and changes to the objectives had been communicated to the personnel and departments heads.	No exceptions noted

CC2.2	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
	Sec-104- AccuKnox Information Security Steering Committee Organization Chart & Charter		
CC2.2.8	Communicating Information to Improve Security Knowledge and Awareness Management provides continued security awareness training to personnel about its security commitments to model appropriate security behaviors to personnel and monitors compliance with security training requirements. AccuKnox also provides user guides, security alerts, and known issues on its websites and customer portal with information to improve security knowledge and awareness. Related Security Document: Sec-102- AccuKnox Information Security Document Management (Policy, Standards, Process, Artifacts)	Obtained the dates of and attendance sheets for the annual security training, as well as the quarterly security compliance updates for employees, and determined that employees had signed the attendance sheet for training sessions and updates on the specified dates. For a selection of personnel not present during the training dates, inspected management's training-related documentation and determined that the selected personnel were required to take the training subsequently within the examination period. Inspected AccuKnox's customer portal and websites and determined that user guides and history of security alerts, and known issues with information to improve security knowledge and awareness were available.	No exceptions noted
CC2.2.9	Communicating Information About System Operation and Boundaries AccuKnox prepares and communicates information about the design and operation of the system and its boundaries to authorized personnel to enable them to understand their role in the system and the results of system operation. AccuKnox posts a description of its system, system boundaries, and system processes that include infrastructure, software, people, processes and procedures, and data on its intranet for authorized users.	Inspected AccuKnox's intranet descriptions of AccuKnox's system, system boundaries, and system processes and determined that the description addressed infrastructure, software, people, processes and procedures, and data for the in-scope technology and locations and available to authorized personnel.	No exceptions noted
CC2.2.10	Communicating System Objectives AccuKnox communicates its system objectives to personnel to enable them to carry out their responsibilities via the company intranet. Planned changes to system components and objectives are reviewed, scheduled, and communicated to management as part of the weekly IT maintenance process. Related Security Document: Sec-166- AccuKnox Change Management Policy & Process	Inspected AccuKnox's intranet descriptions of AccuKnox's system, system objectives and determined that the description addressed system objectives, infrastructure, software, people, processes and procedures, and data for the personnel to carry out their responsibilities.	No exceptions noted

Trust Services Criteria

CC2.3 The entity communicates with <u>external parties</u> regarding matters affecting the functioning of internal control.			
CC2.3	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC2.3.1	Communicating to External Parties Processes are in place to communicate relevant and timely information to external parties, including shareholders, partners, owners, regulators, customers, financial analysts, and other external parties. AccuKnox has incident response policies and procedures in place that includes an escalation plan based on the nature and severity of the incident to senior management, the board of directors, and external parties, including shareholders, partners, owners, regulators, customers, financial analysts, and other external parties as necessary. Related Security Document: Sec-190- AccuKnox Incident Response Policy and Process Sec-106- AccuKnox Third Party / Vendor Security Risk Management Policy & Process	Inspected AccuKnox's vendor and 3rd-party management policy and procedures and determined that it includes communication with external parties regarding matters affecting the functioning of internal controls. Inspected AccuKnox's documented incident response policies and procedures and determined that they include escalation tree and communication plans depending on the nature of the incident, including escalation to senior management, the board of directors, and external parties, including shareholders, partners, owners, regulators, customers, financial analysts, and other external parties as necessary.	No exceptions noted
CC2.3.2	Enabling Inbound Communications Open communication channels allow input from customers, suppliers, external auditors, regulators, financial analysts, and others, providing management and the board of directors with relevant information. AccuKnox has made available contact email and phone numbers on its website and customer portal to customers, consumers, suppliers, external auditors, regulators, financial analysts, and others. Management monitors customer and workforce member complaints reported via emails and phones.	Inspected AccuKnox's customer portal and websites and determined that contact email and phone numbers are available to customers and external users on the customer portal and websites. Inspected AccuKnox's website and test dialed the number provided, and determined that a third-party administered hotline is available. For a selection of customer and workforce member complaints logged via the third-party administered hotline/support, inspected the related documentation and determined that personnel who violated the code of business conduct were sanctioned as per the policy.	No exceptions noted
CC2.3.3	Communicating with the Board of Directors Relevant information resulting from assessments conducted by external parties is communicated to the board of directors. The Legal, Compliance, and Internal Audit departments meet with the steering committee quarterly to provide relevant information resulting from assessments conducted by internal and external parties. In addition, any significant information security-related findings noted as part of AccuKnox's audits are communicated by the external auditor to the Audit Committee during quarterly and annual meetings. Related Security Document: Sec-221- AccuKnox Internal Audit Policy & Process	For a selection of quarters and the year, inspected the quarterly and annual board meeting minutes and determined that the Legal, Compliance and Internal Audit departments present an executive summary of all external and internal audit findings for the quarter, including copies of the audit reports to the Board, and that significant information security-related findings noted by the external auditors were also communicated by the external auditor to the audit committee.	No exceptions noted

CC2.3	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
	Sec-104- AccuKnox Information Security Steering Committee Organization Chart & Charter		
CC2.3.4	Providing Separate Communication Lines Separate communication channels, such as hotlines/support, are in place and serve as fail-safe mechanisms to enable anonymous or confidential communication when normal channels are inoperative or ineffective.	In addition to a support portal for customers' communication, verified that AccuKnox provides phone support and email to enable customers to communicate when normal channels are inoperative or inactive.	No exceptions noted
CC2.3.5	Selecting Relevant Method of Communication The method of communication considers the timing, audience, and nature of the communication and legal, regulatory, and fiduciary requirements and expectations. AccuKnox's security commitments are communicated to external users as appropriate. Agreements are established with service providers and business partners that include clearly defined terms, conditions, and responsibilities for service providers and business partners. Related Security Document: Sec-106- AccuKnox Third Party / Vendor Security Risk Management Policy & Process	Inspected AccuKnox's customer portal and websites and determined that documented responsibilities as it relates to security commitments and responsibilities are available to external personnel. For a selection of agreements with the service providers and business partners, inspected the agreements and determined that the agreement outlined AccuKnox's requirements, including terms, conditions, and responsibilities for the service providers and business partners.	No exceptions noted
CC2.3.6	Communicating Objectives Related to Confidentiality and Changes to Objectives Through business agreements, AccuKnox communicates to external users, vendors, business partners, and others whose products and services are part of the system, objectives and changes to objectives related to confidentiality.	For a selection of agreements with the service providers and business partners, inspected the agreements and determined that the agreement outlined AccuKnox's requirements, including confidentiality and changes to objectives and responsibilities for the service providers and business partners.	No exceptions noted
CC2.3.7	Communicating Objectives Related to Privacy and Changes to Objectives Through business agreements, AccuKnox communicates, to external users, vendors, business partners, and others whose products and services are part of the system, objectives related to privacy, and changes to those objectives.	For a selection of agreements with the service providers and business partners, inspected the agreements and determined that the agreement outlined AccuKnox's requirements, including privacy and changes to those objectives and responsibilities for the service providers and business partners.	No exceptions noted
CC2.3.8	Communicating Information About System Operation and Boundaries AccuKnox prepares and communicates information about the design and operation of the system and its boundaries to authorized external users to permit users to understand their role in the system and the results of system operation.	Inspected AccuKnox's intranet and internet descriptions of AccuKnox's system, system boundaries, and system processes and determined that the description addressed infrastructure, software, people, processes and procedures, and data for the in-scope technology and locations.	No exceptions noted

CC2.3	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
	AccuKnox posts a description of its system, system boundaries, and system processes that include infrastructure, software, people, processes and procedures, and data on the internet for authorized external users.		
CC2.3.9	Communicating System Responsibilities External users with responsibility for designing, developing, implementing, operating, maintaining, and monitoring system controls receive communications about their responsibilities and have the information necessary to carry out those responsibilities. Agreements are established with service providers and business partners that include clearly defined terms, conditions, and responsibilities for service providers and business partners. Related Security Document: Sec-106- AccuKnox Third Party / Vendor Security Risk Management Policy & Process	For a selection of agreements with the service providers and business partners, inspected the agreements and determined that the agreement outlined AccuKnox's requirements, including terms, conditions, and responsibilities for the service providers and business partners, and that signed addendum to agreements were also maintained when changes to commitments occurred as necessary.	No exceptions noted
CC2.3.10	Communicating Information on Reporting System Failures, Incidents, Concerns, and Other Matters External users are provided with information on how to report systems failures, incidents, concerns, and other complaints to appropriate personnel.	Inspected AccuKnox's website for verification of support features to report system failures, incidents, concerns, and other matters.	No exceptions noted

4.3. CC3.0 - Risk Assessment

Trust Services Criteria			
CC3.1	The entity specifies objectives with sufficient clarity to enable the identification and assessment of risks relating to objectives.		
CC3.1	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC3.1.1	Specifying Operational Objectives AccuKnox management specifies Operational Objectives and establishes the following activities as a basis for security, risk management, allocating resources to the achievement of operations objectives: • sub-objectives related to security, availability, processing integrity, confidentiality, and privacy to support the achievement of the entity's objectives related to reporting, operations, and compliance. • Management's choices about structure, industry considerations, and performance of the entity. • Tolerances for Risk- Management considers the acceptable levels of variation relative to the achievement of operations objectives. • Desired level of operations and financial performance for the entity within operations objectives. AccuKnox management performs a risk assessment annually. The risk assessment is based on the objectives established by management under the oversight of the board of directors. The objectives incorporate the service commitments and system requirements of AccuKnox service. Assessed risks are reviewed quarterly to identify changes in underlying threats or in the environment that would require an update to assess risks. Related Security Document: Sec-101- AccuKnox Information Security Management Plan Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process	Inspected AccuKnox Information Security Management Plan to determine that operational objectives were specified and established for security, availability, processing integrity, confidentiality, and privacy to support the achievement of the entity's objectives related to reporting, operations, and compliance. Inspected the annual risk assessment documentation to determine whether the risk assessment process included consideration of AccuKnox's objectives, service commitments, and system requirements.	No exceptions noted
CC3.1.2	Specifying Compliance Objectives AccuKnox management establishes compliance objectives to comply with laws and regulations and minimum standards of conduct. AccuKnox subscribes to an external reporting service that identifies changes to laws and regulations relating to AccuKnox services for the	Inspected AccuKnox Information Security Management Plan to determine that compliance objectives were specified, changes to the law and regulations relating to AccuKnox services for the justifications in which it operates were identified, reported changes were evaluated by the appropriate stakeholders for their impact,	No exceptions noted

	jurisdictions in which it operates. Reported changes are evaluated by personnel within the General Counsel's Office for their impact, and the evaluations are communicated to senior management and are incorporated into the risk assessment and review process. Related Security Document: Sec-220. AccuKnox Regulatory Compliance Policy	and the evaluations were communicated to the senior management and incorporated into the risk management. Obtained the monthly reports of changes in laws and regulations received from the external reporting service. For a sample of changes reported, obtained the evaluation of the changes by General Counsel Office personnel and the communication of the evaluation to senior management to determine whether the changes assessed for their impact on the AccuKnox system. Inspected AccuKnox Security Risk Management Policy and Process documentation of the use of the evaluation in the annual risk assessment reviews. Inspected documentation for two of the three quarterly reviews of the risk assessment to determine whether the reviews included evaluation of identified changes in laws and regulations and changes to contractual commitments	
--	---	---	--

Trust Services Criteria

CC3.2	The entity <u>identifies</u> risks to the achievement of its objectives across the entity and <u>analyzes</u> risks as a basis for determining how the risks should be managed		
CC3.2	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC3.2.1	<u>Identifying and assessing risk at the entity, subsidiary, division, operating unit, and functional levels relevant to the achievement of objectives</u> A company-wide risk assessment is performed annually by management and includes the following: - Determining business objectives, entity, subsidiary, division, operating unit, and functional levels. - Evaluating the effect of environmental, regulatory, and technological changes on AccuKnox's system security - Involving appropriate levels of management. - Analyzing risks associated with the threats - Identifying threats to operations, including security threats, using information technology asset records - Identifying threats to operations, including threats from vendors, business partners, and other parties. - Determining a risk mitigation strategy	Inspected AccuKnox Security Risk Management Policy and Process to determine that the organization identified and required risk management and assessment at all organization levels to achieve its objectives. Inspected the annual risk assessment documentation to determine whether the risk assessment was performed, and the process included consideration of AccuKnox's objectives, service commitments, and system requirements. Inspected a sample of minutes from monthly Security Steering Committee meetings to determine whether organizational strategy and operations, financial results, and risk considerations critical to the business were discussed.	No exceptions noted

CC3.2	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
	Monthly, AccuKnox's Security Steering Committee meets to discuss strategy and operations, financial results, risk considerations, and other factors critical to the business. Related Security Document: Sec-104. AccuKnox Information Security Steering Committee Organization Chart & Charter Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process		
CC3.2.2	Analyzing Internal and External Factors AccuKnox risk identification considers both internal and external factors and their impact on the achievement of objectives. An annual risk assessment is performed to identify and analyze risks arising from external and internal sources, and the report is shared with executive management and the audit committee. Related Security Document: Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process	Inspected AccuKnox Security Risk Management Policy and Process to determine that the organization as part of the risk assessment process, identified both internal and external factors and their impact on the security of the organization. Inspected the annual risk assessment to determine whether risks arising from external and internal sources and the effectiveness of controls to mitigate those risks were identified and communicated to the security steering committee.	No exceptions noted
CC3.2.3	Involving Appropriate Levels of Management AccuKnox puts into place effective risk assessment mechanisms that involve appropriate levels of management, including Information Security, IT, Human Resources, Development, Legal, and others as needed. An overview of the annual risk assessment is also presented to the security steering committee and the executive management. Related Security Document: Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process	Inspected a sample of minutes and meeting agendas from the security steering committee meetings to determine whether an overview of the risk assessment was communicated to the executive management. Inspected Information Security Steering committee chart to determine that representatives from appropriate levels of management were included.	No exceptions noted
CC3.2.4	Estimating Significance of Risks Identified Identified risks are analyzed, and the potential significance of the risk are estimated through a process that includes: - determining the criticality of identified assets in meeting objectives; - assessing the impact of identified threats and vulnerabilities in meeting objectives; - assessing the likelihood of identified threats; and - determining the risk associated with assets based on asset criticality, threat impact, and likelihood.	Inspected a sample of minutes and meeting agendas from monthly information security team meetings to determine whether security risks and vulnerabilities were identified, assessed, analyzed, and the risk impacts were estimated according to AccuKnox's Security risk Management Policy and the process by the management	No exceptions noted

CC3.2	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
	The information security team assess and responds to security risks on an ongoing basis through regular management meetings with IT personnel, reviewing and acting upon security event logs, performing vulnerability assessments, and conducting a formal annual IT risk assessment in conjunction with the company-wide risk assessment. Related Security Document: Sec-101- AccuKnox Information Security Management Plan Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process		
CC3.2.5	Determining How to Respond to Risks AccuKnox Security Risk assessment includes considering how the risk should be managed and whether to accept, avoid, reduce, or share the risk. Related Security Document: Sec-110- AccuKnox Asset Management Policy & Process	Reviewed AccuKnox Security Risk Management Policy and Procedures to determine whether the risks are responded to and managed according to the defined categories based on their adverse impact on the organization.	No exceptions noted
CC3.2.6	Identifying and Assessing Criticality of Information Assets and identification of Threats and Vulnerabilities AccuKnox's risk identification and assessment process include: 1- identifying information assets, including physical devices and systems, virtual devices, software, data and data flows, external information systems, and organizational roles; 2- assessing the criticality of those information assets; 3- identifying the threats to the assets from intentional (including malicious) and unintentional acts and environmental events; 4- identifying the vulnerabilities of the identified assets. AccuKnox has a defined information classification scheme for the labeling and handling of data and classifies data into four levels: public, internal use, confidential, and protected. Related Security Document: Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process Sec-111- AccuKnox Information Classification and Handling Policy	Inspected the data classification policy to determine whether there is a documented classification scheme for labeling and handling data. For a sample of data files and databases, obtained the relevant data dictionary and compared the data classification per the contents of the data dictionary, the data classification scheme, and the data classification of the file/database.	No exceptions noted
CC3.2.7	Analyzing Threats and Vulnerabilities from Vendor Business Partners and Other Parties AccuKnox's vendor risk assessment process includes the analysis of potential threats and vulnerabilities arising from vendors providing goods	Inspected AccuKnox's Third-Party/Vendor Security Risk Management Policy and Process to determine whether the vendor risk assessment process includes the analysis of potential threats and vulnerabilities arising from vendors providing services are included.	No exceptions noted

CC3.2	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
	and services, as well as threats and vulnerabilities arising from business partners, customers, and others with access to AccuKnox's information systems. Activities are performed Prior to and during the acquisition or outsourcing of services. Related Security Document: Sec-106- AccuKnox Third Party / Vendor Security Risk Management Policy & Process Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process	Inspected the annual risk assessment and a sample of completed vendor questionnaires during the calendar year to determine whether an organizational assessment of risk was performed prior to the acquisition or outsourcing of dedicated information security services.	

Trust Services Criteria			
CC3.3	The entity considers the potential for fraud in assessing risks to the achievement of objectives.		
CC3.3	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC3.3.1	Considering Various Types of Fraud AccuKnox's assessment of fraud considers fraudulent reporting, possible loss of assets, and corruption resulting from the various ways that fraud and misconduct can occur. Management conducts a periodic fraud risk assessment to identify the various ways that fraud and misconduct can occur, including how management might engage in inappropriate actions, and maintains documentation of this assessment. Related Security Document: Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process	Inspected AccuKnox Security Risk Management Policy and Procedures for inclusion of the fraud risk assessment to determine whether management periodically evaluated and assessed the various ways fraud and misconduct can occur and that documentation of the assessment was maintained.	No exceptions noted
CC3.3.2	Assessing Incentives and Pressures AccuKnox's assessment of fraud risks considers incentives and pressures. AccuKnox has established measures to protect against the unauthorized and willful acquisition, use, or disposal of assets. Related Security Document: Sec-110. AccuKnox Asset Management Policy & Process Sec-111. AccuKnox Information Classification and Handling Policy Sec-113. AccuKnox Media Handling and Security Policy Sec-114. AccuKnox Data Disposal and Sanitization Policy Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process	Inspected AccuKnox Security Risk Management Policy and Procedures for inclusion of the fraud risk assessment to determine whether measures were established to protect against the unauthorized and unwell acquisition, use, or disposal of assets.	No exceptions noted
CC3.3.3	Assessing Opportunities The assessment of fraud risk considers opportunities for unauthorized acquisition, use, or disposal of assets, altering the entity's reporting records, or committing other inappropriate acts. Management uses information technology tools, including security systems, fraud detection and monitoring systems, and incident tracking systems to identify and manage fraud risk. Related Security Document:	Inspected AccuKnox Security Risk Management Policy and Procedures for inclusion of the fraud risk assessment to determine whether management considered threats and vulnerabilities from the use of IT and access to information.	No exceptions noted

CC3.3	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
	Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process		
CC3.3.4	Assessing Attitudes and Rationalizations The assessment of fraud risk considers how management and other personnel might engage in or justify inappropriate actions. Related Security Document: Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process	Inspected AccuKnox Security Risk Management Policy and Procedures for inclusion of the fraud risk assessment to determine whether management and other personnel might engage in or justify inappropriate actions	No exceptions noted
CC3.3.5	Considering the Risks Related to the Use of IT and Access to Information The assessment of fraud risks includes consideration of threats and vulnerabilities that arise specifically from the use of IT and access to information. Related Security Document: Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process	Inspected AccuKnox Security Risk Management Policy and Procedures for inclusion of the fraud risk assessment to determine whether management considered threats and vulnerabilities that arise specifically from the use of IT and access to information.	No exceptions noted

Trust Services Criteria			
CC3.4	The entity identifies and assesses changes that could significantly impact the system of internal control.		
CC3.4	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC3.4.1	Assessing Changes in the External Environment AccuKnox's risk identification process considers changes to the regulatory, economic, and physical environment in which the entity operates AccuKnox, through its ongoing annual risk assessment process, evaluates changes in: - the regulatory, economic, and physical environment in which AccuKnox operates. - The business environment, including industry, competitors, regulatory environment, and consumers. - The potential impact of new business lines, dramatically altered business lines, acquired or divested business operations on the system of internal control, rapid growth, changing reliance on foreign geographies, and new technologies. - The management and respective attitudes and philosophies on the system of internal control. - AccuKnox's systems and changes in the technology environment. - Vendor and business partner relationships Related Security Document: Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process Sec-166. AccuKnox Change Management Policy & Process	Inspected the annual risk assessment documentation to determine that management identified the need for new controls to address risks that were not adequately addressed by existing controls. Inspected a sample of system change requests to determine that management followed the change management process for new controls identified.	No exceptions noted
CC3.4.2	Assessing Changes in the Business Model AccuKnox considers the potential impacts of new business lines, dramatically altered compositions of existing business lines, acquired or divested business operations on the system of internal control, rapid growth, changing reliance on foreign geographies, and new technologies. Related Security Document: Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process Sec-166. AccuKnox Change Management Policy & Process	Inspected the annual risk assessment documentation to determine that management identified the need for new controls to address risks that were not adequately addressed by existing controls in the business model. Inspected a sample of system change requests to determine that management followed the change management process for new controls identified.	No exceptions noted

CC3.4	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC3.4.3	Assessing Changes in Leadership AccuKnox considers changes in management and respective attitudes and philosophies on the system of internal control. Related Security Document: Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process Sec-166. AccuKnox Change Management Policy & Process	Inspected the annual risk assessment documentation to determine that management identified the need for new controls to address risks that were not adequately addressed by existing controls in the management changes. Inspected a sample of system change requests to determine that management followed the change management process for new controls identified.	No exceptions noted
CC3.4.4	Assessing Changes in Systems and Technology AccuKnox's risk identification process considers changes arising from changes in the entity's systems and changes in the technology environment. Related Security Document: Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process Sec-166. AccuKnox Change Management Policy & Process	Inspected the annual risk assessment documentation to determine that management identified the need for new controls to address risks that were not adequately addressed by existing controls in the systems and technology. Inspected a sample of system change requests to determine that management followed the change management process for new controls identified.	No exceptions noted
CC3.4.5	Assessing Changes in Vendor and Business Partner Relationships The risk identification process considers changes in vendor and business partner relationships. Related Security Document: Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process Sec-166. AccuKnox Change Management Policy & Process Sec-106. AccuKnox Third Party / Vendor Security Risk Management Policy & Process	Inspected the annual risk assessment documentation to determine that management identified the need for new controls to address risks that were not adequately addressed by existing controls in the vendor and business partner relationship. Inspected a sample of system change requests to determine that management followed the change management process for new controls identified.	No exceptions noted

4.4. CC4.0 - Monitoring Activities

Trust Services Criteria			
CC4.1	The entity selects, develops, and performs ongoing and/or <u>separate evaluations</u> to ascertain whether the components of internal control are present and functioning.		
CC4.1	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC4.1.1	Considering a Mix of Ongoing and Separate Evaluations AccuKnox management includes a balance of ongoing and separate evaluations. The internal audit and information security department perform periodic audits to include information security assessments. A separate third-party assessment is performed on an annual basis. Related Security Document: Sec-221- AccuKnox Internal Audit Policy & Process	Inspected the internal audit plan for the calendar year and noted it included information security assessments. Inspected AccuKnox's annual SOC 2 Reports performed by external organizations.	No exceptions noted
CC4.1.2	Considering Rate of Change AccuKnox management considers the rate of change in business and business processes when selecting and developing ongoing and separate evaluations. Internal audit annual plans include a risk analysis of all significant operating and reporting areas of AccuKnox as a means to prioritize audit efforts for the year. Related Security Document: Sec-221- AccuKnox Internal Audit Policy & Process	Inspected the internal audit plan and risk analysis documentation and noted that the significant operating and reporting areas of AccuKnox were assessed to prioritize audit efforts for the year.	No exceptions noted
CC4.1.5	Establishing Baseline Understanding AccuKnox's design, development, and the current state of the internal control system are used to establish a baseline for ongoing and separate evaluations. AccuKnox develops, documents, and maintains a baseline configuration of the internal control system. Related Security Document: Sec-221- AccuKnox Internal Audit Policy & Process	Inspected AccuKnox Information Security Management Plan and the baseline configuration documentation and noted that the design and current state of the internal control system adopted from the SOA baseline was used to establish a baseline for ongoing and separate evaluations	No exceptions noted

CC4.1	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC4.1.6	Using Knowledgeable Assessor Personnel AccuKnox's evaluators performing ongoing and separate evaluations have sufficient knowledge to understand what is being evaluated. AccuKnox provides training, as well as annual performance reviews for internal audit and information security personnel. Related Security Document: Sec-203- AccuKnox Security Awareness Training & Education Policy	Obtained the dates of and attendance sheets for the annual training, as well as the annual performance reviews for internal audit and information security personnel. Determined whether employees had signed the attendance sheet for training sessions and updates on the specified dates.	No exceptions noted
CC4.1.7	Integration of Ongoing Evaluation of the Audit Plan with Business Processes AccuKnox's ongoing evaluations of the audit and assessment plans are built into the business processes and adjust to changing conditions. On an annual basis, an internal audit performs an assessment of the audit plan and scope to identify potential changes impacting AccuKnox's risk profile Related Security Document: Sec-221- AccuKnox Internal Audit Policy & Process Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process Sec-101- AccuKnox Information Security Management Plan	Inspected the annual internal audit and assessment plans and noted that the ongoing plans are adjusted with the business processes and changing conditions.	No exceptions noted
CC4.1.8	Adjusting Scope and Frequency of Assessment AccuKnox management adjusts the scope and frequency of separate evaluations depending on risk as needed Related Security Document: Sec-221- AccuKnox Internal Audit Policy & Process Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process	Inspected the annual internal audit and assessment plans and noted that the internal audit scope and frequency were assessed to identify potential changes impacting AccuKnox's risk profile.	No exceptions noted
CC4.1.9	Evaluating Objectively Separate evaluations are performed periodically to provide objective feedback. Internal audit personnel perform audit procedures using a formal methodology, document their procedures and results in working papers, and prepare an audit report summarizing the procedures performed and the findings from those procedures.	Inspected internal audit methodology and ascertained that the methodology, including requirements for planning, execution, and reporting, and based on standards established by a professional organization. For AccuKnox's internal audit, inspected documentation and ascertained that the documentation complied with the defined methodology.	No exceptions noted

CC4.1	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
	AccuKnox's Security Steering Committee reviews reports from assessors or other third parties to determine whether they indicate possible deficiencies in internal control. Related Security Document: Sec-221- AccuKnox Internal Audit Policy & Process Sec-220. AccuKnox Regulatory Compliance Policy Sec-104- AccuKnox Information Security Steering Committee Organization Chart & Charter	Separate assessments (SOC 2) are performed by external service organizations to provide objective feedback to AccuKnox's management.	
CC4.1.10	Considering Mix of Control Activity Types Internal audit developed audit programs that include a mix of manual and automated controls, as well as preventive and detective controls, to mitigate risks identified during the risk assessment process. Related Security Document: Sec-221- AccuKnox Internal Audit Policy & Process Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process	Inspected a sample of audit programs during the calendar year to determine whether control activities to mitigate identified risks included a mix of manual, automated, detective, and preventive controls.	No exceptions noted
CC4.1.11	Involving Various Levels of Management Internal audit developed audit programs that include various levels of management. Related Security Document: Sec-221- AccuKnox Internal Audit Policy & Process	Inspected a sample of audit programs during the calendar year to determine whether control activities applied various levels of management, including IT, Development, Information Security, DevOps, and Human Resources.	No exceptions noted
CC4.1.12	Considering Different Types of ongoing and Separate Evaluations Management uses a variety of different types of ongoing and separate evaluations, including penetration testing, independent certification made against established specifications (for example, SOC 2 and ISO certifications), and internal audit assessments.	Inspected a sample of audit and assessment programs during the calendar year to determine whether control activities to mitigate identified risks included a mix of ongoing and separate evaluations. AccuKnox's security risk assessment, internal audit, and SOC 2 evaluations are performed on an annual basis or as needed.	No exceptions noted

Trust Services Criteria			
CC4.2	The entity evaluates and communicates <u>internal control deficiencies</u> in a timely manner to those parties responsible for taking corrective action, including senior management and the board of directors, as appropriate.		
CC4.2	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC4.2.1	Assessing Results Information security and the management, as appropriate, assess results of ongoing and separate evaluations. Complete reports of deficiencies in internal control from internal and external sources are reviewed and analyzed by information security and the security steering committee. Information security and the committee work with management to suggest appropriate remediation and follow-up to ensure that proper controls have been established. Related Security Document: Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process Sec-104. AccuKnox Information Security Steering Committee Organization Chart & Charter	Inspected minutes from the information security group and security steering committee meeting and reports to determine whether deficiencies in internal control and external sources were reviewed, analyzed, and followed up.	No exceptions noted
CC4.2.2	Communicating Deficiencies AccuKnox has established a practice that requires all deficiencies rated as serious threats to be reported to senior management and to the security steering committee, as appropriate. Related Security Document: Sec-101. AccuKnox Information Security Management Plan Sec-221. AccuKnox Internal Audit Policy & Process	Inspected minutes from the security steering committee meeting to determine whether the committee reported deficiencies rated as serious threats to the board.	No exceptions noted
CC4.2.3	Monitoring Corrective Action The management or security steering committee tracks the status of all deficiencies that have been rated as a serious threat to the organization until satisfactorily resolved. Related Security Document: Sec-104. AccuKnox Information Security Steering Committee Organization Chart & Charter	Inspected the deficiency tracking matrix to determine whether deficiencies rated as serious threats to the organization were tracked to resolution by the board and/or security steering committee.	No exceptions noted

4.5. CC5.0 - Control Activities

Trust Services Criteria			
CC5.1	The entity selects and develops <u>control activities</u> that contribute to the mitigation of risks to the achievement of objectives to acceptable levels.		
CC5.1	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC5.1.1	Integrating Control Activities with Risk Assessment AccuKnox carries out the control activities that contribute to the mitigation of the identified risks. As part of the annual risk assessment, AccuKnox's management links the identified risks to controls that have been designed and operated to address them. When the need for new controls is identified, the management develops the requirements for the new controls and uses the change management process to implement them. Related Security Document: Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process Sec-101. AccuKnox Information Security Management Plan	Inspected AccuKnox Information Security System Management Plan to obtain the list of controls and determine whether the control activities were integrated with AccuKnox's risk assessment. Obtained and inspected the annual risk assessment documentation to determine that new controls were implemented for any risks not adequately addressed by existing controls. Inspected a sample of system change requests to determine that the change management process was followed for the implementation of the newly identified controls.	No exceptions noted
CC5.1.2	Considering Entity Specific Factors AccuKnox's management considers how some factors such as the environment, complexity, nature, and scope of its operations, as well as the specific characteristics of its organization, affect the selection and development of control activities. These factors are considered as part of the risk assessment, where the management assesses the environment, complexity, nature, and scope of its operations when developing control activities to mitigate the risks. Related Security Document: Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process	Obtained and inspected the risk assessment documentation to determine whether management assessed the environment, complexity, nature, and scope of its operations when developing control activities to mitigate the risks.	No exceptions noted
CC5.1.3	Determining Relevant Business Processes when Selecting Controls AccuKnox's management determines, based on the risk level, which relevant business processes require control activities. Related Security Document:	Inspected AccuKnox Information Security Management Plan to obtain the list of controls and determine whether the control activities were relevant and applicable to the AccuKnox business processes and security requirements based on FIPS-200.	No exceptions noted

	Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process Sec-101. AccuKnox Information Security Management Plan	Obtained and inspected the risk assessment documentation to determine whether management assessed the risk to business processes when developing control activities to mitigate the risks.	
CC5.1.4	Evaluating a Mix of Control Activity Types AccuKnox's control activities include a range and variety of controls and may include a balance of approaches to mitigate risks, considering both manual and automated controls and preventive and detective controls. Related Security Document: Sec-101. AccuKnox Information Security Management Plan	Obtained and inspected the risk assessment documentation to determine whether management considered a mix of control activities to mitigate the identified risks. Inspected a sample of audit programs during the calendar year to determine whether control activities to mitigate identified risks included a mix of manual, automated, detective, and preventive controls.	No exceptions noted
CC5.1.5	Considering at What Level Activities Are Applied AccuKnox management considers control activities at various levels in the organization. Related Security Document: Sec-101. AccuKnox Information Security Management Plan	Inspected a sample of audit programs and risk management during the calendar year to determine that AccuKnox's management considers control activities at various levels in the organization, including management, legal, development, engineering, human resources, and facilities. IT, and information security.	No exceptions noted
CC5.1.6	Addressing Segregation of Duties AccuKnox's management segregates incompatible duties, and where such segregation is not practical, management selects and develops alternative control activities. Related Security Document: Sec-130. AccuKnox Access Control Policy and Process	Obtained and inspected AccuKnox Access Control Policy and Procedures to determine whether segregation of duties was addressed and where such segregation was not practical; management selected and developed alternative control activities. Inspected the organizational chart of AccuKnox, noting the organizational chart described functional areas and reporting structures within functional areas and that the reporting hierarchy was defined and appropriately segregated.	No exceptions noted

Trust Services Criteria			
CC5.2	The entity also selects and develops <u>general control activities</u> over technology to support the achievement of objectives.		
CC5.2	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC5.2.1	Determining Dependency Between the Use of Technology in Business Processes and Technology General Controls AccuKnox's management understands and determines the dependency and linkage between business processes, use of technologies (i.e. IT, virtualization, network infrastructure, operating systems, etc.), and related technology controls. As part of the IT strategic plan, AccuKnox identifies strategic IT risks affecting the organization and recommends courses of action and selection of control activities over technology to support the business objectives. Related Security Document: Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process	Inspected the annual IT strategic plan and security management documentation to determine whether the use of technology (IT, network infrastructure, operating systems) risks affecting the organization, and recommended courses of action were identified and discussed.	No exceptions noted
CC5.2.2	Establishing Relevant Technology Infrastructure Control Activities AccuKnox management selects and develops a list of control activities over the technology infrastructure (i.e. IT, virtualization, network infrastructure, operating systems, etc.), which are designed and implemented to help ensure the completeness, accuracy, and availability of technology processing. Related Security Document: Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process	Inspected documents related to risk assessment, internal audit plan, network diagram, network security, firewall, access control, identification and authentication, and audit program for the calendar year to determine whether management developed and implemented control activities over the technology infrastructure.	No exceptions noted
CC5.2.3	Establishing Relevant Security Management Process Controls Activities AccuKnox management selects and develops control activities over security management process that are designed and implemented to restrict technology access rights to authorized users commensurate with their job responsibilities and to protect the entity's assets from internal and external threats. Related Security Document: Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process Sec-130. AccuKnox Access Control Policy and Process	Inspected the risk assessment, internal audit plan, and audit program for the calendar year to determine whether management developed and implemented control activities related to the security management process to restrict technology access rights to authorized users commensurate with their job responsibilities and protect corporate assets from internal and external threats.	No exceptions noted

CC5.2	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC5.2.4	Establishing Relevant Technology Acquisition, Development, and Maintenance Process Control Activities AccuKnox management selects and develops strategies, methods, and control activities over the acquisition, development, and maintenance of technology, its infrastructure, and information system services from technology suppliers to achieve management's objectives. Related Security Document: Sec-106- AccuKnox Third Party / Vendor Security Risk Management Policy & Process	Inspected the procurement policy manual to determine whether management employed acquisition strategies and procurement methods for the purchase, development, and maintenance of information systems, system components, or information system services from technology suppliers.	No exceptions noted

Trust Services Criteria			
CC5.3	The entity deploys control activities through policies that establish what is expected and in procedures that put policies into action.		
CC5.3	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC5.3.1	Establishing Policies and Procedures to Support the Development of Management's Directives AccuKnox's management establishes control activities that are built into business processes and employees' day-to-day activities through policies establishing what is expected and relevant procedures specifying actions. AccuKnox's policy and procedure manuals address controls over significant aspects of operations. Policy sections include: a. security requirements for authorized users; b. data classification and associated protection, access rights, retention, and destruction requirements; c. risk assessment; d. access protection requirements; e. user provisioning and de-provisioning; f. responsibility and accountability for security; g. responsibility and accountability for system changes and maintenance; h. change management; i. complaint intake and resolution; j. security and other incidents identification, response, and mitigation; k. security training; l. handling of exceptions and situations not specifically addressed in policies; m. commitment and requirement identification and compliance measurement; and n. information sharing and disclosure. Related Security Document: Sec-102- AccuKnox Information Security Document Management (Policy, Standards, Process, Artifacts)	Inspected the policy manuals to determine whether the management establishes, maintains, and enforces the overall security policies and the organization's directives. Inspected AccuKnox Information Security Document Management (Policy, Standards, Process, Artifacts) to determine that policy documents were reviewed, changes were made as needed, and maintained annually.	No exceptions noted
CC5.3.2	Establishing Responsibility and Accountability for Executing Policies and Procedures AccuKnox's management establishes responsibility and accountability for control activities with management (or other designated personnel) of the business unit or function in which the relevant risks reside. Related Security Document:	Inspected the policy and procedure manuals to determine whether roles and responsibilities were identified and established. Inspected a sample of minutes from quarterly Security Steering Committee meetings to determine whether the information security and the steering committee were charged with	No exceptions noted

Section IV - Trust Services Criteria, AccuKnox Implementation of Controls, and Test Results

	Sec-102- AccuKnox Information Security Document Management (Policy, Standards, Process, Artifacts) Sec-104- AccuKnox Information Security Steering Committee Organization Chart & Charter	establishing, maintaining, and enforcing the overall security policies and procedures.	
CC5.3.3	Performing Control Activities in a Timely Manner AccuKnox's responsible personnel perform control activities in a timely manner as required by the policies and procedures. Monthly service level assessments are performed by the functional heads of each department. These assessments include evaluation of the operation of key controls in a timely manner as defined in the policy and procedures as well as assignments to individuals.	Inspected a sample of minutes from monthly departmental and management committee meetings to determine whether the evaluation of the operation of key controls was performed by department heads.	No exceptions noted
CC5.3.4	Taking Corrective Action AccuKnox's responsible personnel investigate and act on matters identified as a result of executing control activities. Assessments are reviewed at monthly departmental meetings and require the development of corrective action plans for addressing the weaknesses.	Inspected a sample of minutes from monthly departmental and management committee meetings to determine whether the corrective action plans for control weaknesses were reviewed by department heads and the management committee.	No exceptions noted
CC5.3.5	Performing Control Activities Using Competent Personnel AccuKnox's competent personnel with sufficient authority perform control activities with diligence and continuing focus. AccuKnox has written job descriptions specifying the responsibilities and the academic and professional requirements for key job positions. Human Resources personnel screen internal and external job applicants' qualifications based on the defined requirements within the job description. Transcripts are obtained to evidence educational attainment, and job references are checked to validate the experience. Related Security Document: Sec-201- AccuKnox Human Resources Security Management Policy Sec-201- AccuKnox Background Screening Policy & Standard Sec-201- AccuKnox Employee & Contractor Onboarding, Change and Termination Policy & Process	For a sample of positions, inspected written job descriptions to determine whether the job descriptions included responsibilities and academic and professional requirements. For a sample of employees, inquired of the employees about their understanding of their job responsibilities, academic qualifications, and professional certifications and compared their responses for consistency to the documented responsibilities and academic and professional requirements documented in the job description applicable to their position. For a sample of new employees and employees who have transferred internally, inspected the personnel file to determine whether transcripts were obtained and job references were checked.	No exceptions noted
CC5.3.6	Reassessing Policies and Procedures AccuKnox's management (security steering committee and security officer) periodically review control activities, policy and procedure manuals for their continued relevance and consistency with the	Inspected the policy and procedure manuals to ascertain whether policies and procedures had been updated for changes in the risk mitigation strategy.	No exceptions noted

	organization's risk mitigation strategy and update them as necessary for changes in the strategy. Related Security Document: Sec-102: AccuKnox Information Security Document Management (Policy, Standards, Process, Artifacts)	Inspected documentation of the annual review of the policy and procedures manuals by the Information Security Officer. Inspected a sample of minutes from quarterly Security Steering Committee meetings to determine whether the information security and the steering committee were charged with reviewing control activities, policies, and procedures.	
--	--	---	--

4.6. CC6.0 - Logical and Physical Access

Trust Services Criteria			
CC6.1	The entity implements <u>logical access</u> security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.		
CC6.1	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC6.1.1	Identifying and Managing the Inventory of information Assets AccuKnox identifies, inventories, classifies, monitors, and manages information assets through automated asset management. Related Security Document: Sec-110- AccuKnox Asset Management Policy & Process	Inspected AccuKnox Asset Management Policy and Procedures to determine if they include identification, inventories, classification, monitoring, and management of the information assets. Inspected the automated inventory management tool to determine that the tool is in place to monitor the system components. Inspected information system inventory records from the inventory management tool to determine that the tool was providing the necessary information to manage assets.	No exceptions noted
CC6.1.2	Restricting Logical Access Logical access to information assets, including hardware, data, software, mobile devices, output, and offline system components, is restricted through the use of access control software and rule sets. The following access controls are in place to restrict access to AccuKnox's information assets: • Network-based access control • User-based access control • Application-based access control • Remote access control AccuKnox's management performs a quarterly access review for the in-scope system components to ensure that access is restricted appropriately. Tickets are created to remove access as necessary in a timely manner. Related Security Document: Sec-130- AccuKnox Access Control Policy and Process Sec-130- AccuKnox Remote Access Policy Sec-150- AccuKnox Network Security Policy Sec-151. AccuKnox Network Segmentation Policy Sec-153- AccuKnox Firewall Management Policy Sec-154. AccuKnox Wireless Security	Inspected AccuKnox's access control policy and procedures to determine that access to the company assets was restricted to authorized personnel and processes. Inspected AccuKnox's firewall policy and Active Directory to verify the implementation of network, user, and application-based access controls.	No exceptions noted

CC6.1	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC6.1.3	User Identification and Authentication AccuKnox's persons, infrastructure, and software are identified and authenticated prior to accessing information assets, whether locally or remotely. In-scope system components require unique usernames and passwords and multi-factor authentications (or authorized SSH keys) prior to authenticating users. Related Security Document: Sec-122. AccuKnox Password Management Policy Sec-120. AccuKnox Account Management Process Sec-120- AccuKnox Identification and Authentication Management Policy & Process	Inspected AccuKnox Identification and Authentication Policy and Procedure to determine that the in-scope system components required authentication measures for users. Inspected login attempts to determine that the in-scope system components required authentication measures for users.	No exceptions noted
CC6.1.4	Segmenting Network AccuKnox implements network segmentation that permits unrelated portions of AccuKnox's information system such as end-user, servers, applications traffic to be isolated from each other. Related Security Document: Sec-150- AccuKnox Network Security Policy Sec-151. AccuKnox Network Segmentation Policy	Inspected the network diagram and configurations to determine that customer environments and data are segmented. Inspected firewall and router configuration for verification of the network segmentation	No exceptions noted
CC6.1.5	Managing Internet Points of Access AccuKnox's internet points of access by outside entities and the <u>types of data</u> that flow through the points of access are identified, inventoried, and managed. The <u>types of individuals and systems</u> using each internet point of access are identified, documented, managed, and authorized only with multi-factor authentication (MFA) over an encrypted virtual private network (VPN) connection. AccuKnox's remote access policy and procedures are in place to help ensure that confidential data is properly secured and restricted to authorized personnel. SSL certificates are used at the entry-point firewalls to information assets to establish access control rules. Related Security Document: Sec-130- AccuKnox Access Control Policy and Process Sec-130- AccuKnox Remote Access Policy	Inspected access review documentation for a sample of quarters to determine that an access review was performed for in-scope system components and that tickets were created to remove inappropriate access Inspected system-generated evidence of the use of 256-bit SSL/TLS encryption for data transmitted for remote connections via internet Point of access. Inspected System generated evidence of VPN configuration settings for the internet point of access, including evidence of: - 2-factor authentication - encrypted tunnels Observed a remote login session to determine that MFA VPN was required to access the production network	No exceptions noted

CC6.1	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC6.1.6	Restricting Access to Information Assets AccuKnox uses a combination of data classification, separate data structures, port restrictions, access protocol restrictions, user identification, access control, and digital certificates to establish access control rules for information assets. AccuKnox maintains logical instances of the applications for each client. Management performs a quarterly access review for the in-scope system components to ensure that access is restricted appropriately. Tickets are created to remove access as necessary in a timely manner. Related Security Document: Sec-130- AccuKnox Access Control Policy and Process Sec-111- AccuKnox Information Classification and Handling Policy Sec-110- AccuKnox Asset Management Policy & Process	Inspected the data classification policy to determine that procedures existed around classifying and protecting confidential information. Inspected the SSL certificates for verification, issuance, signature algorithm, and validity date. Inspected AWS Security Group configuration to determine that access to the information assets was restricted to authorized users. Inspected application instances to determine that each application instance was assigned to one customer.	No exceptions noted
CC6.1.7	Managing Identification and Authentication AccuKnox has established, documented, and managed identification and authentication requirements for individuals and systems accessing AccuKnox's information, infrastructure, and software. Requirements are identified via AccuKnox's Password Management Policy and Procedure, Account Management, Identification and Authentication Policy and Procedure, and Multifactor Authentication Related Security Document: Sec-120. AccuKnox Account Management Process Sec-122. AccuKnox Password Management Policy Sec-120- AccuKnox Identification and Authentication Management Policy & Process	Reviewed AccuKnox's Password Management Policy, Account Management Policy, and Identification and Authentication Policy to determine whether identification and authentication requirements were established and documented. Inspected in-scope system components to determine that systems were configured and managed according to company Identification and authentication policy.	No exceptions noted
CC6.1.8	Managing Credentials for Infrastructure and Software All AccuKnox's internal and external infrastructure and software are registered, authorized, and documented prior to being granted access credentials and implemented on the network or access point. Credentials are removed, and access is disabled when access is no longer required, or the infrastructure and software are no longer in use. Credentials are issued and managed based on AccuKnox's Identification and Authentication Policy and Password Policy.	Reviewed AccuKnox Identification and Authentication Policy and Procedures and inspected credentials for a sample of systems to determine that systems were configured and managed according to the policy.	No exceptions noted

CC6.1	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
	Related Security Document: Sec-120. AccuKnox Account Management Process Sec-122. AccuKnox Password Management Policy Sec-120. AccuKnox Identification and Authentication Management Policy & Process		
CC6.1.9	Using Encryption to Protect Data AccuKnox uses encryption to supplement other measures used to protect data-at-rest when such protections are deemed appropriate based on assessed risk. Related Security Document: Sec-171. AccuKnox Encryption & Key Management Standard	Inspected the configuration for the encryption process to determine that encryption activities use an acceptable cryptographic algorithm. Inspected database configurations to determine that databases were encrypted at rest. Inspected wireless access in the company offices to determine that they were secured by WPA2 encryption or better Inspected system-generated evidence of the use of 256-bit SSL/TLS encryption for data transmitted between the application and the client's host systems.	No exceptions noted
CC6.1.10	Protecting Encryption Keys Processes are in place to protect encryption keys during generation, storage, use, and destruction. Related Security Document: Sec-171. AccuKnox Encryption & Key Management Standard	Inspected AccuKnox Encryption and Key Management Standard to determine whether the encryption key protection is included. This control is inherited from the cloud service provider.	No exceptions noted

Trust Services Criteria			
CC6.2	Prior to issuing system credentials and granting system access, the entity registers and authorizes new internal and external users whose access is administered by the entity. For those users whose access is administered by the entity, user system credentials are removed when user access is no longer authorized		
CC6.2	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC6.2.1	Assigning Access Credentials AccuKnox creates information asset access credentials based on authorization from the system's asset owner or authorized custodian. Access to in-scope system components requires a documented access request form and manager approval prior to access being provisioned. Related Security Document: Sec-120. AccuKnox Account Management Process	Inspected access request forms for a sample of new hires that received access to the in-scope system components to determine that an access provisioning request was approved prior to access being provisioned.	No exceptions noted
CC6.2.2	Removal of Access Credential Per AccuKnox's Account Management Policy and Processes, credential access is removed when an individual no longer requires such access. A termination checklist is completed, and access is revoked for employees within 24 hours as part of the termination process. Related Security Document: Sec-120. AccuKnox Account Management Process	Inspected a listing of terminated employees and compared the listing to the active user listing to determine that terminated employees did not retain access to the in-scope system and platforms after their separation. Inspected termination tickets for a sample of terminated employees during the review period to determine that access was revoked within 24 hours as a part of the termination process.	No exceptions noted
CC6.2.3	Review of Access Credential The appropriateness of access credentials is reviewed on a periodic basis for unnecessary and inappropriate individuals with credentials. AccuKnox's management performs a quarterly access review for the in-scope system components to ensure that access is restricted appropriately. Tickets are created to remove access as necessary in a timely manner. Related Security Document: Sec-120. AccuKnox Account Management Process	Inspected access review documentation for a sample of quarters to determine that an access review was performed for in-scope system components and that tickets were created to remove inappropriate access.	No exceptions noted

Trust Services Criteria			
CC6.3 The entity authorizes, modifies, or removes access to data, software, functions, and other protected information assets based on roles, responsibilities, or the system design and changes, giving consideration to the concepts of least privilege and segregation of duties to meet the entity's objectives.			
CC6.3	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC6.3.1	Creation or Modification of Access to Protected Information Assets Processes are in place to create or modify access to protected information assets based on an authorization from the asset's owner based on the following AccuKnox's Policies: • Sec-130 · AccuKnox Access Control Policy and Process • Sec-130 · AccuKnox Remote Access Policy • Sec-130 · AccuKnox Access Review Policy & Process • Sec-130. AccuKnox 3rd Party Access Control Policy • Sec-130 · AccuKnox Application Access Control Policy & Process Related Security Document: Sec-120. AccuKnox Account Management Process	Reviewed policies and procedures, interviewed asset owners, and inspected documentation to determine that appropriate procedures were in place to assign or modify access to protected information assets as needed. Inspected creation tickets for a sample of new hires during the review period to determine that access and access provisioning request was approved by the asset owner prior to access being provisioned.	No exceptions noted
CC6.3.2	Removal of Access to Protected Information Assets Processes are in place to remove access to protected information assets when an individual no longer requires access based on the following AccuKnox's policies: • Sec-130 · AccuKnox Access Control Policy and Process • Sec-130 · AccuKnox Remote Access Policy • Sec-130 · AccuKnox Access Review Policy & Process • Sec-130. AccuKnox 3rd Party Access Control Policy • Sec-130 · AccuKnox Application Access Control Policy & Process A termination checklist is completed, and access is revoked for employees within 24 hours as part of the termination process. Related Security Document: Sec-130 · AccuKnox Access Control Policy and Process Sec-130 · AccuKnox Application Access Control Policy & Process Sec-130 · AccuKnox Remote Access Policy Sec-130 · AccuKnox Access Review Policy & Process Sec-130. AccuKnox 3rd Party Access Control Policy	Reviewed policies and procedures, interviewed asset owners, and inspected documentation to determine that appropriate procedures are in place to remove access when an individual no longer requires access. Inspected a listing of terminated employees and compared the listing to the active user listing to determine that terminated employees did not retain access to the in-scope system and platforms after their separation. Inspected termination tickets for a sample of terminated employees during the review period to determine that access was revoked within 24 hours as a part of the termination process.	No exceptions noted

CC6.3	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC6.3.3	Use of Role-Based Access Controls AccuKnox establishes and administers privileged user accounts in accordance with a role-based access scheme that organizes information system and network privileges into roles and utilizes role-based access control to support segregation of incompatible functions. Related Security Document: Sec-120. AccuKnox Account Management Process	Inspected the access control policy to determine that the role-based access scheme was employed to organize information system and network privileges into roles. Inspected List of users with access to Applications, Servers, Networks, Database, VPN, and AWS to determine their privileges in accordance with the defined role-based schemes.	No exceptions noted
CC6.3.4	Tracking and Monitoring Privileged Roles AccuKnox's asset owners and custodians review, track, and monitor privileged role assignments on a continuous basis to ensure that access is restricted appropriately. Tickets are created to remove access as necessary in a timely manner. Related Security Document: Sec-120. AccuKnox Account Management Process Sec-120. AccuKnox Identification and Authentication Management Policy & Process	Reviewed policies and procedures, interviewed asset owners, and inspected documentation to determine that appropriate procedures were in place to track and monitor privileged roles.	No exceptions noted

Trust Services Criteria			
CC6.4	The entity restricts <u>physical access to facilities and protected information assets (for AccuKnox, data center facilities, backup media storage, and other sensitive locations)</u> to authorized personnel to meet the entity's objectives.		
CC6.4	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC6.4.1	<u>Creation or Modification of facilities Physical Access</u> AccuKnox's Processes are in place to create or modify physical access to facilities such as server rooms, office spaces, and work areas based on an authorization from the system's asset owner. Access to facilities requires a documented access request form and manager approval prior to access being provisioned. Related Security Document: Sec-180- AccuKnox Physical Security Policy Sec-207- AccuKnox Access Badge Assignment Procedure	Reviewed policies and procedures and inspected documentation to determine that appropriate procedures were in place to assign or modify access to AccuKnox facilities as needed. Inspected access request forms for a sample of new hires that received access to the facility to determine that an access provisioning request was approved prior to access being provisioned.	No exceptions noted
CC6.4.2	<u>Removal of Physical Access</u> Processes are in place to remove access to physical resources when an individual no longer requires access. AccuKnox's procedure requires a termination checklist to be completed and access revoked for employees within 24 hours as part of the termination process. Related Security Document: Sec-180- AccuKnox Physical Security Policy Sec-207- AccuKnox Access Badge Assignment Procedure	Inspected a listing of terminated employees and compared the listing to the active user listing to determine that terminated employees did not retain access to the facilities after their separation. Termination tickets for a sample of terminated employees during the review period to determine that access was revoked within 24 hours as a part of the termination process.	No exceptions noted
CC6.4.3	<u>Review of Physical Access</u> Processes are in place to periodically review physical access to ensure consistency with job responsibilities. Management performs a quarterly access review for facilities to ensure that access is restricted appropriately. Tickets are created to remove access as necessary in a timely manner. Related Security Document: Sec-180- AccuKnox Physical Security Policy Sec-207- AccuKnox Access Badge Assignment Procedure	Inspected access review documentation for a sample of quarters to determine that an access review was performed for the facilities and that tickets were created to remove inappropriate access.	No exceptions noted

Trust Services Criteria			
CC6.5	The entity discontinues logical and physical protections over physical assets only after the ability to read or recover data and software from those assets has been diminished and is no longer required to meet the entity's objectives.		
CC6.5	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC6.5.1	Identifying Data and Software for Disposal AccuKnox's formal data retention and disposal procedures are in place to identify data and software stored on equipment to be disposed of and to render such data and software unreadable. Related Security Document: Sec-110. AccuKnox Asset Management Policy & Process Sec-111. AccuKnox Information Classification and Handling Policy Sec-113. AccuKnox Media Handling and Security Policy Sec-114. AccuKnox Data Disposal and Sanitization Policy Sec-115. AccuKnox Data Retention Policy	Inspected AccuKnox's data retention and disposal policies and procedures to determine that they include identification of data and software for disposal.	No exceptions noted
CC6.5.2	Removing Data and Software from Entity's Physical Control AccuKnox's procedures are in place for data and software stored on equipment to be removed from the physical control of the entity and to render such data and software unreadable. Formal data retention and disposal procedures are in place to guide the secure disposal of the company's and customers' data. Related Security Document: Sec-115. AccuKnox Data Retention Policy	Inspected AccuKnox's data retention and disposal policies and procedures to determine that the procedures outlined the removal of data and software for removal.	No exceptions noted

Trust Services Criteria			
CC6.6	The entity implements logical access security measures to protect against threats <u>from sources outside its system boundaries</u> .		
CC6.6	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC6.6.1	Restricting or Limiting Remote Access AccuKnox restricts remote access types and activities by the system firewalls configurations to limit unnecessary ports, protocols, and services. Related Security Document: Sec-130- AccuKnox Remote Access Policy Sec-153- AccuKnox Firewall Management Policy	Inspected AccuKnox's Remote Access Policy and Procedures to determine that remote access types and activities were restricted by the use of a firewall. Inspected the firewall configurations and rulesets employed within the environment to determine that the permit rules aligned with the specified networking protocols permitted for inbound network traffic.	No exceptions noted
CC6.6.2	Protecting Credentials During Remote Transmission AccuKnox protects Identification and authentication credentials and confidential information during transmission outside its system boundaries over public networks by the deployment of Transport Layer Security (TLS). Related Security Document: Sec-171- AccuKnox Encryption & Key Management Standard	Inspected TLS settings for remote access to determine that transmission of confidential and/or sensitive information over public networks was encrypted.	No exceptions noted
CC6.6.3	Requiring Additional Remote Authentication or Credentials AccuKnox requires additional authentication information or credentials for remote systems access to production systems by authorized employees with multi-factor authentication (MFA) over encrypted virtual private network (VPN) connection. Related Security Document: Sec-130- AccuKnox Remote Access Policy	Observed a remote login session to determine that MFA VPN was required to access the production network	No exceptions noted
CC6.6.4	Implementing Boundary Protection Systems AccuKnox implements boundary protection systems (for example, firewalls, demilitarized zones, and intrusion detection systems) to protect external access points from attempts and unauthorized access and to monitor to detect such attempts. Related Security Document: Sec-150- AccuKnox Network Security Policy	Inspected firewall and intrusion detection system configurations to determine that protection and continuous monitoring of AccuKnox's network and early prevention of potential security breaches were in place.	No exceptions noted

Trust Services Criteria			
CC6.7	The entity restricts the transmission, movement, and removal of information to authorized internal and external users and processes and protects it during transmission, movement, or removal to meet the entity's objectives.		
CC6.7	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC6.7.1	Restricting Data Transmission/Sharing AccuKnox uses data loss prevention technologies to restrict the ability to authorize and execute transmission, movement, and removal of information to unauthorized information systems and networks. Related Security Document: Sec-130- AccuKnox Access Control Policy and Process Sec-160- AccuKnox System Security Assurance and Hardening Policy	Inspected the system and communications protection policy and procedures and associated system configuration settings to determine that the information system restricts the ability of users to transmit, move, or remove system information.	No exceptions noted
CC6.7.2	Using Encryption Technologies or Securing Communication AccuKnox uses encryption technologies or secured communication channels such as VPN, SFTP, SSH to protect the transmission of data and other communications beyond connectivity access points over public networks. Related Security Document: Sec-171- AccuKnox Encryption & Key Management Standard	Inspected firewall configurations to determine that VPN, SFTP, and SSH were used for the transmission of confidential and/or sensitive information over public networks.	No exceptions noted
CC6.7.3	Protecting Removable Media AccuKnox uses encryption technologies, physical asset protections, and sanitization prior to connection for removable media (such as USB drives and backup tapes), as appropriate. Related Security Document: Sec-113- AccuKnox Media Handling and Security Policy Sec-171- AccuKnox Encryption & Key Management Standard	Inspected the information system media protection policy and procedures and media sanitization records to determine that removable media is encrypted and sanitized prior to use.	No exceptions noted
CC6.7.4	Protecting Mobile Devices AccuKnox protects authorized mobile devices that serve as information assets (such as laptops, smart phones, and tablets) access to production systems with encryption and multifactor authentication VPN connection. Related Security Document: Sec-155- AccuKnox Mobile Device Policy	Observed a remote login session to determine that MFA VPN was required to access the production network. Inspected a sample of company-issued workstations for disk encryptions.	No exceptions noted

Trust Services Criteria			
CC6.8 The entity implements controls to prevent or detect and act upon the introduction of unauthorized or malicious software to meet the entity's objectives.			
CC6.8	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC6.8.1	Restricting Application and Software Installation AccuKnox systems are configured to prevent unauthorized use and installation of applications and software. The ability to install applications and software is restricted to authorized individuals and system administrators. Unauthorized use or installation of software is explicitly covered in the employee handbook and Rules of Behavior. Related Security Document: Sec-160. AccuKnox System Security Assurance and Hardening Policy Sec-200. AccuKnox Acceptable Use Policy	Inspected the rules of behavior and the employee handbook and verified that the policies prohibit the installation of software by users, and installation is limited to system administrators. Tested a sample of systems for the installation of software and verified the inability to install unauthorized applications.	No exceptions noted
CC6.8.2	Detecting Unauthorized Changes to Software and Configuration Parameters AccuKnox has put processes in place to detect changes to software and configuration parameters that may be indicative of unauthorized or malicious software. AccuKnox Information Security monitors system logs and alerts system administrators of software installation or attempted software installation. Related Security Document: Sec-160. AccuKnox System Security Assurance and Hardening Policy Sec-167. AccuKnox Security Log & Event Management Policy	Inspected documentation describing the current configuration settings for a sample of the automated mechanisms to determine that these mechanisms are configured as required. Tested the automated mechanisms and their configuration settings by creating a simulated unauthorized installation to determine that these mechanisms were operating as intended.	No exceptions noted
CC6.8.3	Using Defined Change Control Process AccuKnox has formally documented change management procedures (including emergency procedures) that are in place to govern the modification and maintenance of production systems and address security and availability requirements. Related Security Document: Sec-166. AccuKnox Change Management Policy & Process	Inspected the change management procedures to determine that procedures were in place to govern the modification and maintenance of production systems and addressed security and availability requirements.	No exceptions noted

CC6.8	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC6.8.4	Using Antivirus and Anti-Malware Software AccuKnox implements and maintains antivirus and anti-malware to provide for the interception, detection, and remediation of malware for environments commonly susceptible to malicious attacks. The anti-malware software is used to scan assets prior to being placed into production. Related Security Document: Sec-160. AccuKnox System Security Assurance and Hardening Policy	Inspected screenshots of anti-malware software configurations (virus definition update, scan schedule, notifications, and evidence that software is deployed on all servers) to determine that anti-virus was updated routinely, logged, and installed on all production servers.	No exceptions noted
CC6.8.5	Scanning Information Assets Prior to Implementation Procedures are in place to scan information assets that have been transferred or returned to the entity's custody for malware and other unauthorized software and to remove any items detected prior to its implementation on the network. Related Security Document: Sec-160. AccuKnox System Security Assurance and Hardening Policy	Inspected system security assurance and hardening policy and procedures to determine that the transferred or returned information assets were scanned for malware prior to implementation on the network.	No exceptions noted

4.7. CC7.0 - System Operations

Trust Services Criteria			
CC7.1	The entity uses detection and monitoring procedures to identify: (1) changes to configurations that result in the introduction of new vulnerabilities, and (2) susceptibilities to newly discovered vulnerabilities.		
CC7.1	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC7.1.1	Using Defined Configuration Standards AccuKnox has defined and retained a baseline configuration within the configuration management tool for roll-back capability anytime an approved configuration change is made. Baseline configurations are reviewed and updated annually and when required due to reviews and system changes, and anytime integral system components are added. Related Security Document: Sec-160. AccuKnox System Security Assurance and Hardening Policy Sec-166. AccuKnox Change Management Policy & Process Sec-168. AccuKnox Vulnerability Management Policy Sec-169. AccuKnox Patch Management Policy & Process	Inspected the configuration management tool to determine that baseline configurations are retained and up to date for applicable system changes.	No exceptions noted
CC7.1.2	Monitoring Infrastructure and Software Compliance AccuKnox utilizes IT infrastructure monitoring tool, scanning, and logging - to collect data from system infrastructure components and endpoint systems - to monitor system performance, potential security threats and vulnerabilities, resource utilization - to detect unusual system activity or service requests, and - to generate alerts when specific predefined thresholds are met. Related Security Document: Sec-150. AccuKnox Network Security Policy Sec-162. AccuKnox Security Information and Events Monitoring Policy	Inspected IT infrastructure monitoring tool configurations and notification to determine that IT infrastructure monitoring tools were utilized to monitor IT infrastructure compliance with the standards and generated alerts when specific predefined thresholds were met. Obtained the operations log for a sample date from each sample item selected to determine whether the monitoring software was operational.	No exceptions noted
CC7.1.3	Implementing Change-Detection Mechanisms AccuKnox's IT system utilizes a configuration monitoring tool and a change-detection mechanism (for example, file integrity monitoring tools) that alerts to alert personnel to unauthorized modifications of critical system files, configuration files, or content files. Related Security Document: Sec-162. AccuKnox Security Information and Events Monitoring Policy	Inspected alert configuration settings and an AccuKnox alert to determine that a configuration monitoring tool (File Integrity Monitoring) monitored and alerted management of changes to production.	No exceptions noted

CC7.1	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC7.1.4	Detecting Unknown or Unauthorized Components AccuKnox uses automated mechanisms to continuously detect the addition of unauthorized components/devices into the system. The configuration monitoring tool logs all changes in status. Any attempt to insert or install a component immediately sends an alert to the monitoring tool and creates a ticket. Related Security Document: Sec-162. AccuKnox Security Information and Events Monitoring Policy	Inspected configuration settings for the monitoring tool to determine that the tool was configured to alert any unauthorized components.	No exceptions noted
CC7.1.5	Conducting Vulnerability Scans AccuKnox conducts vulnerability scans designed to identify potential vulnerabilities or misconfigurations on a periodic basis and after any significant change in the environment and takes action to remediate identified deficiencies on a timely basis. Related Security Document: Sec-168. AccuKnox Vulnerability Management Policy	Inspected internal and external vulnerability scans for a sample of quarters to determine that internal and external vulnerability scans were performed quarterly, and remediation plans were developed to remediate all critical and high vulnerabilities.	No exceptions noted

Trust Services Criteria			
CC7.2	The entity monitors system components and the operation of those components for anomalies that are indicative of malicious acts, natural disasters, and errors affecting the entity's ability to meet its objectives; <u>anomalies are analyzed</u> to determine whether they represent security events.		
CC7.2	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC7.2.1	Defining and Implementing Detection Policies, Procedures, and Tools AccuKnox has defined detection policies and procedures and implanted tools on infrastructure and software to identify anomalies in operation or unusual activity on systems. Procedures may include - a defined governance process for security event detection and management that includes the provision of resources; - use of intelligence sources to identify newly discovered threats and vulnerabilities; and - logging of unusual system activities. User entities are provided with instructions for communicating potential security breaches to the information security team. Related Security Document: Sec-167. AccuKnox Security Log & Event Management Policy Sec-162. AccuKnox Security Information and Events Monitoring Policy Sec-200. AccuKnox Acceptable Use Policy Sec-203. AccuKnox Security Awareness Training & Education Policy Sec-190. AccuKnox Incident Response Policy and Process	Inspected AccuKnox Security Information and Events Monitoring Policy to determine whether detection policies and procedures are defined. Inspected the instructions provided to user entities to determine whether they included protocols for communicating potential security breaches.	No exceptions noted
CC7.2.2	Implementing Detection Measures AccuKnox has designed and implemented detection measures to identify anomalies that could result from activities such as: - actual or attempted compromise of physical barriers; - unauthorized actions of authorized personnel; - use of compromised identification and authentication credentials; - unauthorized access from outside the system boundaries; - compromise of authorized external parties; and - implementation or connection of unauthorized hardware and software. Detection tools include firewall, network, and host intrusion detections.	Inspected AccuKnox's intrusion detection and firewalls for identification, detection, and reporting of security anomalies. Inspected the written incident management procedures to determine whether the procedures included a process for handling the security incident.	No exceptions noted

	When a potential security incident is detected, a defined incident management process is initiated by authorized personnel. Corrective actions are implemented in accordance with defined policies and procedures. Related Security Document: Sec-162. AccuKnox Security Information and Events Monitoring Policy Sec-190. AccuKnox Incident Response Policy and Process		
CC7.2.3	Implementing Filtering Anomalies to Identify Security Events AccuKnox management has implemented Security Information and Event Management (SIEM) tools to filter, summarize, correlate, and analyze anomalies to identify security events. Related Security Document: Sec-190. AccuKnox Incident Response Policy and Process	Inspected AccuKnox's Security Information and Events Management tool to determine if anomalies reported from detection tools have been received and filtered. Inspected a sample of monitoring tool reports to determine that anomalies were reported.	No exceptions noted
CC7.2.4	Monitoring Detection Tools for Effective Operation AccuKnox has implemented an Intrusion detection system and firewalls. Detected anomalies by those systems are monitored via the SIEM tool for effective operations and continuous monitoring. Related Security Document: Sec-150. AccuKnox Network Security Policy	Inspected intrusion detection system to determine that the network was continuously monitored and potential security breaches were reported.	No exceptions noted
CC7.2.5	Reporting Detected Security Events and Incidents All security events and incidents are reported to the help desk, logged, communicated to affected parties, and tracked through to resolution. Incidents that may affect security compliance are reported to the security compliance officer. Related Security Document: Sec-190. AccuKnox Incident Response Policy and Process	Inspected a sample of IT security incident tickets to determine that an incident response plan was initiated by authorized personnel, threats were mitigated, corrective action plans were documented, incidents were tracked until resolved, and an after-action report was prepared. Selected a sample of security incidents logged in the incident tracking system and inspected documentation to determine whether the incident was reported to security personnel and tracked within the ticket until resolution.	No exceptions noted
CC7.2.6	Assessing Risks for Reported Events A risk assessment is performed for reported security events and incidents. As part of this process, threats and changes (environmental, regulatory, and technological) to service commitments are identified and addressed per established policy and procedures. Related Security Document: Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process	Inspected a sample of reported security events to determine that risks to the organization and operations were evaluated as part of the process.	No exceptions noted

Trust Services Criteria			
CC7.3	The entity <u>evaluates security events</u> to determine whether they could or have resulted in a failure of the entity to meet its objectives (security incidents) and, if so, takes actions to prevent or address such failures.		
CC7.3	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC7.3.1	Responding to Security Incidents AccuKnox has developed security incident response policies and procedures that are communicated to authorized users for responding to security incidents and evaluating the effectiveness of those policies and procedures on a periodic basis. Related Security Document: Sec-190- AccuKnox Incident Response Policy and Process Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process	Inspected incident response policies and procedures to determine that an incident response plan was documented and communicated to responsible users. Inspected a sample of security incidents logged in the incident tracking system and associated communications to the security officer that may affect security compliance to determine whether the incidents were evaluated and responded to by the security team.	No exceptions noted
CC7.3.2	Communicating and Reviewing of Detected Security Events Detected security events are logged, tracked, and communicated to, and reviewed by the individuals responsible for the management of the security program, and actions are taken, if necessary. Related Security Document: Sec-190- AccuKnox Incident Response Policy and Process Sec-167. AccuKnox Security Log & Event Management Policy	Inspected a sample of IT security incident tickets to determine that an incident response plan was initiated by authorized personnel, threats were mitigated, corrective action plans were documented, incidents were tracked until resolved, and an after-action report was prepared.	No exceptions noted
CC7.3.3	Developing and Implementing Procedures to Analyze Security Incidents AccuKnox's procedures are in place to analyze security incidents and determine system impact. An AccuKnox technician or administrator responsible for security incident tickets follows a process of analyzing the security incident. The process begins with detailing what specific attack occurred, which system(s) were affected, and what happened during the attack. Next, the root cause is determined, and the event is given a classification to assign the level of impact of the event. The impact level is based on guidelines detailed in the procedures. Related Security Document: Sec-190- AccuKnox Incident Response Policy and Process Sec-191- AccuKnox Incident Response Plan	Inspected a sample of IT security incident tickets to determine that an incident response plan was initiated by authorized personnel, threats were mitigated, corrective action plans were documented, incidents were tracked until resolved, and an after-action report was prepared.	No exceptions noted

Trust Services Criteria			
CC7.4 The entity <u>responds</u> to identified security incidents by executing a defined incident response program to understand, contain, remediate, and communicate security incidents as appropriate.			
CC7.4	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC7.4.1	Assigning Roles and Responsibilities for Incident Handling AccuKnox management has defined roles and responsibilities for the design, implementation, maintenance, and execution of the incident response program, including the use of external resources when necessary. Related Security Document: Sec-102- AccuKnox Information Security Document Management (Policy, Standards, Process, Artifacts) Sec-190- AccuKnox Incident Response Policy and Process Sec-191- AccuKnox Incident Response Plan	Inspected security policies to determine the company has established defined roles and responsibilities to oversee the implementation of the incident response plan.	No exceptions noted
CC7.4.2	Containing Security Incidents Procedures are in place to contain security incidents that actively threaten entity objectives. After an incident has been confirmed, specific personnel are engaged in the containment process to reduce the magnitude of the incident. Related Security Document: Sec-190- AccuKnox Incident Response Policy and Process Sec-191- AccuKnox Incident Response Plan	Inspected a sample of IT security incident tickets to determine that an incident response plan was initiated by authorized personnel, threats were mitigated, corrective action plans were documented, incidents were tracked until resolved, and an after-action report was prepared.	No exceptions noted
CC7.4.3	Mitigating Ongoing Security Incidents AccuKnox's procedures are in place to mitigate the effects of ongoing security incidents. The containment phase ensures that all other interconnections to the system were not affected by the security incident. Related Security Document: Sec-190- AccuKnox Incident Response Policy and Process Sec-191- AccuKnox Incident Response Plan	Inspected a sample of IT security incident tickets to determine that an incident response plan was initiated by authorized personnel, threats were mitigated, corrective action plans were documented, incidents were tracked until resolved, and an after-action report was prepared.	No exceptions noted
CC7.4.4	Ending Threats Posed by Security Incidents AccuKnox's procedures are in place to end the threats posed by security incidents and to prevent similar incidents in the future through the	Inspected a sample of IT security incident tickets to determine that an incident response plan was initiated by authorized personnel, threats were mitigated, corrective action plans were documented, incidents were tracked until resolved, an after-action report was prepared, and similar vulnerabilities were removed.	No exceptions noted

CC7.4	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
	closure of the vulnerability, removal of unauthorized access, and other remediation actions Related Security Document: Sec-190- AccuKnox Incident Response Policy and Process Sec-191- AccuKnox Incident Response Plan		
CC7.4.5	Restoring Operations AccuKnox's procedures are in place to restore data and business operations to an interim state that permits the achievement of entity objectives. Daily incremental and weekly full backups are configured for the databases in case of the need for data restoration. Related Security Document: Sec-165. AccuKnox Data Backup Policy & Process	Observed backup configuration to determine that daily incremental and weekly full backups were configured for the databases.	No exceptions noted
CC7.4.6	Developing and Implementing Communication Protocols for Security Incidents AccuKnox's procedures for communicating security incidents and actions taken to affected parties are developed and implemented to meet AccuKnox's objectives. Related Security Document: Sec-190- AccuKnox Incident Response Policy and Process Sec-191- AccuKnox Incident Response Plan	Inspected a sample of IT security incident tickets to determine that an incident response plan was initiated by authorized personnel, threats were mitigated, corrective action plans were documented, incidents were tracked until resolved, and an after-action report was prepared.	No exceptions noted
CC7.4.7	Understanding Nature of Incident and Determination of Containment Strategy AccuKnox Incident Response Policy and Response Plan require analysis and understanding of the nature (for example, the method by which the incident occurred and the affected system resources) and severity of the security incident is obtained to determine the appropriate containment strategy, including • a determination of the appropriate response time frame, and • the determination and execution of the containment approach. AccuKnox incorporates lessons learned from ongoing incident response activities into incident response procedures accordingly. If changes are required, necessary changes are made to the policy and procedures and redistributed according to all responsible organizations and key personnel.	Inspected AccuKnox Incident Response Policy and Incident Response Plan to determine whether they include incident postmortem analysis.	No exceptions noted

CC7.4	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
	Related Security Document: Sec-190: AccuKnox Incident Response Policy and Process Sec-191: AccuKnox Incident Response Plan		
CC7.4.8	Remediating Identified Vulnerabilities As part of AccuKnox's Vulnerability and Patch Management Policy and Processes, identified vulnerabilities are remediated through the development and execution of remediation activities. Internal and external network vulnerability scans are performed quarterly. A remediation plan is developed, and changes are implemented to remediate all critical and high vulnerabilities at a minimum. Related Security Document: Sec-168: AccuKnox Vulnerability Management Policy Sec-169: AccuKnox Patch Management Policy & Process Sec-105: AccuKnox Security Risk Assessment/Management Policy & Process	Inspected internal and external vulnerability scans and incident tickets for a sample of quarters to determine that internal and external vulnerability scans were performed quarterly and remediation plans were performed according to patch management policy and procedures to remediate all critical and high vulnerabilities.	No exceptions noted
CC7.4.9	Communicating Remediation Activities AccuKnox's Incident Response Plan and Policy require remediation activities to be documented and communicated. Related Security Document: Sec-190: AccuKnox Incident Response Policy and Process Sec-191: AccuKnox Incident Response Plan	Inspected the incident response plan and policy to determine whether the plan requires remediation activities to be documented and communicated to stakeholders and the security steering committee.	No exceptions noted
CC7.4.10	Evaluating Effectiveness of Incident Response The design of incident response activities is evaluated for effectiveness on an annual basis.	Inspected AccuKnox's Incident Response Plan and Policy to determine whether the policy requires incident activities to be evaluated for effectiveness on an annual basis. Verified changes and updates made to the policy.	No exceptions noted
CC7.4.11	Evaluating Incidents Periodically, management reviews incidents related to security, availability, processing integrity, confidentiality, and privacy and identifies the need for system changes based on incident patterns and root causes.	Interviewed security officer to determine whether security-related incidents were evaluated on an annual basis.	No exceptions noted

Trust Services Criteria			
CC7.5	The entity identifies, develops, and implements activities to <u>recover</u> from identified security incidents		
CC7.5	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC7.5.1	Restoring the Affected Environment AccuKnox's activities to restore the affected environment to functional operation include rebuilding systems, updating software, installing patches, and changing configurations, as needed. Software updates to restore the affected environment are tested for effectiveness and potential side effects on the system before installation. All software updates and patches are tested by creating a virtual instance of the environment and running the tests associated with the software update and/or patch. The ability to rollback is implemented during software updates and/or patching. Related Security Document: Sec-169. AccuKnox Patch Management Policy & Process	Inspected the configuration management policy to determine that all changes, including patches/updates are configuration controlled through virtual instance testing and rollback capability. Inspected a sample of patch updates to determine that patches were tested in accordance with the configuration management policy prior to being placed into production.	No exceptions noted
CC7.5.2	Communicating Information About the Event AccuKnox communicates information about the nature of the incident, recovery actions taken, and activities that are required for the prevention of future security events to management and others as appropriate (internal and external). Related Security Document: Sec-190. AccuKnox Incident Response Policy and Process Sec-191. AccuKnox Incident Response Plan	Inspected a sample of IT security incident tickets to determine that an incident response plan was initiated by authorized personnel, threats were mitigated, corrective action plans were documented, incidents were tracked until resolved, and an after-action report was prepared and communicated to management and others as appropriate.	No exceptions noted
CC7.5.3	Determining Root Cause of the Event AccuKnox's technician or administrator responsible for security incident tickets follows a process of analyzing the security incident. The process begins with detailing what specific attack occurred, which system(s) were affected, and what happened during the attack. Next, the root cause is determined, and the event is given a classification to assign the level of impact of the event. The impact level is based on guidelines detailed in the procedures. Related Security Document: Sec-190. AccuKnox Incident Response Policy and Process Sec-191. AccuKnox Incident Response Plan	Inspected a sample of IT security incident tickets to determine that an incident response plan was initiated by authorized personnel, the incident was analyzed, the root cause of the incident was determined, threats were mitigated, corrective action plans were documented, incidents were tracked until resolved, and an after-action report was prepared.	No exceptions noted

CC7.5	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC7.5.4	Implementing Changes to Prevent and Detect Recurrences AccuKnox evaluates the incident response through analysis of after-action reports of the mitigation of exploited vulnerabilities and implements additional architecture or changes to prevent and detect recurrence of similar incidents in the future. Related Security Document: Sec-190- AccuKnox Incident Response Policy and Process Sec-191- AccuKnox Incident Response Plan	Inspected incident response policies and procedures to determine that it required implementation of changes to detect and prevent future similar incidents. Inspected a sample of IT security incident tickets to determine that an incident response plan was initiated by authorized personnel, the incident was analyzed, the root cause of the incident was determined, threats were mitigated, corrective action plans were documented, incidents were tracked until resolved, and an after-action report was prepared.	No exceptions noted
CC7.5.5	Improving Response and Recovery Procedures AccuKnox incorporates lessons learned from ongoing incident response activities into incident response procedures accordingly. If changes are required, necessary changes are made to the policy and procedures and redistributed according to all responsible organizations and key personnel. Related Security Document: Sec-190- AccuKnox Incident Response Policy and Process Sec-191- AccuKnox Incident Response Plan	Inspected the incident response plan to determine that the document has been reviewed and revised every year and changes were incorporated from prior incidents and associated lessons learned.	No exceptions noted
CC7.5.6	Implementing Incident Recovery Plan Testing AccuKnox performs annual testing of the incident response plan and recovery plan using tabletop exercises and simulations to ensure the incident response procedures are up-to-date and accurate. The testing includes: • development of testing scenarios based on threat likelihood and magnitude; • consideration of relevant system components from across the entity that can impair availability; • scenarios that consider the potential for the lack of availability of key personnel; and • revision of continuity plans and systems based on test results. When updating the incident response plan, lessons learned from tabletop exercises are used to implement changes to reflect effective procedures when handling incidents. Related Security Document: Sec-190- AccuKnox Incident Response Policy and Process Sec-191- AccuKnox Incident Response Plan	Inspected documentation for the most recent incident response plan review to determine that the plan was tested within the past year and that drills conducted to imitate incidents were resolved, and service availability was restored. Inspected the incident response plan for revision due to the testing performed.	No exceptions noted

CC7.5	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC7.5.7	AccuKnox has a formalized security and systems development methodology that includes project planning, design, testing, implementation, maintenance, and disposal or decommissioning. Related Security Document: Sec-170: AccuKnox Application Security Policy	Inspected the security and systems methodology policy to determine whether it includes project planning, design, testing, implementation, maintenance, and disposal or decommissioning.	No exceptions noted
CC7.5.8	Security administration team approval of changes is required prior to implementation. Related Security Document: Sec-166: AccuKnox Change Management Policy & Process	Inspected change documentation from a system-generated list of system changes to determine whether the changes were approved by the security administration prior to implementation.	No exceptions noted

4.8. CC8.0 - Change Management

Trust Services Criteria			
CC8.1	The entity authorizes, designs, develops or acquires, configures, documents, tests, approves, and implements <u>changes</u> to infrastructure, data, software, and procedures to meet its objectives.		
CC8.1	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC8.1.1	Managing Changes Throughout the System Lifecycle AccuKnox has adopted a formal systems development lifecycle (SDLC) methodology that governs the development, acquisition, implementation, and maintenance of computerized information systems and related technology requirements. AccuKnox has also adopted a process for managing system changes throughout the development, the system, and its components lifecycle (infrastructure, data, software, and procedures) to support system availability and processing integrity. Related Security Document: Sec-166- AccuKnox Change Management Policy & Process Sec-170- AccuKnox Application Security Policy Sec-172- AccuKnox Secure Software Development Life Cycle SDLC Sec-177- AccuKnox Application Security Standard	Inspected AccuKnox Change Management Policy and Procedures to determine that processes were adopted for managing changes to the system, software, and infrastructure. Inspected AccuKnox's systems development life cycle (SDLC) methodology to determine that it supports system availability and processing integrity.	No exceptions noted
CC8.1.2	Authorizing Changes AccuKnox's software and infrastructure change management process requires the following prior to change requests to be: • Authorized • Formally documented • Tested prior to migration to production • Reviewed and approved Related Security Document: Sec-166- AccuKnox Change Management Policy & Process	Inspected Change Control Board (CCB) meeting minutes for the list of items reviewed and authorized by the board. Inspected a sample of change requests to determine that changes were: • Authorized • Formally documented • Tested prior to migration to production • Reviewed and approved • Tracked through completion	No exceptions noted
CC8.1.3	Design and Development of Changes AccuKnox has formally documented change management procedures (including emergency procedures) to govern the design, development, and modification and maintenance of production systems and address security and availability requirements.	Inspected the change management procedures to determine that procedures were in place to govern the design, modification and maintenance of production systems and addressed security and availability requirements.	No exceptions noted

CC8.1	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
	Related Security Document: Sec-166: AccuKnox Change Management Policy & Process		
CC8.1.4	Documenting Changes AccuKnox's change management policy and process require all changes, including maintenance activities, to be documented from initiation through deployment and validation. Related Security Document: Sec-166: AccuKnox Change Management Policy & Process	Inspected a sample of change requests to determine that changes were: • Authorized • Formally documented • Tested prior to migration to production • Reviewed and approved • Tracked through completion	No exceptions noted
CC8.1.5	Tracking System Changes AccuKnox's change management policy and process require all changes, including maintenance activities, to be tracked from initiation through deployment and validation. Related Security Document: Sec-168: AccuKnox Vulnerability Management Policy	Inspected a sample of change requests to determine that changes were: • Authorized • Formally documented • Tested prior to migration to production • Reviewed and approved • Tracked through completion	No exceptions noted
CC8.1.6	Configuring Software AccuKnox change process is in place to select and implement the configuration parameters used to control the functionality of the software. Baseline configurations are retained within the configuration management tool for roll-back capability anytime an approved configuration change is made. Baseline configurations are reviewed and updated annually or when required due to reviews and system changes, and anytime integral system components are added. Related Security Document: Sec-168: AccuKnox Vulnerability Management Policy Sec-169: AccuKnox Patch Management Policy & Process Sec-166: AccuKnox Change Management Policy & Process	Inspected the configuration management tool to determine that baseline configuration was retained and up to date for applicable system changes.	No exceptions noted
CC8.1.7	Testing System Changes AccuKnox's change management policy and process are in place and require all changes, including maintenance activities, to be tested prior to implementation through deployment and validation.	Inspected a sample of change requests to determine that changes were: • Authorized • Formally documented • Tested prior to migration to production • Reviewed and approved	No exceptions noted

CC8.1	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
	Related Security Document: Sec-169. AccuKnox Patch Management Policy & Process Sec-166. AccuKnox Change Management Policy & Process	Tracked through completion	
CC8.1.8	Approving System Changes AccuKnox's change management policy and process require all changes, including maintenance activities, to be approved prior to implementation. Related Security Document: Sec-168. AccuKnox Vulnerability Management Policy Sec-169. AccuKnox Patch Management Policy & Process	Inspected a sample of change requests to determine that changes were: - Authorized and approved - Formally documented - Tested prior to migration to production - Reviewed and approved - Tracked through completion	No exceptions noted
CC8.1.9	Deploying System Changes AccuKnox has formally documented change management procedures (including emergency procedures) to govern the design, development, and modification, and maintenance of systems and address security and availability requirements. Related Security Document: Sec-168. AccuKnox Vulnerability Management Policy	Inspected the change management procedures to determine that procedures were in place to govern the design, modification and maintenance of production systems and addressed security and availability requirements.	No exceptions noted
CC8.1.10	Identifying and Evaluating System Changes AccuKnox identifies objectives affected by system changes and evaluates the ability of the modified system to meet the objectives through the system development life cycle. Related Security Document: Sec-190. AccuKnox Incident Response Policy and Process Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process	Inspected the change management policy and procedures to determine that procedures were in place to govern the identification, evaluation, design, modification, and maintenance of production systems and addressed security and availability requirements.	No exceptions noted
CC8.1.11	Identifying Changes in Infrastructure, Data, Software, and Procedures Required to Remediate Incidents AccuKnox identifies changes in infrastructure, data, software, and procedures required to remediate incidents to continue to meet objectives and initiates the change process upon identification through a formal documented change management process. Changes to hardware, operating system, and system software are authorized, tested (when applicable), and approved by appropriate personnel prior to implementation.	Inspected the change management policy for hardware, operating system, and system software to determine whether procedures are formally documented, including procedures over authorization, testing (when applicable), and approval prior to implementation. Inspected change documentation from a system-generated list of system changes to determine whether the changes were authorized, tested, and approved prior to implementation.	No exceptions noted

CC8.1	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
	Related Security Document: Sec-166- AccuKnox Change Management Policy & Process		
CC8.1.12	Creating Baseline Configuration of IT Technology AccuKnox has defined and retained a baseline configuration within the configuration management tool for roll-back capability anytime an approved configuration change is made. Baseline configurations are reviewed and updated annually or when required due to reviews and system changes, and anytime integral system components are added. Related Security Document: Sec-166- AccuKnox Change Management Policy & Process	Inspected the configuration management tool to determine that baseline configurations are retained and up to date for applicable system changes.	No exceptions noted
CC8.1.13	Providing for Changes Necessary in Emergency Situations AccuKnox has defined and documented policies and procedures for authorizing, designing, testing, approving, and implementing changes necessary in emergency situations (that is, changes that need to be implemented in an urgent timeframe). Emergency changes follow the standard change management process but at an accelerated timeline. Prior to initiating an emergency change, all necessary approvals are obtained and documented. Related Security Document: Sec-166- AccuKnox Change Management Policy & Process	Inspected change documentation from a system-generated list of program changes for a sample of emergency changes to determine whether the changes were approved.	No exceptions noted
CC8.1.14	Protecting Confidential information AccuKnox protects confidential information during system design, development, testing, implementation, and change processes to meet the entity's objectives related to confidentiality. Related Security Document: Sec-166- AccuKnox Change Management Policy & Process	Inspected the change management policy and procedures to determine that procedures were in place to govern the identification, evaluation, design, modification, and maintenance of production systems and addressed security and availability requirements.	No exceptions noted

4.9. CC9.0 – Risk Mitigation

Trust Services Criteria			
CC9.1	The entity identifies, selects, and develops risk mitigation activities for risks arising from potential business disruptions.		
CC9.1	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC9.1.1	Considering for Mitigation of Risks of Business Disruption AccuKnox's Risk mitigation activities include the development of planned policies, procedures, communications, and alternative processing solutions to respond to, mitigate, and recover from security events that disrupt business operations. Those policies and procedures include monitoring processes and information and communications to meet AccuKnox's objectives during the response, mitigation, and recovery efforts. A documented risk management program is in place that includes guidance on the identification of potential threats, rating the significance of the risks associated with the identified threats, and mitigation strategies for those risks. A risk assessment is performed on at least an annual basis. As part of this process, threats and changes (environmental, regulatory, and technological) to service commitments, policies, and procedures are identified, and the risks are formally assessed. Related Security Document: Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process	Inspected the risk management policy to determine that a program had been established around the identification of potential threats, rating the significance of the risks associated with the identified threats, and mitigation strategies for those risks. Inspected the most recent risk assessment to determine that threats and changes were formally identified and assessed on an annual basis.	No exceptions noted
CC9.1.2	Considering the Use of Insurance to Mitigate Financial Impact Risks AccuKnox's risk management activities consider the use of insurance to offset the financial impact of loss events that would otherwise impair the ability of the entity to meet its objectives.	Inspected AccuKnox's Security Risk Management Policy to determine that a policy includes the use of insurance to mitigate the financial impact of loss events.	No exceptions noted

Trust Services Criteria			
CC9.2	The entity assesses and manages risks associated with vendors and business partners.		
CC9.2	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC9.2.1	Establishing Requirements for Vendor and Business Partner Engagements AccuKnox establishes specific requirements for a vendor and business partner engagement that includes: • scope of services and product specifications, • roles and responsibilities, • compliance requirements, and • service levels. Related Security Document: Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process Sec-106. AccuKnox Third Party / Vendor Security Risk Management Policy & Process	Inspected AccuKnox's Third Party and Vendor Security Risk Management Policy and Procedures to determine that the policy includes the establishment of requirements for vendors and business partners' engagements.	No exceptions noted
CC9.2.2	Assessing Vendor and Business Partner Risks As part of AccuKnox's vendor risk management process, AccuKnox assesses, on a periodic basis, the risks that vendors and business partners that have access to confidential data or impact the security of the system represent to the achievement of AccuKnox's objectives. Related Security Document: Sec-106. AccuKnox Third Party / Vendor Security Risk Management Policy & Process	Inspected AccuKnox's third-party and Vendor Security Risk Management Policy and Procedures to determine that the program has been established. Inspected vendor risk assessment documentation for a sample of vendors to determine that a risk assessment was performed within the past year.	No exceptions noted
CC9.2.3	Assigning Responsibility and Accountability for Managing Vendors and Business Partners AccuKnox assigns responsibility and accountability for the management of risks associated with vendors and business partners and to oversees the implementation of vendor information security policy. Related Security Document: Sec-106. AccuKnox Third Party / Vendor Security Risk Management Policy & Process	Inspected security policies to determine AccuKnox has established defined roles and responsibilities to oversee the implementation of information security policies.	No exceptions noted

CC9.2	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC9.2.4	Establishing Communication Protocols for Vendors and Business Partners AccuKnox establishes communication and resolution protocols for service or product issues related to vendors and business partners. Related Security Document: Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process	Inspected AccuKnox Vendor Security Policy and Procedures to determine that they address applicable information security requirements, including communication of service issues. Observed AccuKnox's intranet to determine that security policies are published and communicated to employees and relevant third parties.	No exceptions noted
CC9.2.5	Establishing Exception Handling Procedures from Vendors and Business Partners AccuKnox has documented and communicated security policies that define the information security rules and requirements for the service environment, which includes exception handling procedures for service or product issues related to vendors and business partners. Related Security Document: Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process Sec-102. AccuKnox Information Security Document Management (Policy, Standards, Process, Artifacts)	Inspected AccuKnox's third-party and Vendor Security Risk Management Policy and Procedures to determine that the policy includes exception handling from vendors and business partners.	No exceptions noted
CC9.2.6	Assessing Vendor and Business Partner Performance An annual vendor risk assessment is performed by management and includes the following: a. Determining business objectives, entity, subsidiary, division, operating unit, and functional levels b. Evaluating the effect of environmental, regulatory, and technological changes on AccuKnox system security c. Involving appropriate levels of management. d. Analyzing risks associated with the threats e. Identifying threats to operations, including security threats, using information technology asset records f. Identifying threats to operations, including threats from vendors, business partners, and other partners. Related Security Document: Sec-105. AccuKnox Security Risk Assessment/Management Policy & Process	Inspected the annual vendor risk assessment documentation to determine whether it included the significant aspects of operations and performance.	No exceptions noted

CC9.2	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
CC9.2.7	Implementing Procedures for Addressing Issues Identified During Vendor and Business Partner Assessments AccuKnox security risk management policy requires the implementation of procedures for addressing issues identified with vendor and business partner relationships. Related Security Document: Sec-106- AccuKnox Third Party / Vendor Security Risk Management Policy & Process	Inspected AccuKnox security risk management policy and procedures to determine whether the vendor risks identified during vendor risk assessments were addressed.	No exceptions noted
CC9.2.8	Implementing Procedures for Terminating Vendor and Business Partner Relationships AccuKnox has clauses in its agreements with vendors and business partners to terminate relationships when necessary. Vendor and business partner access is removed upon termination through a termination checklist, and access is revoked within 24 hours as part of the termination process.	Inspected a listing of terminated vendors and compared the vendor employee listing to the active user listing to determine that terminated vendor employees did not retain access to the in-scope system and platforms after their separation. Inspected termination tickets for a sample of terminated vendors during the review period to determine that vendor employee access was revoked within 24 hours as a part of the termination process.	No exceptions noted
CC9.2.9	Obtaining Confidentiality Commitments from Vendors and Business Partners AccuKnox obtains confidentiality commitments through an agreement that is consistent with AccuKnox's confidentiality commitments and requirements from vendors and business partners who have access to confidential information.	Inspected sample of contracts vendors to determine those agreements included the scope of services and security commitments, including confidentiality.	No exceptions noted
CC9.2.10	Assessing Compliance with Confidentiality Commitments of Vendors and Business Partners On a periodic and as-needed basis, per the vendor security risk assessment process, AccuKnox assesses compliance by vendors and business partners with AccuKnox's confidentiality commitments and requirements.	Inspected the annual vendor risk assessment documentation to determine whether it included compliance with confidentiality requirements.	No exceptions noted

4.10. Additional Criteria Applicable to the Availability Principle

Trust Services Criteria			
A1.1	The entity maintains, monitors, and evaluates current processing capacity and use of system components (infrastructure, data, and software) to manage capacity demand and to enable the implementation of additional capacity to help meet its objectives.		
A1.1	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
A1.1	Measuring Current Usage The use of AccuKnox's system components is measured to establish a baseline for capacity management and to use when evaluating the risk of impaired availability due to capacity constraints. AccuKnox has implemented the capacity planning process, which is used to identify and quantify adjustments to the growing demand for resources. The goal of the capacity process is to plan while using optimal efficiency. AccuKnox capacity planning is done monthly. Hardware, storage, and application usage are collected from AccuKnox centralized monitoring, and growth is calculated (where applicable). Based on those numbers, future capacity requirements are estimated, and follow-up tickets are filed. Cloud Operations senior management meets periodically or as needed to discuss capacity findings and approves significant capacity changes. The main items reviewed during the monthly meeting are: • Network usage • Customer usage for applicable applications • Data files sizes for major applications • CPU/memory/disk usage for Search applications	AccuKnox leverages the cloud service provider's automated utilities to monitor usage and capacity that can optimize for the workload and adjust capacity as needed, and notify System Administrators.	No exceptions noted
A1.2	Forecasting Capacity With the use of cloud services, there is no need to provision up-front resources. Cloud service providers such as AWS and GCP can optimize the workload and adjust capacity as needed.	AccuKnox leverages the cloud service provider's services that can optimize for the workload and adjust capacity as needed.	No exceptions noted
A1.3	Making Changes Based on Forecasts The system change management process is initiated when forecasted usage exceeds capacity tolerances.	Inspected AccuKnox's Change Management Policy and Procedures to determine that the capacity change is addressed within the document.	No exceptions noted

Trust Services Criteria			
A1.2	The entity authorizes, designs, develops or acquires, implements, operates, approves, maintains, and monitors environmental protections, software, data backup processes, and recovery infrastructure to meet its objectives.		
A1.2	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
A1.2.1	Identifying Environmental Threats As part of the risk assessment process, management identifies environmental threats that could impair the availability of the system, including threats resulting from adverse weather, failure of environmental control systems, electrical discharge, fire, and water. AccuKnox uses the platform service provider's PaaS (GCP) for all its production and customer resources to protect the availability of AccuKnox resources and functions. The following controls are designed, developed, implanted, maintained, and monitored by the PaaS provider (GCP). • Cooling systems • Battery backup in the event of power failure • Redundant communications lines • Smoke detectors • Dry pipe sprinklers Operations personnel monitor the status of environmental protection during each shift. Environmental protections receive maintenance on an annual basis.	This control is inherited from AccuKnox's cloud service provider. Inspected AccuKnox's PaaS provider's annual certification to determine that the environmental protections are authorized, designed, developed, implemented, operated, approved, maintained, and monitored to meet AccuKnox's availability commitments and system requirements.	No exceptions noted
A1.2.2	Designing and Detecting Measures Detection measures are implemented to identify anomalies that could result from environmental threat events.	This control is inherited from the cloud service provider Reviewed cloud service provider's SOC 2 reports.	No exceptions noted
A1.2.3	Implementing and Maintaining Environmental Protection Mechanisms Management implements and maintains environmental protection mechanisms to prevent and mitigate environmental events. AccuKnox uses a cloud service providers' multi-location strategy for its facilities to permit the resumption of operations at other facilities in the event of loss of a facility. Cloud service provider critical infrastructure components have a minimum level of redundancy. Disaster recovery and business continuity plan is documented, authorized, designed, implemented, operated, approved, maintained,	Interviewed Operations management to obtain an understanding of the disaster recovery plan. This control is inherited from AccuKnox cloud service provider (GCP), which utilizes a multi-location strategy for its facilities to resume resumption of operations at other facilities in the event of loss of a facility. Inspected the Disaster Recovery Plan to determine whether the plan is documented and appropriately communicated to users. Reviewed cloud service provider's SOC 2 reports	No exceptions noted

A1.2	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
	and monitored to meet AccuKnox's availability commitments and system requirements.		
A1.2.4	Maintaining Power Supply A backup power supply is available for the data centers in case of primary power failure. Backup power generators are maintained on a regular basis. Maintenance is documented by the supplier company providing a report.	This control is inherited from the cloud service provider (GCP PaaS) Reviewed cloud service provider's SOC 2 reports.	No exceptions noted
A1.2.5	Maintaining Fire Suppressing System The data center is equipped with appropriate fire emergency systems. Fire emergency systems are tested and maintained on a regular basis. Maintenance is documented by the supplier company providing a report.	This control is inherited from the cloud service provider (GCP PaaS) Reviewed cloud service provider's SOC 2 reports.	No exceptions noted
A1.2.6	Maintaining Air Condition Control System Systems are operating within a required temperature scale. The data center is equipped with air conditioning systems. Air conditioning systems are tested and maintained on a regular basis. Maintenance is documented by the supplier company providing a report.	This control is inherited from the cloud service provider (GCP PaaS) Reviewed cloud service provider's SOC 2 reports.	No exceptions noted
A1.2.6	Implementing Alerts to Analyze Environmental Anomalies Management implements alerts that are communicated to personnel for analysis to identify environmental threat events.	This control is inherited from the cloud service provider (GCP PaaS) Reviewed cloud service provider's SOC 2 reports.	No exceptions noted
A1.2.6	Responding to Environmental Threat Events Procedures are in place for responding to environmental threat events and for evaluating the effectiveness of those policies and procedures on a periodic basis. This includes automatic mitigation systems (for example, uninterruptable power system and generator back-up subsystem).	This control is inherited from the cloud service provider (GCP PaaS) Reviewed cloud service provider's SOC 2 reports.	No exceptions noted
A1.2.6	Communicating and Reviewing of Detected Environmental Threat Events Detected environmental threat events are communicated to and reviewed by the individuals responsible for the management of the system, and actions are taken, if necessary.	This control is inherited from the cloud service provider (GCP PaaS) Reviewed cloud service provider's SOC 2 reports.	No exceptions noted
A1.2.6	Determining Data Requiring Backup AccuKnox evaluates data to determine whether backup is required. Weekly full-system and daily incremental backups are performed using an automated system.	Inspected data backup configurations to determine whether data was identified for backups. Inspected AccuKnox's automated system backup configurations to determine that weekly backup is scheduled. Inspected samples of performed backups.	No exceptions noted

A1.2	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
	Backups are monitored for failure using an automated system, and the incident management process is automatically invoked. IT Management has implemented a strategy for periodic backup and restoration. The usability of the backups is verified annually via restoration testing, and results are documented.	Inspected automated backup system to determine that the system was configured to alert appropriate authorities in case of backup failure. Interviewed the Database Administrator to obtain an understanding of the process for the restoration testing. Inspected results of the restoration testing to determine whether the tests were performed and were successful.	
A1.2.6	Addressing Offsite Storage Back-up data is stored in a location at a distance from its principal storage location sufficient that the likelihood of a security or environmental threat event affecting both sets of data is reduced to an appropriate level.	This control is inherited from the cloud service provider (GCP PaaS) Reviewed cloud service provider's SOC 2 reports.	No exceptions noted
A1.2.6	Implementing Alternate Processing Infrastructure Measures are implemented for migrating processing to alternate infrastructure in the event normal processing infrastructure becomes unavailable.	This control is inherited from the cloud service provider (GCP PaaS) Reviewed cloud service provider's SOC 2 reports.	No exceptions noted

Trust Services Criteria			
A1.3	The entity tests recovery plan procedures are supporting system recovery to meet its objectives.		
A1.3	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
A1.3.1	Implementing Business Continuity Plan Testing Business continuity plan testing is performed on a periodic basis. The testing includes - development of testing scenarios based on threat likelihood and magnitude; - consideration of system components from across the entity that can impair the availability; - scenarios that consider the potential for the lack of availability of key personnel; and - revision of continuity plans and systems based on test results. Disaster recovery plans, including restoration of backups, are tested annually. Related Security Document: Sec-210- AccuKnox Business Contingency Policy Sec-211- AccuKnox Business Continuity and Disaster Recovery Policy	Inspected AccuKnox Business Continuity and Disaster Recovery Plan to determine that the testing was required. This control is inherited from the cloud service provider (AWS, GCP)	No exceptions noted
A1.3.2	Testing Integrity and Completeness of Back-Up Data The integrity and completeness of backup information are tested on a periodic basis. Related Security Document: Sec-165. AccuKnox Data Backup Policy & Process	Inspected a sample of data backup for integrity and completeness within the examination period.	No exceptions noted

4.11. Additional Criteria Applicable to the Confidentiality Principle

Trust Services Criteria			
C1.1	The entity identifies and maintains confidential information to meet the entity's objectives related to confidentiality.		
C1.1	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
C1.1.1	Identifying Confidential Information Per AccuKnox's Asset Management Policy and Data Classification Policy, confidential information is identified and designated when it is received or created and determined the period over which the confidential information is to be retained per AccuKnox's data retention policy. Related Security Document: Sec-111. AccuKnox Information Classification and Handling Policy Sec-115. AccuKnox Data Retention Policy	Inspected AccuKnox Asset Management Policy and Data Classification Policy documents to determine that procedures existed around classifying and protecting confidential information. Inspected information asset inventory with classifications	No exceptions noted
C1.1.2	Protecting Confidential information From Destruction Per AccuKnox's Information classification and handling policy, procedures are in place to protect confidential information from erasure or destruction during the specified retention period of the information. Related Security Document: Sec-111. AccuKnox Information Classification and Handling Policy	Inspected AccuKnox's Information Classification and Handling policy to determine that requirements exist for the protection of confidential information from destruction.	No exceptions noted

Trust Services Criteria			
C1.2	The entity disposes of confidential information to meet the entity's objectives related to confidentiality.		
C1.2	AccuKnox's Control Implementations	Infoguard's Test Procedures	Infoguard's Test Results
C1.2.1	Identifying Confidential Information for Destruction Procedures are in place to identify confidential information requiring destruction when the end of the retention period is reached. Formal data retention and disposal procedures are in place to guide the secure disposal of the company's and customers' data. Related Security Document: Sec-114. AccuKnox Data Disposal and Sanitization Policy Sec-115. AccuKnox Data Retention Policy	Inspected data retention and disposal procedures to determine that they were in place.	No exceptions noted
C1.2.2	Destructing Confidential Information Procedures are in place to erase or otherwise destroy confidential information that has been identified for destruction. Per AccuKnox's Data Disposal and Sanitization Policy Related Security Document: Sec-114. AccuKnox Data Disposal and Sanitization Policy	Inspected data retention and disposal procedures to determine that they were in place.	No exceptions noted

Section V. Notes

